

IEEE

SECURITY & PRIVACY

BUILDING DEPENDABILITY, RELIABILITY, AND TRUST

The Future of Cybersecurity Policy

Reliability Society



IEEE
COMPUTER
SOCIETY



IEEE

January/February 2020
Vol. 18, No. 1

COMPSAC 2020

Madrid, Spain

July 13-17, 2020

COMPSAC is the IEEE Computer Society Signature Conference on Computers, Software and Applications. It is a major international forum for academia, industry, and government to discuss research results and advancements, emerging challenges, and future trends in computer and software technologies and applications. The theme of COMPSAC 2020 is “Driving Intelligent Transformation of the Digital World”.

Staying relevant in a constantly evolving digital landscape is a challenge faced by researchers, developers, and producers in virtually every industry and area of study. Once limited to software-enabled devices, the ubiquity of digitally-enabled systems makes this challenge a universal issue. Furthermore, as relevance fuels change, many influencers will offer solutions that benefit their own priorities. Fortunately, history has shown that the building blocks of digital change are forged by those conducting foundational research and development of digital systems and human interactions. Artificial Intelligence is not new, but is much more utilized in everyday computing now that data and processing resources are more economically viable, hence widely available. The opportunity to drive the use of this powerful tool in transforming the digital world is yours. Will your results help define the path ahead, or will you relegate those decisions to those with different priorities for utilizing intelligence in digital systems? COMPSAC has been and continues to be a highly respected venue for the dissemination of key research on computer and software systems and applications, and has influenced fundamental developments in these fields for over 40 years. COMPSAC 2020 is your opportunity to add your mark to this ongoing journey, and we highly encourage your submission!

COMPSAC 2020, organized as a tightly integrated union of symposia, will focus on technical aspects of issues relevant to intelligent transformation of the digital world. The technical program will include keynote addresses, research papers, industrial case studies, fast abstracts, a doctoral symposium, poster sessions, and workshops and tutorials on emerging and important topics related to the conference theme. Highlights of the conference will include plenary and specialized panels that will address the technical challenges facing researchers and practitioners who are driving fundamental changes in intelligent systems and applications. Panels will also address cultural and societal challenges for a society whose members must continue to learn to live, work, and play in the environments the technologies produce.

Authors are invited to submit original, unpublished research work, as well as industrial practice reports. Simultaneous submission to other publication venues is not permitted except as highlighted in the COMPSAC 2020 J1C2 & C1J2 program. All submissions must adhere to IEEE Publishing Policies, and will be vetted through the IEEE CrossCheck portal. Further info is available at www.compsac.org.

Organizers

Standing Committee Chair: Sorel Reisman (California State University, USA)

Steering Committee Chair: Sheikh Iqbal Ahamed (Marquette University, USA)

General Chairs: Mohammad Zulkernine (Queen's University, Canada), Edmundo Tovar (Universidad Politécnica de Madrid, Spain), Hironori Kasahara (Waseda University, Japan)

Program Chairs in Chief: W. K. Chan (City University, Hong Kong), Bill Claycomb (Carnegie Mellon University, USA), Hiroki Takakura (National Institute of Informatics, Japan)

Workshop Chairs: Ji-Jiang Yang (Tsinghua University, USA), Yuuichi Teranishi (National Institute of Information and Communications Technology, Japan), Dave Towey (University of Nottingham Ningbo China, China), Sergio Segura (University of Seville, Spain)

Local Chairs: Sergio Martin (UNED, Spain), Manuel Castro (UNED, Spain)

Important Dates

Workshops proposals due: 15 November 2019

Workshops acceptance notification: 15 December 2019

Main conference papers due: 20 January 2020

Paper notification: 3 April 2020

Workshop papers due: 9 April 2020

Workshop paper notifications: 1 May 2020

Camera-ready and registration due: 15 May 2020



IEEE



IEEE
COMPUTER
SOCIETY

Photo: King Felipe III in Major Square, Madrid

Photo credit: Iria Castro - Photographer (Instagram @iriacastrphoto)



Cover art by Barry Downard, www.debutart.com

The Future of Cybersecurity Policy

This special issue of *IEEE Security & Privacy* explores future trends impacting cybersecurity policy. Dynamic trends are affecting the landscape of cybersecurity policy making. Whatever the driver of these changes—new technologies, threat types, or innovative approaches in government, industry, or society—there is a need to anticipate and prepare for them and to clarify the challenges, opportunities, and interdependencies we face. The articles focus on updating the way we think about attribution, assessing the future of cyberinsurance, harmonizing governance in a data-driven society, anticipating future trends in the information environment, and learning about the European approach to cybersecurity governance.

8 Guest Editors' Introduction—The Future of Cybersecurity Policy

Kate Charlet and Heather King

12 Deconstructing Cyber Attribution: A Proposed Framework and Lexicon

Andrew Grotto

21 Does Insurance Have a Future in Governing Cybersecurity?

Daniel W. Woods and Tyler Moore

28 Toward a Data-Driven Society: A Technological Perspective on the Development of Cybersecurity and Data-Protection Policies

José L. Hernández-Ramos, Dimitris Geneiatakis, Ioannis Kounelis, Gary Steri, and Igor Nai Fovino

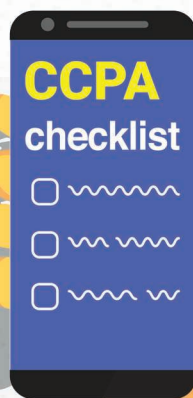
39 Understanding the Information Environment to Win the Next Conflict Without Firing a Shot

Michael Klipstein, Austin Minter, and Jeremiah Pittman

46 Governance Challenges for European Cybersecurity Policies: Stakeholder Views

Pierantonio Sterlini, Fabio Massacci, Natalia Kadenko, Tobias Fiebig, and Michel van Eeten

California Consumer Privacy Act



61



65

Columns

4 From the Editors

The Value of Useless Academic Research to the Cyberdefense of Critical Infrastructures
David M. Nicol

72 Last Word

Technologists vs. Policy Makers
Bruce Schneier

Departments

55 Resilient Security

Cyberattack-Resilient Cyberphysical Systems
Barry M. Horowitz

61 Privacy Interests

Handling of Personal Information and Deidentified, Aggregated, and Pseudonymized Information Under the California Consumer Privacy Act
William Stallings

65 Real-World Crypto

Blockchain Compliance With Federal Cryptographic Information-Processing Standards
James P. Howard II and Maria E. Vachino

Also in This Issue

6 | IEEE Reliability Society Information

Cover 3 | IEEE Computer Society Information

EDITOR IN CHIEF

David M. Nicol | University of Illinois
at Urbana-Champaign

ASSOCIATE EDITORS IN CHIEF

Terry Benzel | USC Information Sciences Institute
Jeremy Epstein | National Science Foundation
James Bret Michael | Naval Postgraduate School
Sean Peisert | Lawrence Berkeley National
Laboratory and University of California, Davis
Phyllis A. Schneck | Northrop Grumman
Paul van Oorschot | Carleton University
Laurie Williams | North Carolina State University

EDITORIAL BOARD

Nikita Borisov | University of Illinois
at Urbana-Champaign
Kc Claffy | Center for Applied Internet
Data Analysis (CAIDA)
Robert Deng | Singapore Management University
Dieter Gollmann | Technical University
Hamburg-Harburg
Feng Hao | University of Warwick
Trent Jaeger | The Pennsylvania State University
Roy Maxion | Carnegie Mellon University
Gary McGraw
Bashar Nueseibeh | The Open University and Lero
Hamed Okhravi | MIT Lincoln Laboratory
Indrakshi Ray | Colorado State University
Anderson Rocha | University of Campinas
XiaoFeng Wang | Indiana University
Vinod Yegneswaran | SRI International
Jianying Zhou | Singapore University
of Technology and Design

DEPARTMENT EDITORS

Building Security In | Fabio Massacci, University
of Trento; and John Steven, Zero North
Cybercrime and Forensics | Pavel Gladyshev,
University College Dublin
Education | Jelena Mirkovic, University of Southern
California Information Sciences
Institute; and Bill Newhouse, NIST
Privacy Interests | Khaled El Emam, Privacy
Analytics; and Katrine Evans,
Hayman Lawyers
Real-World Crypto | David Naccache,
École Normale Supérieure
Resilient Security | Richard Kuhn, NIST
Sociotechnical Security and Privacy | Heather
Richter Lipford, University of North Carolina
at Charlotte; and Jessica Staddon, Google

Systems Attacks and Defenses | Davide

Balzarotti, EURECOM; William Enck, North
Carolina State University; Samuel King,
University of California, Davis; and Angelos
Stavrou, George Mason University

COLUMNISTS

Last Word | Elisa Bertino, Purdue University;
Bruce Schneier, Resilient Systems;
Steven M. Bellovin, Columbia University;
and Daniel E. Geer, Jr., In-Q-Tel

CS MAGAZINE OPERATIONS COMMITTEE

Sumi Helal (Chair), Irena Bojanova, Jim X. Chen,
Shu-Ching Chen, Gerardo Con Diaz,
David Alan Grier, Lizy K. John,
Marc Langheinrich, Torsten Möller, David Nicol,
Ipek Ozkaya, George Pallis, VS Subrahmanian

CS PUBLICATIONS BOARD

Fabrizio Lombardi (VP for Publications),
Saurabh Bagchi, Alfredo Benso, Cristiana Bolchini,
Javier Bruguera, Carl K. Chang, Fred Douglass,
Sumi Helal, Shi-Min Hu, Sy-Yen Kuo,
Avi Mendelson, Stefano Zanero, Daniel Zeng

IEEE SECURITY & PRIVACY STAFF

Managing Editor | Jessica Welsh, j.welsh@ieee.org
Cover Design | Barry Downard
Peer Review Administrator | security@computer.org
Publications Portfolio Manager | Kimberly Sperka
Publisher | Robin Baldwin
Senior Advertising Coordinator | Debbie Sims
IEEE Computer Society Executive Director |
Melissa Russell

IEEE PUBLICATIONS OPERATIONS

Senior Director, Publishing Operations |
Dawn M. Melley
Director, Editorial Services | Kevin Lisankie
Director, Production Services | Peter M. Tuohy
**Associate Director, Information Conversion
and Editorial Support** | Neelam Khinvasara
Senior Managing Editor | Geraldine Krolin-Taylor
Senior Art Director | Janet Dudar

EDITORIAL OFFICE

IEEE Security & Privacy
 c/o IEEE Computer Society Publications Office
 10662 Los Vaqueros Circle, Los Alamitos, CA 90720 USA
 Phone | +1 714 821-8380; Fax | +1 714 821-4010

PUBLISHING COSPONSORS



TECHNICAL COSPONSORS



Editorial | Unless otherwise stated, bylined articles,
as well as product and service descriptions, reflect the
author's or firm's opinion. Inclusion in *IEEE Security &
Privacy* does not necessarily constitute endorsement by
the IEEE or the IEEE Computer Society. All submissions
are subject to editing for style, clarity, and length.

Submissions | We welcome submissions about
security and privacy topics. Please see our statement on
publications of interest (<https://publications.computer.org/security-and-privacy/what-we-publish/>) or log onto
IEEE Security & Privacy's author center at ScholarOne
(<https://mc.manuscriptcentral.com/cs-ieee>).

Reuse Rights and Reprint Permissions | Educational
or personal use of this material is permitted without fee,
provided such use: 1) is not made for profit; 2) includes
this notice and a full citation to the original work on
the first page of the copy; and 3) does not imply IEEE
endorsement of any third-party products or services.
Authors and their companies are permitted to post
the accepted version of IEEE-copyrighted material on
their own Web servers without permission, provided
that the IEEE copyright notice and a full citation to
the original work appear on the first screen of the
posted copy. An accepted manuscript is a version
that has been revised by the author to incorporate
review suggestions, but not the published version with
copyediting, proofreading, and formatting added by
IEEE. For more information, please go to www.ieee.org/publications_standards/publications/rights/paperversionpolicy.html. Permission to reprint/
republish this material for commercial, advertising, or
promotional purposes or for creating new collective
works for resale or redistribution must be obtained
from IEEE by writing to the IEEE Intellectual
Property Rights Office, 445 Hoes Lane, Piscataway,
NJ, USA 08854-4141 or pubs-permissions@ieee.org. Copyright © 2020 IEEE. All rights reserved.

Abstracting and Library Use | Abstracting is permitted
with credit to the source. Libraries are permitted to
photocopy for private use of patrons, provided the
per-copy fee indicated in the code at the bottom of the
first page is paid through the Copyright Clearance
Center, 222 Rosewood Drive, Danvers, MA 01923.
**IEEE prohibits discrimination, harassment, and
bullying: For more information, visit www.ieee.org/web/aboutus/whatis/policies/p9-26.html.**



David M. Nicol

The Value of Useless Academic Research to the Cyberdefense of Critical Infrastructures

Like a barker in front of a carnival tent, the title was chosen to draw your attention! It is a play on the 1939 essay “The Usefulness of Useless Knowledge,”¹ written by Abraham Flexner, the first director of Princeton’s Institute for Advanced Study. Flexner points out the foundational role that research for knowledge’s sake plays in technology development. Although he stresses the need for research with absolutely no practical objective in mind, my argument is for the value of early-stage research that is relevant to an application domain but useless in the sense of not being close to transitioning to practical use. My emphasis is on research that helps increase the cyberdefense of critical infrastructures, such as electric power, oil and gas, transportation, and critical manufacturing. Although I don’t expect arguments against the existence of this value, I believe that this kind of early-stage research is underappreciated by funders and industry, in part because these stakeholders don’t yet see the role it can play in workforce development and outreach to industry. After fleshing out these points, I’ll offer an idea that tries to address the problem.

Critical infrastructures of industrialized nations are vulnerable to attack on their digitized controls. Cyber-based threats are on the rise, with new threats circumventing existing protection. Furthermore, critical infrastructures are typically owned and operated by private companies, and defense of the critical infrastructures against cyberbased attack rests on these companies. Although the largest companies can allocate people and license software tools to maintain an active cyberdefense, much of the infrastructure is managed by small or medium-sized companies that cannot. This is problematic because infrastructures like the

power grid and manufacturing systems are composed of independently owned subsystems that are coupled. A successful cyberattack against a weakly defended company can be leveraged by an attacker to impact the system as a whole.

Against these threats, what is the value of early-stage research? Both the U.S. Department of Energy (DOE) and the Department of Homeland Security (DHS) invest in research for which there is a clear transition path to practical use and eventual commercial self-sufficiency. However, the expectation of transition exposes the assumption that prior research has already brought the state of knowledge to a point from which refinement, application, and transition are possible. One obvious value of early-stage research is helping to create starting points for later-stage work that transitions.

Perhaps less obvious, another benefit of early-stage research is in the training of students who end up working with cybersecurity in some critical infrastructure and training of others who pursue research careers in the area. For these purposes, the specific cybersecurity research problem a student pursues doesn’t matter much, so long as the research problem is relevant to and informed by the operation of a critical infrastructure. Hires are made based on a student’s potential; the student’s research is preparation to work at a certain level of sophistication. Although (of course) student training occurs with research poised for transition, support for early-stage research as well increases the pool of new workers and, I will argue, increases the number of faculty prepared to assist critical infrastructure industries in their cyberdefense.

So there are at least two ways in which early-stage research can help address the threats. How is that research typically funded? In the

Digital Object Identifier 10.1109/MSEC.2019.2951835
Date of current version: 23 January 2020

United States, the National Science Foundation (NSF) plays a key and solitary role. The Cyber-Physical Systems (CPS) program in the Division of Computer and Network Systems is a natural place to submit proposals. The NSF puts award information online, and a search of CPS awards since 2013 shows a total of 372 grants, of which 11 have titles related to cybersecurity of critical infrastructures. Those 11 projects received a total of US\$6.6 million.

The other natural NSF program for submissions is Secure and Trustworthy Cyberspace (SaTC) in the same division. A search of SaTC awards since 2012 yields seven out of 862 awards with titles related to critical infrastructure or cyber-physical systems, receiving a total of US\$2.4 million. Of course, both programs have a much wider scope than cybersecurity of critical infrastructure, and these figures say nothing about the topics of proposals not selected for funding. Still, at my university, US\$9 million would fund fewer than 35 students during those seven years, if each were supported throughout a four-year Ph.D. program. A nationwide yield of five Ph.D. students per year is a tiny investment in early-stage research against the backdrop of a critical need.

How could the size of this investment be boosted, and whose responsibility would it be to do so? There are challenges, which I'll explain by looking at how the U.S. government and industry view academic research in this domain. In the realm of cyberresilience for energy systems, the DOE supports "the research, development and demonstration of new tools and technologies."² The expectations of the DHS are similar. The DOE in partnership with the DHS has been investing more than US\$30 million during five years in two academic

consortiums that perform translational research on cyberresilience for energy delivery systems—I'm the principal investigator for one of these consortiums. The DOE also invests significantly on transitional research led by industry and by national labs. Although the DOE and DHS missions address a clear need and their programs can point to a number of impactful outcomes, the emphasis does not easily accommodate any early-stage research needed before the idea of a tool is even possible.

My understanding of industry's view of academic research is the result of a requirement our DOE-funded consortiums have to create a plan for self-sufficiency—after the DOE support ends, industry is to take over funding of the research.

**My understanding of industry's view
of academic research is the result of a
requirement our DOE-funded consortiums
have to create a plan for self-sufficiency.**

Consequently, we have been developing a proposal for an NSF Industry University Cooperative Research Center (IUCRC.)

The academic research performed by an IUCRC is selected and paid for by industrial members, and the NSF contributes funding for administration of the center. The model has worked well in research areas where a number of industrial competitors agree to jointly support the development of open precompetitive research. Obviously, to be successful, an IUCRC has to develop a value proposition that resonates with potential members. Toward this end, the NSF runs IUCRC proposal bootcamps based on the NSF's Innovation Core (I-Corps) training program. One of the key I-Corps ideas is to formulate hypotheses about the

IUCRC's value proposition, then test and refine those hypotheses through structured interviews with many potential members.

In our bootcamp, we conducted nearly 50 interviews. Some of those interviewed were from utilities that deliver electric power and/or natural gas, some represented groups of such utilities, some were from manufacturers of devices used in energy systems, some were cybersecurity service providers, and some were consultants. What we learned was consistent with what we'd heard from industry people throughout the life of the DOE project. More than 90% of those interviewed said their company's primary value from engaging with academia is workforce development, writ large. The process of meet-

ing students, recruiting interns, and eventually hiring new employees was identified as a strong value proposition, across all customer groups.

Development of existing employees by attendance at center-organized meetings was also widely valued, particularly to the utilities and consultants. At these events, people from both academia and industry can share their knowledge about emerging threats, active research, emerging technologies, and applicable software tools; we heard that industry attendees like to become more knowledgeable and return home to do their own jobs better. Responders also saw value in meetings where utilities, manufacturers, government agencies, and regulators can come together on neutral ground for open and frank discussions. Only fourth down the list of rank-ordered value propositions did we find access to software that results from center research.

One needs to interpret these results carefully. It is safe to say that industry values what academia can provide in terms of a hiring pool and



Executive Committee (ExCom) Members: Jeffrey Voas, President; Dennis Hoffman, Sr. Past President; Christian Hansen, Jr. Past President; Pierre Dersin, VP Technical Activities; Pradeep Lall, VP Publications; Carole Graas, VP Meetings and Conferences; Joe Childs, VP Membership; Alfred Stevens, Secretary; Bob Loomis, Treasurer

Administrative Committee (AdCom) Members:

Joseph A. Childs, Pierre Dersin, Lance Fiondella, Carole Graas, Samuel J. Keene, W. Eric Wong, Scott Abrams, Evelyn H. Hirt, Charles H. Recchia, Jason W. Rupe, Alfred M. Stevens, Jeffrey Voas, Marsha Abramo, Loretta Arellano, Lon Chase, Pradeep Lall, Zhaojun (Steven) Li, Shihpyng Shieh

<http://rs.ieee.org>

The IEEE Reliability Society (RS) is a technical society within the IEEE, which is the world's leading professional association for the advancement of technology. The RS is engaged in the engineering disciplines of hardware, software, and human factors. Its focus on the broad aspects of reliability allows the RS to be seen as the IEEE Specialty Engineering organization. The IEEE Reliability Society is concerned with attaining and sustaining these design attributes throughout the total life cycle. **The Reliability Society has the management, resources, and administrative and technical structures to develop and to provide technical information via publications, training, conferences, and technical library (IEEE Xplore) data to its members and the Specialty Engineering community. The IEEE Reliability Society has 28 chapters and members in 60 countries worldwide.**

The Reliability Society is the IEEE professional society for Reliability Engineering, along with other Specialty Engineering disciplines. These disciplines are design engineering fields that apply scientific knowledge so that their specific attributes are designed into the system / product / device / process to assure that it will perform its intended function for the required duration within a given environment, including the ability to test and support it throughout its total life cycle. This is accomplished concurrently with other design disciplines by contributing to the planning and selection of the system architecture, design implementation, materials, processes, and components; followed by verifying the selections made by thorough analysis and test and then sustainment.

Visit the IEEE Reliability Society website as it is the gateway to the many resources that the RS makes available to its members and others interested in the broad aspects of Reliability and Specialty Engineering.



what academia can teach it. The comparatively low score on research products must be viewed in the context of the question, “what is the value to you of directly interacting with an academic center?” and not “what is the value to you of commercial products whose provenance includes university research?” In particular, the results are not a refutation of the DOE/DHS’s investment in academic research that transitions. The results do imply, though, that this particular industry would rather spend its own money on academically provided education than on academically provided as-yet-to-be-transitioned research results. On the face of it, many members of this industry will need some convincing to invest their own resources in academic research within an IUCRC framework.

I’m emphasizing early-stage research because it’s what academics do best, and I think they have an underutilized role in the cyberdefense of critical infrastructures. The intellectual challenges tend to be of most interest to academics because there is a greater emphasis on ideas and less on implementation. Furthermore, academic advancement is in part a function of publications. The leading conferences and journals for cybersecurity research strongly favor early-stage ideas. Although development is key to transitional research, it takes more time and money to get publishable results than does early-stage work. Students need to publish to graduate and get jobs, and faculty need to publish to get tenure and, later, promotions. Early-stage research is a more efficient means toward publication.

To review the situation, early-stage research is needed to prime the pump for transitional research; however, the stakeholders responsible for critical infrastructure aren’t investing significantly in it at universities. In the specific area of cybersecurity for critical infrastructure, the NSF will fund early-stage research and the DOE/DHS will fund transitional research,

but the funding of early-stage research has been very small. This particular industry is interested in hiring students and in being educated by academia but ranks those interests higher than funding research itself. Finally, from the academic point of view, early-stage research is the sweet spot for its participation in addressing critical infrastructure vulnerabilities. That said, to choose relevant research problems in a particular application domain, the researchers have to understand the special characteristics of that domain, e.g., limitations on processing power and memory, the need for provably bounded end-to-end communication delays, and the characteristics of specialized devices that appear in the domain but not elsewhere. To be relevant, the researchers have to invest in learning about cyberrequirements of the domain, and research funding enables that learning.

There is, I think, a way forward, if government funding agencies were to see the value of using academia to help industry do a better job of protecting critical infrastructures. I can imagine a program by the NSF, DOE, or DHS that creates academic centers for specific domains, e.g., one on energy delivery systems, where the emphasis is on educating industry on best practices, keeping it informed of commercially available state-of-the-art security controls, and on soon-to-emerge technology to improve cybersecurity. Such a center might include training and workforce development courses, faculty/student visitations to industrial sites, internships, information webinars, white papers, meetings focused on addressing critical emerging issues, and multi-stakeholder semiannual meetings. But if there is value in having cybersecurity researchers participating—and I think this is essential—to draw them in and increase the number of students knowledgeable enough to join the industry, the center needs

also to fund research projects, many of them early stage. The researchers need the exposure to industry to understand the specialized requirements of computing and communication in their domain and so identify research problems that are relevant. They need the feedback from industry on whether they understand the issues correctly. Industry needs the researchers for their knowledge, perspectives, and access to students.

Centers like this could simultaneously address multiple needs:

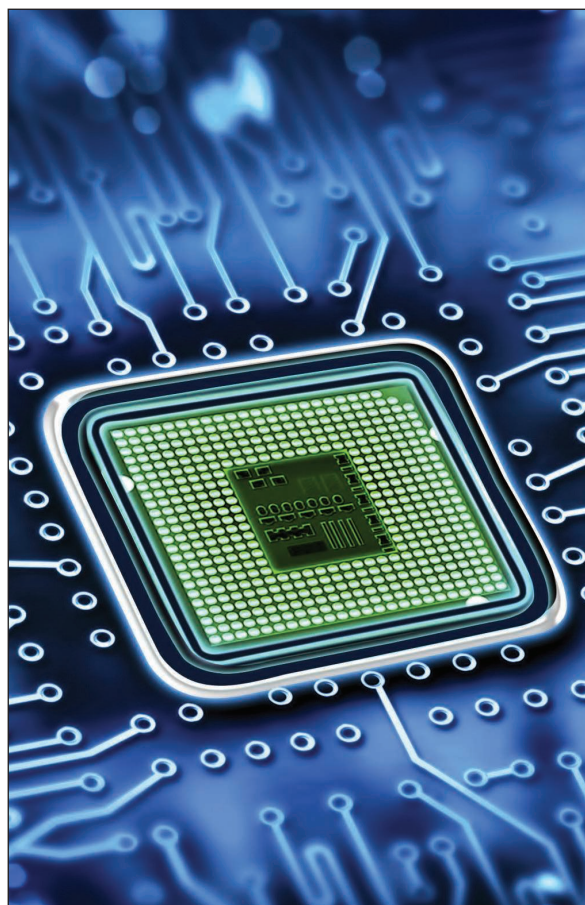
- develop the domain-relevant early-stage results needed to launch research that transitions to practice
- increase the pool of students trained in cybersecurity within a critical infrastructure, for workforce development in both industry and academia
- provide cybersecurity training and advice to the small and medium-sized companies that cannot afford it otherwise
- keep larger companies apprised of the dynamically changing threat landscape and informed about leading-edge means of mitigating those threats.

For this idea to become reality, everyone has to bend a little. The government view of what it will fund with respect to industry/academia interaction needs to broaden. Industry needs to see that early-stage research can be leveraged to aid its workforce development needs. Academics need to accept the responsibility for outreach to industry as a condition for accepting research funding, embrace

the need to understand the specialized requirements of the industry, and prioritize research areas to ones that are relevant to the industry. My experience with members of all of these groups is that many see the seriousness of critical infrastructure vulnerabilities and want to help, and I believe this willingness can lead to new ways of addressing the issue. ■

References

1. A. Flexner, "The usefulness of useless knowledge," in *The Usefulness of Useless Knowledge*. Princeton, NJ: Princeton Univ. Press, 2017, pp. 49–88.
2. Office of Cybersecurity, Energy Security, and Emergency Response, "Cybersecurity for critical energy infrastructure," 2019. [Online]. Available: <https://www.energy.gov/ceser/activities/cybersecurity-critical-energy-infrastructure>



IEEE TRANSACTIONS ON

COMPUTERS

Call for Papers: *IEEE Transactions on Computers*

Publish your work in the IEEE Computer Society's flagship journal, *IEEE Transactions on Computers*. The journal seeks papers on everything from computer architecture and software systems to machine learning and quantum computing.

Learn about calls for papers
and submission details at
www.computer.org/tc.



Digital Object Identifier 10.1109/MSEC.2019.2962590



The Future of Cybersecurity Policy

Kate Charlet | Carnegie Endowment for International Peace

Heather King | Cyber Threat Alliance

The five feature articles in this special issue of *IEEE Security & Privacy* focus on the future of cybersecurity policy. Dynamic trends are affecting the landscape of cybersecurity policy making. Whatever the driver of these changes—new technologies, new threat types, or innovative approaches in government, industry, or society—there is a need to anticipate and prepare for them and clarify the challenges, opportunities, and interdependencies we face. The articles focus on updating the way we think about attribution, assessing the future of cyberinsurance, harmonizing governance in a data-driven society, anticipating future trends in the information environment, and learning about the European approach to cybersecurity governance.

Exploring How Technology Will Change Cybersecurity

This special issue of *IEEE Security & Privacy* explores future trends impacting cybersecurity policy. Why focus on policy? The goal of *IEEE Security & Privacy* is to understand how systems, data, and people are protected in a world of rapid technological evolution. Achieving this requires understanding the ways in which smart, technically informed policies can enable stronger defenses against the digital threats of today and tomorrow.

As policy makers ourselves, we know that cybersecurity policy is more successful when it is proactive, not

reactive, and when it accounts for rapid technological change. Certain experiences—the Iranian denial-of-service attacks against the U.S. financial industry and the attacks on the Ukrainian electrical grid, to name a couple—have shaped policy for years to come. There is much to learn from such events and the international community's response to them, but we must also guard against a failure of creativity to anticipate how those threats will evolve and how policies need to evolve with them.

There are many factors that contribute to making cybersecurity a difficult challenge. For instance, cybersecurity is not just a technical issue but is also a psychological, business operations, economic, and human behavioral problem. Cyberspace also has different rules than what we've been used to in the physical world. For instance, the temporal speed at which things move in cyberspace is not comparable to most physical world analogies. Furthermore, we have not had time or experience to develop the body of law, policy, and practice needed to operate effectively in cyberspace. We need to keep such factors as these in mind as we consider how to tackle the challenge of cybersecurity policy making.

Moreover, there are many drivers of policy that influence cybersecurity and serve as a forcing function. Whatever the driver—new technologies, threat types, or innovative approaches in government, industry, or society—there is a need to anticipate and prepare for them. Effective cybersecurity also requires the full array of measures already established in the physical world. For example, we need to move into a realm of better

situational awareness like what exists for weather prediction, increased preparation as we have for natural disasters, stronger frameworks to inform attribution and decision making, and greater consequence management. If we do not begin to effectively consider the full measures we can take to address the cybersecurity challenges we face, the benefits we gain from a digital age could wither.

Our special issue's call for papers solicited articles in a broad range of topics—everything from the evolution of data-sharing partnerships to the impact of quantum computing on cybersecurity policy. These broad topics are tied together by the need to anticipate how technology change will drive an ever-evolving need for smart policies and good governance. We called, for example, for other topics as well, including the following:

- data security for human genetic information
- case studies or proposals for innovative ways to advance public–private partnerships for cybersecurity
- how artificial intelligence-driven cybertools, both offensive and defensive, could change the landscape for cyberconflict
- implications of emerging cyberthreats to critical infrastructure, such as the risks posed to census databases or space assets
- new approaches to establishing international norms of responsible behavior in cyberspace or reducing the risk of cyberconflict between major nation states.

From the submissions received, we selected five articles that highlight key policy issues with which the cyber- and information-security communities will need to grapple in coming years.

Updating the Way We Think About Attribution

Cybersecurity firms, governments, and even technology companies are increasingly willing and able to attribute the source of cyberattacks. But stakeholders often talk past one another, applying different mental models of what it means to attribute a cyberattack. Andrew Grotto proposes a framework to address this concern. He suggests that we distinguish between two categories of attribution: analytic and strategic attribution. Analytic attribution is largely based on forensic and technical data related to the identity of a malicious cyberactor. Strategic attribution, on the other hand, relates to the actions taken in light of analytic attribution, such as remaining silent, disclosing the information to select third parties, or publicly naming and shaming. Grotto argues that these categories can provide a common reference point for scholarly and policy debate about the means and ends of attribution, appropriate evidentiary

standards for different types of attribution claims, and the advisability of various proposals for encouraging more and better attribution.

Assessing the Future of Cyberinsurance

Does insurance have a future in governing cybersecurity? This is the question that Daniel W. Woods and Tyler Moore examine. The authors consider how insurance programs promote security, and what forces prevent them from being more effective than they could be. Can insurance improve cyberhygiene? How will cyberinsurance deal with major catastrophe? Will cyberinsurance even exist a decade from now? The authors outline possible futures for cyberinsurance as a method of managing risk, including the different roles that organizations, insurers, and governments can play across the broader ecosystem. Woods and Moore ultimately assess that current forms of cyberinsurance offer a relatively weak tool, but they outline some key steps to elevate its value.

Harmonizing Governance in a Data-Driven Society

Developing a data-driven society requires a common approach to achieve a harmonized vision of cybersecurity. This is the argument that José L. Hernández-Ramos, Dimitris Geneiatakis, Ioannis Kounelis, Gary Steri, and Igor Nai Fovino make in describing key cybersecurity policies and joint initiatives supported by the European Union (EU). The article examines networked models of governance to identify what works best to promote cybersecurity research and development. Ultimately, the authors argue that, in our data-driven society, there is a clear need for stakeholders, including industry, standards-making bodies, and users, to cooperate with one another to develop future technologies using a common legal umbrella representing current and future cybersecurity and data-protection policies.

Anticipating Future Trends in the Information Environment

Michael Klipstein, Austin Minter, and Jeremiah Pittman focus on the future of the information space 10 years from now to understand how the environment will interact with society. In today's digital world, they argue, three distinct domains of warfare (cyberwarfare, electronic warfare, and information operations) have now converged in new ways. Misinformation has become a powerful tool for influencing viewpoints and sowing discord and friction among members of society. Identified are four critical trends to follow as we deal with the coming challenge, including the global decline in trust in the United States, the rise of China in the areas of the Internet of Things and

computing, the societal divisions forming nontraditional news, and an increase in combating adversaries in the information space as a method of avoiding kinetic conflict.

Learning About the European Approach to Cybersecurity Governance

Pierantonio Sterlini, Fabio Massacci, Natalia Kadenko, Tobias Fiebig, and Michel van Eeten examine the broader governance challenges facing cybersecurity policies, such as the EU's proposal of the Network of Competence Centers to manage all European cybersecurity funding. In this article, they outline possible approaches for cybersecurity governance and compare them to this proposal, using input from key stakeholders via surveys and interviews within the EU. The authors make several conclusions, among them the flexibility of a network model, which seems to be most

appropriate to address cybersecurity challenges and to provide flexibility to adapt to different economic and policy conditions.

We hope this special issue provides a helpful road map for the issues we need to be prepared to face in our near future. ■

Acknowledgment

The guest editors provided their editorial recommendations during the summer of 2019.

Kate Charlet was with Carnegie Endowment for International Peace. Contact her at rosnos@ceip.org.

Heather King is with Cyber Threat Alliance. Contact her at heatherking@cyberthreatalliance.org.



Top Technology Trends for 2020 Featured in *Computer*

IEEE Computer Society tech experts unveil their annual predictions for the future of tech. Six of the top 12 technology predictions have been developed into peer-reviewed articles published in *Computer* magazine's December 2019 issue, covering topics such as cognitive robotics, practical drone delivery, and digital twins.

ACCESS SIX FREE ARTICLES!

www.computer.org/2020-top-technology-predictions



IEEE
COMPUTER
SOCIETY



Digital Object Identifier 10.1109/MSEC.2019.2962588



ComputingEdge

Your one-stop resource for industry hot topics, technical overviews, and in-depth articles.

Cutting-edge articles from the IEEE Computer Society's portfolio of 12 magazines.

Unique original content by computing thought leaders, innovators, and experts.

Keeps you up to date on what you need to know across the technology spectrum.

Subscribe for free
www.computer.org/computingedge





Deconstructing Cyber Attribution: A Proposed Framework and Lexicon

Andrew Grotto | Stanford University

I propose a new conceptualization of cyber attribution to provide a reference point for debate about the means and ends of attribution, appropriate evidentiary standards for attribution claim types, and the advisability of various proposals for encouraging more and better attribution.

When an actor makes a claim about cyber attribution, it is typically a purposeful act conducted with one or more goals in mind: aiding defensive efforts, supporting initiatives to punish or deter perpetrators, contributing to scholarly understanding of threats, attracting acclaim for infosec research adeptness, and so on. Cyber attribution claims are instrumental in nature. The optimal form and content of an attribution claim, therefore, depend on the intended goals served by the claim.

Amid calls for more cyber attribution, criticisms that governments do not do it enough, various proposals for new organizations to step in to fill the perceived gap, and a recent effort by the U.S. intelligence community to clarify its methodology for attribution, I attempt to bring greater coherence and clarity to scholarly and policy debate about attribution by identifying and defining different iterations of the concept. Though the various uses and conceptions of cyber attribution arguably have more in common with each other than not, they also reflect subtle but important biases about the means and ends of attribution as well as different evidentiary standards, target audiences, and modes of communication for attribution claims.

In this article, I propose two overarching categories of attribution: analytic and strategic. I describe analytic attribution as primarily an analytic judgment pertaining to what an analyst knows (or thinks he or she knows) about the identity of a malicious cyberactor. Strategic attribution, in contrast, pertains to what the analyst does with the analytic attribution, which includes keeping the judgment private, disclosing it to selected third parties, or making it public. These three modes of strategic attribution are referred to as *private*, *selective*, and *public*. Judgments about analytic attribution will often rely on forensic and other technical artifacts, along with all-source intelligence about threat actors and their intentions, tools, techniques, and procedures; it amounts to a falsifiable claim about who perpetrated an attack. Decisions about strategic attribution are guided by political and economic factors pertaining to which mode of strategic attribution most advances the decision maker's interests. These categories are applicable to attribution decisions by both state and nonstate actors.

My contention and objective are that parsing the concept of attribution into these broad categories can provide a common reference point for

1. scholarly and policy debate about the means and ends of cyber attribution

2. appropriate evidence standards for different types of attribution claims
3. the advisability of various proposals for encouraging more and better attribution.

I elaborate on these three categories by using a series of iterative, fictional examples involving attribution decisions by two nation-states, Americious and Ukaria; a company that suffers a breach, Acme Widget Corporation; and a cybersecurity services provider, CyberDefenders. These fictional examples are composite sketches inspired by or based on real-world incidents and activities.

Fictional examples are used rather than nonfictional ones for two reasons: 1) to encourage the reader to accept the presentation of the examples as given and focus critical energies on the discussion that follows them and 2) for present purposes, a trio of compact fictional examples designed to draw out key dimensions of attribution decisions is a more efficient use of limited space. Even so, these examples highlight some (but not all) of the many factors that shape analytic and strategic attribution decisions. I end by drawing out several additional conclusions.

Cyber Attribution in Scholarly and Policy Debate

At its most basic, attribution is the act of “determining the identity or location of an attacker or an attacker’s intermediary.”¹ This simple definition is appealing, but it does not capture the normative and communicative connotations of the term that create implied expectations about its meaning in debates on cyber policy. In everyday (noncyber) usage, to *attribute* is oftentimes to assign credit or blame, as in a work or quip attributed to this or that author or a malign act carried out by a thus-guilty party. The word is laden with judgment, and, especially when it involves assigning blame, it begs the question of what consequences ought to follow. As Rid and Buchanan assert, “[d]oing attribution well is at the core of virtually all forms of coercion and deterrence, international and domestic.”² The term also has a communicative aspect: to *attribute* is to name, and a name is generally not something kept strictly private—otherwise, what is the point of naming?

From this perspective, the varying usages and treatments of the word in infosec and cyber-policy debates are not surprising.

Consider four distinct but important communities involved in making cyber-attribution claims:

1. private infosec researchers
2. private infosec practitioners
3. intelligence agencies
4. law-enforcement agencies.

For private infosec researchers and practitioners, attribution is often principally concerned with uncovering and identifying patterns in the tactics, techniques, and procedures used by malicious actors to aid infosec and perhaps demonstrate technical prowess for marketing purposes, bragging rights, or both.³

The grist for this research typically includes a combination of technical data acquired via analysis of the digital threat landscape and forensic investigation of cyberincidents, along with nontechnical data, such as victim identity and geopolitical circumstances.

Intelligence agencies also draw on technical and other data for their attribution judgments, including classified raw and analytic intelligence reporting about threat actor capabilities and intentions, to develop attribution-related products for their customers in policy and operational roles.⁴

Law-enforcement agencies utilize these and other data to investigate suspected cybercriminals, indict them before a grand jury, and prosecute them in a criminal proceeding involving judge and possibly jury.⁵

All four actors draw on technical and other data to arrive at judgments about the perpetrator of an incident. Yet the evidentiary standards, estimative language for presenting attribution claims, target consumers, and ultimate aims of attribution are obviously quite different. These problems have prompted proposals for new institutions to carry out attribution as part of a standardized process.^{6,7} Attribution claims, moreover, can take varying levels of abstraction about the malicious actor’s identity and can range from the relatively specific (“Unit 61398 of the 3PLA” or “Evgeniy Bogachev”) to the relatively generic (“three computers in China”). The appropriate level of abstraction for an attribution claim depends on the goals served by making the attribution.⁸ If the goal is a criminal conviction, for example, attribution at the level of “three computers in China” may not suffice. Additionally, some infosec practitioners dismiss the value of communicating their attribution judgments to customers.⁹

In policy debates, cyber attribution is often shorthand for the act of publicly accusing an actor as the perpetrator of malicious cyberactivity. In this context, attribution is a strategic intervention with geopolitically significant implications.^{2,10} This view of attribution emphasizes states as the author and object of attribution: “attribution is what states make of it,” according to Rid and Buchanan.² Those authors go on to emphasize the importance of public attribution by states, which, in their view, means “improved credibility, improved attribution, and improved defences.” This is certainly true in some cases, as they persuasively argue, but not in all cases. The concept of strategic attribution, with its different subtypes—private, selective, and public—provides a framework for why this is so.

An orientation toward states and statecraft is also understandably the focus of attribution-related scholarship by

international relations researchers,^{2,11} especially an intriguing line of research on the dynamics of states signaling to each other and other constituencies in secret.^{12,13} This research suggests that important, consequential signaling among state and nonstate actors can happen selectively, away from full public view. An actor's ability to punish, compel, or deter an adversary does not necessarily require loud, public actions. What matters instead is whether a signal is intelligible and credible to the recipients. This important point, which I draw out in the discussion to follow, is seldom acknowledged in cybersecurity scholarship.

Deconstructing (and Reconstructing) Cyber Attribution

In this section, five concepts are given with the goal of defining key dimensions of attribution: analytic attribution and strategic attribution, along with three types of strategic attribution: private, selective, and public attribution. As can be seen, there is some fluidity between the two categories, not least because strategic attribution, by definition, requires analytic attribution. Moreover, the quality of analytic attribution may benefit from strategic attribution, when strategic attribution results in analysts sharing and acquiring knowledge that enriches the accuracy of analytic attribution. Additionally, the actors and organizations involved in decisions about analytic and strategic attribution will often overlap, though in many contexts the management and methodological models for analytic and strategic attribution will be quite distinct.

Analytic Attribution: Who Is the Malefactor?

Analytic attribution is an entity's judgment about the identity of the perpetrators of a malicious cyberincident, whether the entity was the victim of the incident or not. It is primarily an analytic judgment, formed on the basis of information about the incident and its suspected perpetrators and enablers and any other relevant data. Such information may include public and nonpublic information from any source.

Consider the following examples of analytic attribution:

- *Example A₁*: Americious is a rule-of-law-oriented Western democracy in the Anglo-American tradition. Ukaria, a fledgling democracy allied with Americious, has an unresolved border dispute with Rosaria, a longtime adversary of Americious. The lead intelligence service in Americious disseminates a classified intelligence assessment to Americious policy makers that the actors behind a cyberattack against Ukaria's electric grid are likely affiliated with a Rosaria military intelligence unit. The assessment is based on foreign intelligence collection and forensic data brought back to Americious by a "fly-in team" of Americious government experts invited by Ukaria to support its forensic analysis of the attack.

The Americious government has analytically attributed the attack to Rosaria.

- *Example B₁*: The Americious company Acme Widget Corporation, a publicly traded company, suffers a cyber-enabled theft of its trade secrets. Acme's executive team assesses that malicious cyberactors located in the territory of Chicoria and acting on behalf of National Champion Company (NCC), a state-owned enterprise in Chicoria, were likely behind the incident. The assessment is based on forensic data from the company's chief information security officer (CISO) and outside cybersecurity vendor and, critically, the timing of the incident, which coincided with its negotiations with NCC over a joint venture in Chicoria. Acme has analytically attributed the attack to NCC.
- *Example C₁*: CyberDefenders Corporation, a leading provider of managed security services and incident response services, assesses that a campaign of malicious cyberactivity against global shipping interests, some of whom are its clients, is likely the work of a global organized crime syndicate called #APT. CyberDefenders's assessment is based primarily on consensual forensic analysis of its customers' systems, with supplemental data drawn from its proprietary global sensor network (much of which is composed of consensual instrumentation of its customers' systems) and other sources of information. In addition, by exploiting weaknesses in #APT tradecraft, CyberDefenders is able to link several suspected #APT operators to their true names with high confidence. CyberDefenders has analytically attributed the attack to #APT and several specific #APT operators.

In these examples, each protagonist has formulated a judgment about analytic attribution. For now, at least, all have kept their analytic attributions private. They have also drawn on different data sources to arrive at their analytic attributions. In Example A₁, for instance, the Americious intelligence service drew upon intelligence sources and methods, along with a trust relationship with Ukaria that permitted its experts to gain some firsthand insights into the attack. Acme's executive team in Example B₁ based its analytic judgment on information from the company's systems and their business instincts, while CyberDefenders in Example C₁ founded its assessment in substantial part on technical information from its customers' systems.

In these examples, the protagonists' confidence level in their analytic judgments may be expressed in different ways. Assuming the Americious intelligence service's analytic capabilities are professional, its analytic attribution of the attack against Ukaria to Rosaria would include express language about its confidence level—high, medium, or low. This confidence level, in turn, would be a function of how specific and direct the intelligence is. To the extent that intelligence is valuable and potentially fragile—for example,

midpoint and endpoint signals-intelligence collection of perpetrator conversations and planning materials, respectively—the originators of the intelligence will have strong incentives to compartmentalize and limit the distribution of the intelligence to only those who need to know.

Analytic attribution can provoke or inform action; it is not necessarily consequence free. Indeed, an actor's willingness to take potentially costly actions based on an analytic attribution speaks volumes about the actor's confidence in the accuracy of the attribution. In Example A₁, Americious's analytic attribution could lead it to take a variety of actions, such as prioritizing intelligence collection against Rosaria's cyberoperators, pursuing covert action against Rosaria's cyberinfrastructure, forging closer security, diplomatic, and intelligence ties with Ukaria, or building diplomatic support for norms of behavior in cyberspace during peacetime that proscribe the actions Rosaria took in Ukaria. None of these actions necessarily requires naming Rosaria's attack on Ukaria as the inspiration for them. In Example B₁, even if Acme's evidence were limited to the executives' hunches, the company may still decide to never do business with NCC again or even abandon the Chicorian market altogether. And in Example C₁, CyberDefenders's analytic attribution could lead the company to invest more resources in monitoring the threat posed by #APT.

By the same token, some defensive actions do not require analytic attribution. For example, a defender does not necessarily need to know the identity of an adversary to implement known technical defensive measures. As one leading cybersecurity company asserts, "there is little to no value in true attribution (state, agency, or operator identity) to defense teams."⁹ On the other hand, it is not categorically true that an analytic attribution is never valuable for defensive purposes. For instance, learning the identity of an adversary can help defenders set mitigation priorities and more effectively assess risk. As can be seen later in this article, in Example A₂, Americious hopes to send this signal to grid operators by selectively attributing the attack in Ukaria to Rosaria.

Another example helps illustrate the point. Let us say that Rosaria has a propensity for launching denial-of-service attacks against Americious banks whenever news breaks that the Americious government is considering economic sanctions against Rosaria. Knowing that Rosaria does this should alert defenders of the need to monitor the news for stories on new sanctions against Rosaria so they can be ready to surge defensive resources as necessary (or better yet, work with the Americious government on a mechanism for appropriate rapid notice).

Analytic attribution is not limited to forensic or other objective, measurable technical data. The executive team's hunches in Example B₁ formed part of the basis for Acme's analytic attribution of NCC. The executives would presumably prefer to ground their analytic attribution on better

information than what they have, but decision makers in the real world often have to make decisions based on imperfect or incomplete information. The Acme executive team's hunch is probably not enough to persuade many third parties of NCC's culpability, but as I will suggest, the persuasiveness of the evidence to third parties may not be a factor in terms of how a victim or other aggrieved actor responds to an incident. For some responses, all that may matter is whether the decision maker is sufficiently persuaded.

Especially for governments, intelligence collection may yield essential data pertaining to analytic attribution. Imagine if Rosaria's operation against Ukaria was exquisite from a technical perspective and left no traces of tradecraft or tools in the aftermath of the attack. Ukaria knows it experienced a power outage and may have suspicions about who caused it and how, but, from an evidentiary standpoint, the cause might as well have been swamp gas. Under the circumstances, technical forensic analysis would yield little of probative value. But if Americious had penetrated Rosaria's military intelligence unit and had a vetted, reliable asset there, and/or had corroborating signals intelligence, then the lack of technical forensic evidence pointing to Rosaria's role in the attack may be irrelevant as far as analytic attribution is concerned. The attack itself may have been exquisite, but it doesn't necessarily follow that high-confidence analytic attribution is impossible.

In any event, exquisite attacks along these lines are uncommon: hackers make mistakes or leave technical "dots" ready to be connected with other dots. Analytic attributions will often draw, at least in part, on forensic analysis of a victim's machines and/or its infrastructure that came into contact with them. In Example C₁, for instance, CyberDefenders's analytic attribution is based in part on data collected from its enterprise customers on a consensual, contractual basis. One important practical implication of this mode of sourcing is that the corporation's customers have a decisive say in the types of data and systems it can access—and what it can do with them.

Similarly, in Example A₁, the trust relationship between Americious and Ukaria paved the way for the Americious experts to conduct their forensic analysis. If the technical forensic analysis yielded decisive clues about Rosaria's role in the attack, then Ukaria's consent and cooperation played a major role in the ability of Americious to arrive at its analytic attribution. Depending on the nature or terms of the bilateral relationship, Ukaria may have a valid claim of collegial right to Americious's analysis, including judgments about analytic attribution—and possibly even significant influence over what Americious does with its analytic attribution, including with which other third parties, if any, Americious can share its findings (more on this later).

The confidence that Americious analysts place in their findings is going to be a function of how much they trust the intentions and integrity of Ukaria—and their own

ability to detect any evidence of tampering by Ukaria. If Ukaria is a close ally with deep, enduring political, military, and intelligence ties to Americious and has a reputation for integrity, then the Americious analysts might take it as an article of faith that Ukaria would not tamper with the machines affected by the attack. On the other hand, if Americious had reason to believe that Ukaria might consider tampering with the evidence, the Americious analysts would have to discount the probative value of data pertaining to attribution if they had doubts about their ability to detect tampering.

The example assumes that Ukaria is able to make commitments on behalf of its electric grid operators, or at least that the grid operators and their host government have an aligned set of interests in allowing Americious analysts to participate in the investigation. The situation would get vastly more complex if, instead, the grid operators opposed allowing the Americious analysts access and Ukaria had no authority to compel them to do otherwise. A victim's willingness to cooperate with authorities or other third parties is a critical factor in the ability of these third parties to understand what happened and possibly who did it.

Strategic Attribution: Do We Tell? And Whom?

Strategic attribution occurs when an entity decides to disclose its analytic attribution to a third party, based on an assessment that the benefits of disclosure outweigh the costs. Factors bearing on its assessment of benefits and costs may include business, legal, political, evidentiary, and reputational considerations, among others. An entity engages in strategic attribution if and only if it assesses that doing so will serve their interests.

Strategic attribution comes in three forms:

- private attribution, which involves deciding to not disclose an analytic attribution to third parties
- selective attribution, in which an analytic attribution is disclosed to select third parties
- public attribution, where an analytic attribution is made more or less public.

The article focuses here on selective and public attribution, with aspects of private attribution woven in.

Selective Attribution: Psst ... Listen to This!

Consider the following examples of selective attribution:

- *Example A₂*: The Americious government provides classified threat briefings to major Americious grid operators on the tools, techniques, and procedures that the threat actors from Rosaria used to carry out the attack in Ukaria and provides recommendations for how to mitigate the threat. In the classified briefing, the Americious government also describes its classified analytic

attribution of Rosaria as the perpetrator as context to reinforce the severity of the threat and the need for the operators to prioritize these particular mitigations. The briefers also hope that the quality of the briefing, including the decision to share sensitive forensic attribution details, will persuade the operators to reciprocate and engage in information sharing with the Americious government about the threat. The Americious government has selectively attributed the attack to Rosaria, with major Americious grid operators as the recipients of the selective attribution.

- *Example B₂*: Acme Widget Corporation's CISO shares information about the incident, along with the company's analytic attribution of the incident to NCC, with a trusted circle of fellow CISOs at similarly situated companies to aid their defense and reinforce reciprocity norms about sharing threat information within the circle of trust. The CISO shared the information under a Traffic Light Protocol (TLP) Red designation to highlight the sensitivity of the information. The company's general counsel also shares information about the incident with outside counsel to facilitate the understanding of legal risks and options and notifies Americious law enforcement (ALE) of the breach. Acme has selectively attributed the attack to NCC; recipients include the CISO's trusted circle of fellow CISOs and outside counsel. The disclosure to law enforcement is not an example of selective attribution unless Acme shared its analytic attribution as part of the disclosure.
- *Example C₂*: CyberDefenders issues a report on the cyberattack campaign, including its analytic attribution of the campaign to #APT, to its customers, who pay considerable sums of money for the report and sign nondisclosure agreements (NDAs) as a condition of receipt. CyberDefenders has selectively attributed the attack to #APT. CyberDefenders chooses to not identify the true names of the suspected operators in its report, however. This choice is an example of private attribution.

In Example A₂, the Americious briefers shared their analytic attribution with a subset of critical infrastructure owners and operators to protect public safety. Americious made a judgment that these companies had a need to know that warranted exposing intelligence sources and methods to some heightened degree of risk of unauthorized disclosure.

By being so selective in its outreach to the private sector, however, Americious has potentially assumed new risks. What if Rosaria or another malicious actor was able to use substantially similar tradecraft to attack sectors that had not been briefed? Most importantly, this would put the people of Americious at risk of harm. But it could also jeopardize the political fortunes of Americious's leadership, who, in the aftermath of such an attack, would face

the inevitable second-guessing of why they had failed to brief more companies.

What does Ukaria think about Americious's actions in Example A₂, and should Americious care? Ukaria is unlikely to let a foreign government, even a friendly one, examine infrastructure that was targeted by a hostile foreign power without some guarantee that the fruits of the examination would make their way back to Ukaria. One of the issues that Americious and Ukaria (and their respective legal advisors) would want to have worked through in advance is calibrating both sides' expectations about what is and is not shared by way of intelligence associated with the incident. Americious could share its technical findings with Ukaria but leave it up to Ukaria to connect the analytic attribution dots. Or it could go a step further and engage Ukaria in a more robust analytic exchange and dialogue that could include judgments about analytic attribution. Either way, the two parties will want to think this through in advance.

Intelligence is ultimately about informing action, so another issue the two parties will want to think through is arriving at a mutual understanding of what each side will do with what it learns from the other. This is a delicate issue because both sides would understandably resist restrictions on the use of information that could potentially save lives or avert catastrophic economic harm. Ukaria, for example, would almost certainly want to give its own electric grid operators a briefing similar to what Americious provided its grid operators. Americious would be hard pressed to say no, though it would obviously want to work with Ukaria to ensure that risks to intelligence sources and methods were managed appropriately.

Extending Example A₂ further, Americious may want to send deterrence signals to Rosaria. It could do so in a variety of ways, but what is important is that the signals are intelligible and credible to Rosaria's leadership; otherwise, the signal would not have the desired impact. Americious could send a public signal (more on this later), but it could also send a private signal through one or more discreet channels, such as the Americious ambassador to Rosaria delivering a demarche to the Rosaria foreign minister and/or the Americious embassy chief of station communicating with the head of Rosaria's military intelligence. The message might go something like this: "We know you did this, and if we see you preparing to do this against us, we will be forced to respond preemptively at a time and in a manner of our choosing." This would be an example of selective attribution in service of deterrence.

Notice how, in this particular scenario, the evidentiary standard in the underlying analytic attribution is basically irrelevant as far as deterrence goes. Whichever Rosarian official receives the message may well protest the accusation, express outrage, and demand evidence. Americious could refuse to engage, and, as long as Rosaria understood

the message and assessed the threat as credible, the failure to engage should not affect Rosaria's calculus.

In Example B₂, Acme's executives are trying to get their heads around what happened by seeking external advice and assistance, with the CISO also recognizing that peer infosec officers in similar companies might be facing similar risks. Example B₂ also makes reference to the Acme CISO's use of the TLP, which is widely used by infosec practitioners to label threat-related information according to its perceived sensitivity and request that recipients handle the information accordingly. TLP Red is the highest classification under this scheme; it means the material is not for disclosure and restricted only to participants.¹⁴ The kind of exchange described in this example happens all the time in the corporate infosec world, and anecdotal evidence suggests that these exchanges result in stronger defenses. On the other hand, these exchanges often occur without the knowledge or consent of the company's senior executives. These interchanges are informal, rooted in personal bonds of trust, and done in secret.

In this case, the fact that the information is labeled TLP Red means that the individuals with whom the Acme CISO shared the information should not provide it to others within their organizations (including the senior executives) or refer to it in the context of strategic attribution without the consent of the originator, Acme's CISO. It is important to note, however, that the TLP scheme is not binding on participants; putting a TLP classification on a document or asserting it in a conversation does not create any legal rights or duties among the parties to the exchange. Unless recipients also sign NDAs or similar agreements (as CyberDefenders required recipients of its report to do in Example C₂) or a specific law is broken, Acme would have no recourse under the law to sue or press charges against a recipient who violates the terms of TLP Red sharing.

As the example indicates, Acme is in the widget business. Assuming it is a conscientious, well-managed business, the company's management team will work closely with its chief information officer, CISO, and legal counsel to get an accurate handle on what information within the company was exposed in the breach and what courses it must then pursue. Was it just information relating to the negotiations with NCC, or was other information exposed, such as trade secrets or customer data? To the extent customer data were at all at exposed, does the company need to notify its customers under the law or for business reputation reasons? And, if a notification is in order, does it disclose its analytic attribution, i.e., engage in selective attribution? In addition, as a publicly traded company, are there any market disclosures it needs to make under Americious securities law? Is the company's analytic attribution of the incident to NCC materially relevant to the market implications of the breach? It could be, to the extent that the incident affects the company's plans

about the Chicorian market and what those plans mean for the company's revenues and profitability. If so, the company may have obligations under its securities regulator to disclose its attribution.

Example B_2 also indicates that Acme notified ALE of the breach (perhaps it has a cyberinsurance policy that requires it to notify law enforcement as a condition of coverage). Let us stipulate for a moment that Acme has decided for various business reasons to not engage in any further strategic attribution. If ALE took an interest in the case and opened a criminal investigation, it would probably seek Acme's consent to conduct a forensic analysis of the company's systems to search for evidence. Acme's executive team would now face a conundrum: in light of its business decision to not engage in any strategic attribution, does it permit the law-enforcing body to conduct the analysis or decline their request? After all, the ultimate goal of an ALE criminal investigation is to convict criminals—a very public act of strategic attribution. If Acme's executives are firmly against any further strategic attribution of the breach to NCC, then they might well conclude that cooperating with the agency is not in the company's best business interests and decline ALE's request.

Why might CyberDefenders engage in selective attribution? It could be for the same reason that Americious did—to provide context for defenders to understand and assess the threat. It is also potentially good marketing, as a show of analytic prowess—assuming, of course, that the analysis holds up. On the other hand, CyberDefenders has decided that disclosing the identities of the suspected perpetrators to its customers does not advance its interests. NDAs cannot prevent recipients from making unauthorized disclosures; all they can do is create disincentives. CyberDefenders may have assessed that, notwithstanding the NDAs it has with its customers, including perpetrator identities in its report would expose its sources and methods to undue risk, or that naming names in a report could expose CyberDefenders to especially bitter reprisal from #APT, should the report ever be made public.

Public Attribution: Hello, World!

Public attribution is another form of strategic attribution and occurs when an entity calculates that the mode of disclosure of its private attribution to third parties that best serves its interests is public disclosure. Put differently, public attribution reflects a judgment by an entity that the benefits of public disclosure outweigh the balance of benefits and costs associated with selective or private attribution.

Consider the following examples of public attribution:

- *Example A_3 :* The Americious ministers of energy, homeland security, and state issue a joint statement blaming Rosaria for the cyberattack against Ukaria. The ministers and their law-enforcement colleagues publish an alert on

the technical aspects of the threat, with recommended mitigations. The Ministry of Justice indicts three operators in the Rosarian military intelligence service for criminal prosecution, and the Ministries of Commerce and Treasury impose economic sanctions on the operators' entire military unit and affiliated business interests. The Americious and Ukarian ambassadors to the United Nations request an emergency meeting of the Security Council to consider an appropriate response to Rosaria's alleged aggression. The Americious government has publicly attributed the attack to Rosaria through several channels.

- *Example B_3 :* The Acme Widget Company files a lawsuit in Americious court against NCC, alleging theft of trade secrets and other damages in its pleading. Acme has publicly attributed the attack to NCC.
- *Example C_3 :* CyberDefenders releases a public report on its assessment of the incident, in which it names #APT as the perpetrator. The report is careful to avoid any use or reference to information protected by CyberDefenders's contracts with its customers. CyberDefenders has publicly attributed the attack to #APT.

Example A_3 features a cornucopia of public attributions aimed at imposing costs on Rosaria using a range of different modalities, each of which is subject to different requirements or expectations about evidentiary standards—no fewer than four such standards, in this example. Americious's optimal end state for the criminal indictments is to secure criminal convictions for the three suspects. Here, the evidentiary standard might be something like the American standard of "beyond a reasonable doubt," an appropriately high standard when the stakes involve denying persons their liberty. Conviction requires, of course, that ALE is able to bring the three suspects into custody—Americious does not try criminal defendants in absentia—and to presumably do so without the cooperation of Rosaria, which is unlikely to turn over its own operatives to stand trial in a foreign land. Getting custody of the suspects may be tricky, however, if the suspects are savvy about international travel and extradition processes. Americious might have to settle instead for having the suspects live under the shadow of the indictments, which is no trivial thing to the extent the suspects had aspirations of being internationally mobile. The evidentiary standard for indictments compared to criminal convictions is lower in Americious, as is typical, and is similar to the American standard of whether there is probable cause (i.e., reasonable grounds) to believe the suspects committed a crime. The evidentiary standard for economic sanctions may be even lower.

Persuading a jury to deliver a guilty verdict in a criminal case is no small feat, from an evidentiary perspective. Persuading foreign governments that an analytic attribution is true, as Americious and Ukaria will have to do to build a multilateral coalition against Rosaria's actions, presents its

own unique challenges, for several reasons. There are no consensus evidentiary standards under international law generally for assigning blame, let alone in the cyber context specifically. For example, a U.N. Group of Governmental Experts concluded in 2015 that accusations of malicious cyberactions should be “substantiated,” but there was no consensus on what it would take to substantiate an accusation.¹⁵ In addition, unlike criminal proceedings in most rule-of-law democracies, where evidentiary rules exist to safeguard the integrity of evidence, there are no such rules in international affairs. Indeed, Americious based its analytic attribution in part on classified intelligence collection, which is often stolen information.

Moreover, the persuasiveness of the evidence in international affairs when there is no smoking gun is closely tied to the credibility and reputation of the claimant. This feature of international politics was illustrated perhaps most famously when Secretary of State Dean Acheson, on behalf of President John F. Kennedy, visited French President Charles de Gaulle to show him surveillance photos of Soviet missiles in Cuba. De Gaulle reportedly declined to view them and told Acheson that “The word of the president of the United States is good enough for me.” If Americious has a strong reputation for honesty, good faith, and integrity, its implied evidentiary burden at the United Nations is almost certainly lower than for countries lacking that reputation.

As it stands today, the evidentiary standard for public attribution outside the confines of established legal or other adjudicatory frameworks is context dependent and fundamentally political. The identity of the claimant bears directly on the credibility of its claim, with none of the formal evidentiary and other substantive and procedural safeguards available in most municipal legal settings to protect the integrity of evidence and witness testimony with the goal of allowing the facts and evidence to speak for themselves. Similarly, nation-states and other actors will often evaluate evidence with an eye toward what the consequences might be if the evidence were true. They are not neutral factfinders.

The example notes that Americious ministers published an alert on the technical aspects of the threat, with recommended mitigations. Even though the point of the alert seems to be to equip defenders with threat information and practical mitigations as opposed to making the case for Rosaria’s culpability, the ministers should expect skeptics and naysayers to cite any perceived evidentiary inadequacies in the alert as part of an effort to undermine the credibility of Americious’s accusations against Rosaria.

Regardless of what other governments think about these claims, Americious and, especially, Ukaria have set in motion with their public attribution a strategic dynamic with domestic political and geopolitical implications. If the two countries fail to marshal international support for

some form of meaningful punitive action against Rosaria, Rosaria and other countries might conclude that the diplomatic costs of offensive cyberoperations are manageable. For Ukaria in particular, by making a strong statement of public attribution about an attack it suffered, it will almost certainly face some pressure at home to “do something” about Rosaria, independent of what happens at the Security Council. Americious might face similar pressures at home as well. A government’s inability to meet these expectations is a cost and must be factored in to a calculus about public attribution.

In Example B₃, Acme seeks money damages from NCC. To prevail against NCC in a civil lawsuit with American-like evidentiary requirements, Acme will have to persuade a factfinder (a judge or jury) that the preponderance of the evidence (i.e., at least 50.0000001%) supports their claim, meeting the standard of “more likely than not.” There is a potential cost to this lawsuit, beyond the inevitable lawyers’ fees. If Chicoria, NCC’s home government, is vindictive, then, by waging the lawsuit, Acme may be effectively writing off the Chicorian market.

In Example C₃, why would CyberDefenders issue a public report? Maybe its executive leadership is legitimately fed up with #APT and wants to provoke media and policy makers to pay more attention to it. A public report may also be good for sustaining employee morale by giving analysts and others in the company a sense of mission and importance. And last but not least, a compelling report is killer marketing.

On the other hand, a public report is going to get picked apart by other researchers. There is no consensus over appropriate evidentiary standards for analytic attribution by a private company in the court of infosec opinion, so CyberDefenders is exposing itself to a potentially fluid and shifting set of evidentiary expectations. Also, depending on the antagonist featured in the report, the report could expose the company to reprisals from an angry government or, in this example, a criminal group. The stakes are high for CyberDefenders. It is a reminder that an actor does not engage in strategic attribution unless the benefits outweigh the costs. As one cybersecurity company aptly explains its policy on attribution, “Due to the lack of value to defenders and the ramifications of incorrect attribution, Dragos does not comment publicly on attribution.”⁹

Several conclusions emerge from this discussion. Analytic attribution—a theory of who perpetrated a cyberattack—is sometimes necessary for action but not always. And even in cases where having some theory of analytic attribution is a prerequisite for action, the necessary level of specificity about the identity of the perpetrator to enable action can vary widely. For infosec researchers and defenders, distilling information about

malicious activity into broad adversary groupings—“APT 1,” “Fancy Bear,” and the like—is often sufficient to enable research and defensive efforts that require some measure of analytic attribution. For such actions as criminal prosecutions, economic sanctions, and civil lawsuits, however, a specific person or organization must be identified. Even so, the evidentiary standards for each of these actions are different and range from relatively low (sanctions) to substantial (criminal conviction) to informal and community driven (adversary groupings).

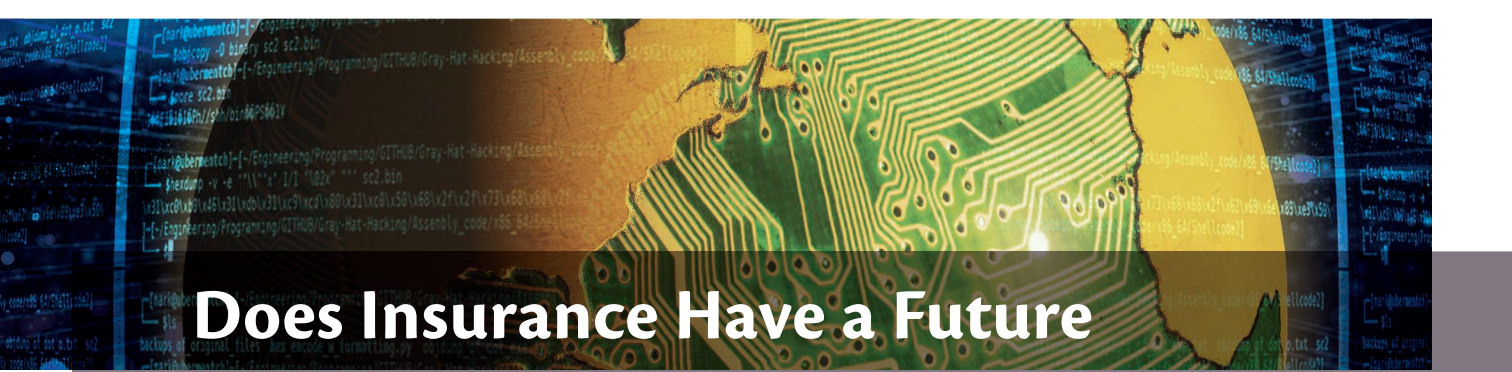
Selective attribution is far more common than public attribution yet its vital role in infosec and cyber policy is often glossed over. Evidentiary issues may be partly to blame for the relative lack of scholarly and policy attention paid to selective attribution since these more discreet acts of attribution, by definition, do not always register in the public domain. That said, it is clearly a topic worthy of more scholarly and policy focus. Strategic attribution will often be necessary for sending deterrence signals, but the sender has a choice between delivering the signal selectively or publicly. Which mode is superior is likely to be context dependent, and there is nothing inherently superior about public attribution: sometimes it may be necessary; other times it will not be.

Finally, the victim of a cyberincident will often have a decisive say in attribution matters. If the individual or entity's consent and cooperation are required before a third party is able to investigate an incident and acquire data leading to an analytic attribution, or they have a veto right over how a third party can use the data it acquired, including for strategic attribution, then the third party's options for attribution are linked to the victim's preferences. In some cases, the victim's preference for discretion may conflict with a third party's desire to use the incident to advance some strategic objective, such as deterrence. The reverse may also be true. ■

References

1. D. A. Wheeler and G. N. Larsen, “Techniques for cyber attack attribution,” Institute for Defense Analysis, Alexandria, VA, 2003. [Online]. Available: <https://apps.dtic.mil/dtic/tr/fulltext/u2/a468859.pdf>
2. T. Rid and B. Buchanan, “Attributing cyber attacks,” *J. Strateg. Stud.*, vol. 38, no. 1–2, pp. 4–37, 2015.
3. S. Romanosky and B. Boudreaux, “Private sector attribution of cyber incidents: Benefits and risks to the U.S. government,” RAND Corp., Santa Monica, CA, WR-1267-OSD, 2019.
4. Office of the Director of National Intelligence, “A guide to cyber attribution,” McLean, VA, 2018. [Online]. Available: https://www.dni.gov/files/CTIIC/documents/ODNI_A_Guide_to_Cyber_Attribution.pdf
5. United States v. Fujie Wang et al., Case 1:19-cr-00153-JRS-MJD (U.S. District Court, Southern District of Indiana, Indianapolis Division, 2019). [Online]. Available: <https://www.justice.gov/opa/press-release/file/1161466/download>
6. J. Davis et al., *Stateless Attribution: Toward International Accountability in Cyberspace*. Santa Monica, CA: RAND Corp., 2017.
7. J. Neutze, “The role of cybernorms in preventing digital warfare,” Microsoft, Redmond, WA, 2016. [Online]. Available: <https://blogs.microsoft.com/eupolicy/2016/07/08/the-role-of-cybernorms-in-preventing-digital-warfare/>
8. H. Lin, “Attribution of malicious cyber incidents: From soup to nuts,” Hoover Working Group on National Security, Technology, and Law, Aegis Series Paper No. 1607, Sept. 26, 2016. [Online]. Available: <https://lawfareblog.com/attribution-malicious-cyber-incidents>
9. Dragos Inc., “TRISIS Malware: Analysis of Safety System Targeted Malware,” Hanover, MD, 2017. [Online]. Available: <https://dragos.com/wp-content/uploads/TRISIS-01.pdf>
10. J. Healey, “Beyond attribution: Seeking national responsibility for cyber attacks,” Atlantic Council, Washington, D.C., 2012. [Online]. Available: http://www.atlanticcouncil.org/images/files/publication_pdfs/403/022212_ACUS_NatlResponsibilityCyber.PDF
11. J. R. Lindsay, “Tipping the scales: The attribution problem and the feasibility of deterrence against cyberattack,” *J. Cybersecur.*, vol. 1, no. 1, pp. 53–67, 2015.
12. A. Carson and K. Yarhi-Milo, “Covert communication: The intelligibility and credibility of signaling in secret,” *Secur. Stud.*, vol. 26, no. 1, pp. 124–156, 2017.
13. M. Poznansky and E. Perkosi, “Rethinking secrecy in cyberspace: The politics of voluntary attribution,” *J. Global Secur. Stud.*, vol. 3, no. 4, pp. 402–416, 2018.
14. First.org, “Traffic Light Protocol (TLP), Version 1.0,” Cary, NC, 2016. [Online]. Available: <https://www.first.org/tlp>
15. United Nations Group of Governmental Experts, “Report of the Group of Governmental Experts on developments in the field of information and telecommunications in the context of international security,” United Nations General Assembly, New York, 2015. [Online]. Available: <https://undocs.org/A/70/174>

Andrew Grotto is the director of Stanford University's Program on Geopolitics, Technology, and Governance. He received his J.D. from the University of California, Berkeley, and his M.P.A. from Harvard University. Grotto is the William J. Perry International Security Fellow at the Stanford Cyber Policy Center and a visiting fellow at the Hoover Institution, and he served as senior director for cyber policy on the National Security Council in the Obama and Trump administrations. Contact him at grotto@stanford.edu.



Does Insurance Have a Future in Governing Cybersecurity?

Daniel W. Woods | University of Oxford
Tyler Moore | University of Tulsa

Cyber insurance could achieve public policy goals for cybersecurity using private-sector means. Insurers assess organizational security postures, prescribe security procedures and controls, and provide postincident services. We evaluate how such mechanisms impact security, identify market dynamics restricting their effectiveness, and sketch out possible futures for cyber insurance as governance.

Despite grabbing policy makers' attention, cybersecurity has seen very few policy measures adopted. Efforts to spur investments in cybersecurity have been modest and diffuse. Ex-ante obligations tend to be industry specific and avoid prescribing technical controls in favor of specifying organizational processes that must be followed.¹ Organizations setting security budgets and deciding how much and where they should be spent must look beyond regulation.

Private governance influences how responsibilities and liabilities are aligned for organizations. For our purposes, this consists of nongovernmental entities creating rules and enforcement mechanisms that influence security decisions. For example, the Payment Card Industry Security Standards Council defines a standard for how merchants manage credit card data. This includes the annual validation of compliance with the standard and fines for noncompliance resulting in lost data. Enforcement power is derived from controlling access to payment card networks. Merchants must either accept the standard or ask their customers to pay by other means.

The subsequent Payment Card Industry Data Security Standard (PCI DSS) is remarkably prescriptive in terms of how payment card data are handled, especially when compared with most public regulations.

The insurance industry provides another model of private governance. Ericson et al.² analyzed how insurers attempt to control policy holder decisions to reduce the “moral risk” of policy holders who act recklessly. Insurance contracts define rules to be followed, insureds are assessed before the contract is signed, premiums rise and fall depending on insured characteristics and behavior, and claim-generating incidents are investigated. Although there is skepticism regarding its effectiveness, insurers can influence policy holder behavior up to the point that switching to another provider or operating without insurance is preferable. Such processes occurring “beyond the state”² tie into a liberal theory of governance that de-emphasizes state responsibility.

Given the limits of public policy measures thus far, enthusiasm for insurance as a form of cybersecurity governance is growing. Public institutions in the European Union (EU) and the United States have published reports exploring how they can support the insurance industry in improving cybersecurity levels.³ The impact

will increase as more organizations purchase policies. Allianz, for example, predicts the cyber insurance market will grow to US\$20 billion by 2025, as identified by Romanosky et al.⁴

Insurers face incentives to put mechanisms of control in place to reduce cyber losses. Scholars predict that the industry will increase security levels by offering premium discounts for more secure infrastructure.⁵ Talesh suggests insurers focus on reducing losses postincident by acting as the self-styled “quarterbacks of data breach response.”⁶ These claims about cyber insurance are based on intuition and insurers self-reporting. Establishing whether and how these mechanisms occur is necessary, especially given that policy makers are considering costly interventions to support the market.³ Government acting as the (cyber) insurer of last resort is frequently proposed, for example.

Cyber Insurance As Governance

Cyber insurance was predicted to impact security behavior before any evidence was collected. In 2001, Schneier⁵ envisaged a world where every organization purchases network security insurance with discounts offered for security enhancing decisions such as replacing an insecure Windows system with a more secure version of Linux. The optimistic essay ends by suggesting “good security [will be] rewarded in the marketplace” as insurers recognize “computer security snake-oil peddlers.”⁵

A 2008 report⁷ echoed Schneier’s vision of premium discounts as incentives, while also suggesting discounts could be used as security metrics. Security investments offering a bigger discount would be viewed as more effective. These discounts would be based on knowledge generated by aggregating claims data or even commissioning primary research. Despite the report being commissioned by a policy-making institution, the authors offered a wait-and-see conclusion regarding possible policy measures in support of the market.

Although these arguments are intuitively appealing, a review of cyber insurance in 2010 revealed that “positive expectations about cyber insurance have not been analyzed rigorously.”⁸ Informal conjectures claimed the insurers would impact security levels or generate knowledge without any corresponding parameters or model features. If this was a criticism of theoretical research, their observations of empirical research went even further by stating “we are not aware of any quantitative empirical work on cyber insurance markets.”

Yet policy makers in the United States and the EU latched onto the idea that insurers can incentivize better risk management. Reports released from 2012 onward by public institutions in the United States and the EU suggest that insurance contracts will contain “prescribed security controls and procedures”³ that the

policy holder must implement for coverage to be valid. All of the private governance mechanisms covered in this section were discussed at some point; however, these reports were largely based on individual views of the market, not empirical findings.

Talesh⁶ explored the topic by collecting evidence from industry conferences, educational webinars, and marketing documents. This self-reporting by insurers supports the conclusion that insurer-sponsored help is greatly appreciated by organizations. The article concedes that suggesting this leads to a net benefit is premature, especially given that Talesh admits the value of these insurer-sponsored risk management services remains an open question.

The following is a list of mechanisms by which insurers are claimed to affect cybersecurity:

- *C1 Assess Security Levels:* The application process will “measure the organization’s practices and make sure they are consistent with the prevailing security standards.”⁶
- *C2 Incentives for Investment:* Premium discounts will influence the choice of systems and security controls.⁵
- *C3 Create Security Obligations:* Ensure that contracts will contain “prescribed security controls and procedures”³
- *C4 Access to Response Services:* Provide “a menu of services that an organization can quickly access in the event of a data breach”⁶
- *C5 Generate Knowledge:* Aggregate claims information and conduct primary research to develop an understanding of cyber risk.⁷

Before policy makers endorse insurance as an effective form of governance, we should evaluate these claims by collecting empirical evidence.

The Evidence Thus Far

We conducted nine interviews with underwriters operating in the Lloyd’s of London market, which sells insurance to international clients. We also considered the findings of several empirical studies. Romanosky et al.⁴ analyzed 235 regulatory filings regarding cyber insurance policy terms, application forms, and pricing algorithms. Woods et al.⁹ mapped the security controls found in 24 cyber insurance application forms to two popular information security standards. Franke¹⁰ conducted interviews with 15 insurance professionals based in Sweden. Axon et al.¹¹ analyze 70 cyber insurance claims.

Application forms collect information relevant to information security^{4,9} confirming that insurers assess security (C1). Which aspects of security are measured is a more interesting question. A study of 44 applications

forms found “only very rudimentary information is collected” about technical infrastructure.⁴ Further, many forms do not collect any information about entire sections of popular information security standards.⁹

Often these forms are not even filled out because brokers push underwriters to assess larger clients based on market meetings. Multiple underwriters ask representatives of the insured questions about IT architecture and security measures over the phone. Interviewees reported questions going unanswered, with one suggesting that insurance can be purchased without naming “who your dependencies [sic] are,” thus undermining the insurer’s ability to monitor vendors.

Results from the Swedish interviews¹⁰ suggest that implementing security controls and procedures leads to premium discounts (C2); however, many Swedish insurers do not actually put this into practice,¹⁰ stating that discounts suit bigger clients better. Our U.K. respondents offered discounts based on a holistic view of an applicant’s security but cannot quantify the effectiveness of a security control in isolation. One interviewee suggested accreditation to standards does not lead to a massive discount, while another said, “... it is not like a 10% discount if you take good logs.” A separate interviewee suggested that discounts for IT security were coming down because “more of the issues are coming out of procedure.” Romanosky et al.⁴ found that 45% of pricing algorithms filed with U.S. regulators did not even consider information security.

Organizations face little additional incentive to comply with the security policy once a policy has been purchased (C3). The most commonly observed exclusions were not necessarily directly related to the cyber realm.⁴ The exception proves the rule in “Columbia Casualty Company Versus Cottage Health System,” in which an insurer denied coverage because the insured used factory default system configurations and systems in which security patches were no longer even available, much less implemented, despite representing otherwise in the application. This was the first such case, and it was widely believed that these terms should have been negotiated out of the contract, which suggests that insurers cannot punish policy holders for flaunting basic security procedures.

Insurers are more likely to exclude types of losses or causes of incidents. Famously, one insurer excluded coverage for the NotPetya attack claiming it constituted a “hostile or war-like action,” which had already been identified as a potential issue by Woods and Simpson.³ Although this legal case relates to a property insurance policy, cyber insurance policies contain similar exclusions, but none have been enforced thus far. Romanosky et al.⁴ observe that “almost half” of the policies in their sample exclude losses related to extortion or ransom. Many of the analyzed policies were written before ransomware became

widely used by cybercriminals, prompting many interviewees to update their policies to reflect this.

All of our interviewees supported the view that postincident services (C4) reduce losses. Axon et al.¹¹ showed that lawyer services and breach counsel are the most common expenditures related to cyber insurance claims, indicating that insurers do indeed provide these services. There is, however, a potential conflict of interest when the insurer chooses the provider. This forces a choice between acting to minimize the client’s losses or the insurer’s indemnity payment. For example, a public statement might be seen favorably by regulators when considering the size of a fine, which the insurer would indemnify, while also causing reputation damage, which the insurer would not indemnify.

The preceding evidence could result from an immature market. Insurers may first need to generate knowledge and understand the market (C5). One insurer discontinued a subsidiary conducting loss research into information risks in the early 2000s,⁷ and we are not aware of any similar insurance industry-sponsored R&D outfits. Increasing understanding by aggregating claims data is limited by inconsistent data collection in an unstandardized format;³ however, the individual underwriters we interviewed were admirably committed to learning about information security via formal courses, news reports, academic articles, and other such resources. This focus on education is extended to clients. One interviewee’s firm offered an online cybersecurity awareness platform and monitored how often the insured party used it, which was deemed to be an effective way to gauge culture.

Unfortunately, this does not seem to be translating to innovation in policies or underwriting methods. Studying policies from 2007 to 2017 did not reveal any substantial changes in policy length, style, or composition over time.⁴ Only 15% of 395 insurance professionals responding to the 2017 Advisen cyber insurance market trends survey reported that systemic events such as the Dyn distributed denial-of-service attack or the WannaCry Ransomware event had a moderate or significant impact on underwriting, with 45% reporting no impact whatsoever.

The evidence indicates that today’s cyber insurance market is not fully delivering on its predicted governance functions, with security obligations in contracts particularly lacking. The following section explores why this is the case.

What Is Preventing Governance?

The lack of focus on security posture during the risk assessment could be explained by a phenomenon observed by Woods and Simpson.³ Here, brokers directed applicants toward insurers with the least stringent application procedures, creating a “race to the bottom” in

risk assessment. Many respondents want the market to harden, that is, move away from an oversupply of insurance, so that insurers can begin asking tougher questions and start demanding concessions from the client. Woods et al.¹² collected evidence suggesting that cyber insurance premiums in the Californian-admitted market are falling, with the latest data point occurring in 2019, indicating that the oversupply of insurance will continue.

The Payment Card Industry Security Standards Council has sidestepped this problem by the card providers jointly developing a standard and ensuring providers do not deviate from enforcement. Such an approach by insurance carriers would likely violate competition laws.

We are yet to see evidence that indicates insurers can directly improve security via premium discounts. The cost of most security controls dwarfs the benefit in terms of reduced premium, which suggests discounts only provide incentives to invest at the margin. Furthermore, insurers do not provide discounts based on individual controls, but rather, due to a holistic view of security. Insurers offering discounts for security controls already in place is different from offering discounts as an incentive to implement security. The latter is akin to suggesting that cinemas encourage pursuit of higher education by offering discount ticket prices to students.

It is natural to ask why insurers would offer greater incentives to invest than what are currently available. A rational insured would already have a cost-effective security control in place; this is because security controls accrue more benefit to the insured than the insurer, given that insurers only cover a subset of the potential losses. A counterargument focuses on interdependent security⁸ in which security controls provide security for other policy holders in addition to the one who makes the investment. This means that the insurer is uniquely placed to internalize the positive externality and would do so by incentivizing security. It is an empirical question whether the benefits from interdependent security will overpower the insurer covering a subset of the potential loss. It is worth noting that none of our interviewees mentioned interdependent security, likely because it is a concept more associated with academic discussions.

Exclusions (such as withdrawing coverage if security patches are not applied) are mysteriously absent in insurance policies. One explanation for this could be broker commission, which tends to be a percentage of the premium. This incentivizes negotiating for broader coverage with fewer security obligations rather than for a lower price and more security obligations. Another explanation could be that insurers recognize that the implementation of security controls is imperfect, and they want to assure their clients that they will pay out claims in the event of a breach.

Once again, the comparison to PCI DSS is instructive: in nearly all high-profile thefts of payment card data, investigators have retroactively found the affected firms to be noncompliant with PCI rules and therefore subject to penalties. This has weakened the incentive to spend the resources necessary to become compliant in the first place. Additionally, insurers do not wield nearly as powerful a stick as does the PCI council, which can suspend acceptance of credit card payments. It therefore seems reasonable to offer broader coverage to attract customers in a competitive marketplace.

In other words, customer relations matter a lot. Cuthbert Heath famously offered to pay all claims in full following the 1906 San Francisco earthquake¹³ without auditing the claims. Insurers may pay claims from organizations that are not currently following security procedures so as to maintain trust in the product, which is essentially a promise to pay out. Yet the lack of security obligations could lead to moral hazard polluting risk pools, in which bad risks joining the risk pool increase expected losses, with these costs absorbed by the customers following such procedures.

Postbreach services are the success story of cyber insurance. Insurers provide these services because they reduce incident costs that insurers would have to otherwise indemnify, whereas risk mitigation leads to benefits in terms of attacks (and therefore claims) avoided, which is more difficult to observe. Monitoring risk mitigation measures is costly, and the potential for misconfiguration undermining efficacy is great. Alternatively, security vendors have not been able to demonstrate that their products reduce losses, unlike, say, manufacturers of fire doors in property insurance.

The lack of change in policy composition over time could result from innovation not tracked by the regulatory filings analyzed by Romanosky et al.⁴ Underwriters pursuing further education and independent research leads to better decisions without formal documentation. It is also possible that requiring insurers to file when they update policy wording or prices is dampening innovation.

We next consider what might change in the future.

Will Cyber Insurance Exist in 10 Years?

A fundamental question for cyber insurance is whether it will even exist as a distinct offering in the future. Presently, a considerable proportion of traditional policies do not affirmatively include or exclude cyber coverage. The resulting ambiguity is known as *silent cyber*.³ The industry is currently moving to remove this ambiguity by using exclusions.

Multiple interview participants expressed the opinion that cyber risks will be affirmatively included in traditional lines of insurance. This future considers cyberattacks as a peril, not unlike fire or workplace accidents.

Traditional losses caused by cyberattacks or cyber liability assigned by courts would be realized as in the noncyber equivalents. This would mirror environmental liability insurance, which received much attention as stand-alone coverage in the 1980s but is not widely purchased.

A contradictory future sees cyber insurance emerge as a stand-alone product that every organization purchases. It would cover all losses resulting from cyberattacks, including ransom demands, liability, and business interruption. Differentiating risks in this way helps insurers address problems such as adverse selection and moral hazard. Additionally, cybersecurity expertise could be concentrated, with insurance professionals selling stand-alone cyber insurance.

If cyber insurance is absorbed into traditional lines, the private governance effects will be more diffuse. It is an empirical question whether this is more effective for changing security practices. In one respect, individual underwriters will have less specialized expertise in conducting in-depth cyber risk assessments or issuing security advice. Conversely, cyber risk may be integrated into organizational risk management on a footing equal to other risks, potentially leading to more resources being allocated to cybersecurity.

In large part, this debate stems from the lack of clarity in the term *cyber insurance*. Böhme et al.¹⁴ suggest differentiating coverage by the type of asset and the means of risk arrival. Cyberthreat insurance, which covers physical losses caused by logical attack, could be absorbed into traditional lines. Offering coverage for information assets may be more difficult. It is worth noting that the industry response to “silent cyber” has generally been to exclude losses caused by logical attack and offer coverage under stand-alone cyber insurance coverage.³

Can Insurance Improve Cyber Hygiene?

Another question concerns the depth of risk assessment. This could shift if policy holders with stronger security postures recognize that the lack of a rigorous risk assessment pollutes risk pools. Uniquely, buyers with a strong security posture relative to other buyers should seek out insurers conducting in-depth risk assessments. The time cost of communicating information about security posture results in better risk selection and fewer claims for the insurer to pay, which should translate to lower premiums. Brokers are well placed to lead this change because they understand which insurers conduct rigorous assessments. It may not be in a broker’s self-interest because communicating this information requires more of the broker’s time, which is not rewarded as they are paid by commission.

Insurers refusing coverage for organizations that flaunt basic security procedures (such as using default system configurations) should be applauded for preventing moral hazard from polluting risk pools. Policy holders who

follow basic procedures must cross-subsidize otherwise. However, there is a fine line between requiring a basic security level from insureds and withdrawing coverage to avoid paying out on claims. An entity should monitor this, whether that be a regulator, broker, or consumer group.

The presence of security obligations in contracts touches on the general lack of standardized policy wording. Industry bodies or regulators could force more standard contracts.³ Consumers would benefit from standard policies that allow for comparisons of insurer product offerings. Insurers, however, would be restricted in their ability to innovate in response to the dynamics of cybercrime.

Brokers are the primary beneficiaries of the current nonstandard market. They earn commission by reducing transaction costs for organizations looking to buy insurance. The diversity of products increases the value of specializing in assessing and negotiating the terms and price of cyber insurance policies. The race-to-the-bottom effects are likely to remain as long as insurers rely on intermediaries to sell cyber insurance products, which undermines insurance as governance.

Will an Actuarial Science of Cybersecurity Emerge?

Power¹⁵ charted the rise of risk management and its impact on organizational life. The concept of operational risk, to which cyber risk contributes, emerged from the financial sector. Power suggested that the actuarial base for operational risk insurance must be suspect due to the low frequency of events. Examining how the actuarial base might be built, historic claims data were sought.

The majority of the market is open to sharing while a few insurers see claims data as their competitive advantage.³ Unfortunately, these insurers also tend to hold most of the data. The value of claims data could tilt the market toward a natural monopoly that can only support a few dominant firms. The next best thing is databases that aggregate all publicly reported incidents. These will continue to grow over time but are limited by reporting biases; incidents related to availability or integrity, which tend not to compromise personal data, do not fall under mandatory reporting laws.

The actuarial base is further undermined by tension between long-term analytics and short-term expediency. An interview participant suggested proposal forms that provide standardized data collection could lead to an “analytic database,” but that large companies are moving “more toward meetings and calls.” This trend could see cyber insurance descend into an art based on the ad hoc judgment of underwriters. Many participants were optimistic about “security scorecard science” providing an objective basis for analytics, which involves collecting data by scanning externally facing nodes on the applicant’s network to provide a single score, much like a credit rating.

Power's¹⁵ account of reputation risk provides a cautionary tale for standardized risk assessment, such as security scores. External agencies created evaluation metrics that cannot be challenged by the organization under evaluation. The criteria of these metrics were internalized over time, displacing values linked to the organization's particular context. This may result in a suboptimal use of resources by emphasizing externally observable controls over more effective ones.

The suboptimal allocation of resources might also result from micropolitics¹⁵ within the organization, which is empowered by cyber insurance. Departments such as IT and human resources may compete for responsibility and resources regarding risk management. If the application forms value legal compliance over technical infrastructure, as seems to be the case,^{4,9} the legal department may use this to justify taking responsibility away from the IT department. Insurers focusing on process could result from the "streetlight effect," rather than what is optimal for the organization.

The relationships between insurers and security service providers is troubling. Insurers revealed that they received advice in exchange for recommending the vendor to their clients, sometimes even requiring insureds to use that vendor's services or products. Beyond the anticompetitive aspects, we should question the role of commercial interests in providing this advice. It could be warping the underwriter's view of what constitutes an effective security investment. One might also question the social desirability of the most common claims costs³ going toward professional services rather than restitution for victims, who often have little control over their data.

How to Deal With the Potential for Cyber Catastrophe?

The potential for correlated cyber losses is intimately linked to how claims costs arise. Axon et al.¹¹ describe evidence indicating that data breaches, ransomware, and noncompliance with legislation are the most common triggers of cyber insurance claims. Data breaches rarely correlate across companies, and costs assigned by courts are bounded by the judge's sense of proportionality, although insurers have fallen victim to political judgments assigning costs to those deemed to have the deepest pockets in the past.¹³

Ransomware incidents are different because many claims can result from the same underlying cause, as evidenced by the NotPetya attack. Incidents occurring independently, such as data breaches, can be absorbed by risk pools; however, correlated incidents pose an existential threat to the risk pool. The increasing prevalence of ransomware claims and their increased solvency risk may force insurers, possibly led by reinsurers, to influence cybersecurity levels in a way that we have

not seen thus far. But we should be cautious given the number of false dawns observed heretofore.

Anxiety about aggregated or correlated losses will not abate until network complexity is reduced. Doing so would fundamentally reshape modern economies. Insurers instead try to track service providers as a point of correlated risk accumulation. If the market began to harden, they may be able to select or incentivize insureds to create more diversity and resilience.

Alternatively, the industry may move toward excluding coverage for systemic attacks. Poor communication in doing so undermines consumer trust. Criticisms were leveled following the NotPetya attack because the threshold for cyber war is ambiguous. Many of these criticisms were unfair given the policy in question was not sold as cyber insurance. Nevertheless, court battles are an expensive way to clarify expectations.

Insurers may instead lobby the government to become the reinsurer of last resort. There are precedents, such as with flood and terrorism insurance and the many different forms this can take.¹³ Proponents suggest that these losses are caused by states failing to protect companies from other nation-state attacks. Detractors ask why taxpayers should cover the tail risk of private companies when they fail to comply with basic security procedures, such as patching the vulnerability behind the NotPetya attack.

Recalling why governments provide a backstop for flood and terrorism coverage is important for evaluating this policy measure. Reinsurers began excluding terrorism-related losses following events in the United States and the United Kingdom, leading to reinsurers withdrawing coverage.¹³ It was argued that insurers would not offer policies to consumers unless a government backstop was provided. In contrast, policy reports have identified a lack of demand in the cyber insurance market,³ which cannot be solved by supply-side measures such as government backstops. This policy measure should be shelved until an undersupply of cyber insurance is identified.

Policy makers have long held high hopes for cyber insurance as a tool for improving security. Unfortunately, the available evidence should give policy makers pause. Cyber insurance appears to be a weak form of governance at present. Insurers writing cyber insurance focus more on organizational procedures than technical controls, rarely include basic security procedures in contracts, and extend discounts that only offer a marginal incentive to invest in security. However, the cost of external response services is covered, which suggests insurers believe ex-post responses to be more effective than ex-ante mitigation. (Alternatively, they can

more easily translate the costs associated with ex-post responses into manageable claims.)

The private governance role of cyber insurance is limited by market dynamics. Competitive pressures drive a race to the bottom in risk assessment standards and prevent insurers from including security procedures in contracts. Policy interventions, such as minimum risk assessment standards, could solve this collective-action problem. Policy holders and brokers could also drive this change by considering insurers who conduct rigorous assessments. Doing otherwise allows adverse selection, and moral hazard will increase costs for firms with responsible security postures.

Moving toward standardized risk assessment via proposal forms or external scans supports the actuarial base in the long term. But there is a concern that policy holders will succumb to Goodhart's law by internalizing these metrics and optimizing the metric rather than minimizing risk. This is particularly likely given that these assessments are constructed by private actors with their own incentives. "Search-light effects" may drive the scores toward being based on what can be measured, not what is important.

Systemic risk has a number of possible futures. Organizations may have to accept liability as insurers exclude the risk. Governments may step in to offer reinsurance, although we caution against doing so until an undersupply of cyber insurance is observed. Otherwise, insurers may demonstrate leadership by encouraging diversity in technology and service providers to reduce systemic risk. ■

Acknowledgment

We thank Rainer Böhme and the anonymous reviewers for providing constructive feedback. Thanks also to participants in the Lorentz Center's workshop "Cyber Insurance and its Contribution to Cyber Risk Mitigation," for their many interesting ideas about the role of brokers. Our collaboration was made possible by a Fulbright Cybersecurity Scholar Award.

References

1. T. Moore, "The economics of cybersecurity: Principles and policy options," *Int. J. Critical Infrastructure Protection*, vol. 3, no. 3–4, pp. 103–117, 2010.
2. R. Victor Ericson, A. Doyle, and D. Barry, *Insurance As Governance*. Toronto, ON, Canada: Univ. of Toronto Press, 2003.
3. D. W. Woods and A. C. Simpson, "Policy measures and cyber insurance: A framework," *J. Cyber Policy*, vol. 2, no. 2, pp. 209–226, 2017.
4. S. Romanosky, L. Ablon, T. Jones, and A. Kuehn, "Content analysis of cyber insurance policies: How do carriers price cyber risk?" *J. Cybersecurity*, vol. 5, no. 1, 2019. doi: 10.1093/cybsec/tyz002, [Online]. Available: <https://academic.oup.com/cybersecurity/article/5/1/tyz002/5366419>
5. B. Schneier, "Insurance and the computer industry," *Commun. ACM*, vol. 44, no. 3, pp. 114–115, 2001.
6. S. A. Talesh, "Data breach, privacy, and cyber insurance: How insurance companies act as "compliance managers" for businesses," *Law Social Inquiry*, vol. 43, no. 2, pp. 417–440, 2018.
7. R. Anderson, R. Böhme, R. Clayton, and T. Moor, "Security economics and European policy," in *ISSE 2008 Securing Electronic Business Processes*. Wiesbaden: Springer Vieweg Verlag, 2009, pp. 57–76.
8. R. Böhme and G. Schwartz, "Modeling cyber-insurance: Towards a unifying framework," in *Proc. 9th Workshop Economics of Information Security (WEIS 2010)*, 2010, pp. 1–36.
9. D. W. Woods, I. Agrafiotis, J. R. Nurse, and S. Creese, "Mapping the coverage of security controls in cyber insurance proposal forms," *J. Internet Services Appl.*, vol. 8, p. 8, July 2017. doi: 10.1186/s13174-017-0059-y. [Online]. Available: <https://jisajournal.springeropen.com/articles/10.1186/s13174-017-0059-y>
10. U. Franke, "The cyber insurance market in Sweden," *Comput. Security*, vol. 68, pp. 130–144, July 2017.
11. L. Axon, A. Erola, I. Agrafiotis, M. Goldsmith, and S. Creese, "Analysing cyber-insurance claims to design harm-propagation trees," in *Proc. Int. Conf. Cyber Situational Awareness, Data Analytics and Assessment (Cyber SA)*, 2019. doi: 10.1109/CyberSA.2018.8551399.
12. D. W. Woods, T. Moore, and A. C. Simpson, "The county fair cyber loss distribution: Drawing inference from insurance prices," in *Proc. 18th Workshop Economics of Information Security (WEIS)*, 2019, pp. 1–25.
13. R. Thoyts, *Insurance Theory and Practice*. Evanston, IL: Routledge, 2010.
14. R. Böhme, S. Laube, and M. Riek, "A fundamental approach to cyber risk analysis," *Variance*, vol. 12, no. 2, pp. 161–185, 2019.
15. M. Power, *Organized Uncertainty: Designing a World of Risk Management*. London: Oxford Univ. Press, 2007.

Daniel W. Woods is a Ph.D. student in the Department of Computer Science at the University of Oxford, United Kingdom. His research focuses on the economics of cyber risk transfer. He is the recipient of a Fulbright Cyber Security Award. Contact him at daniel.woods@cs.ox.ac.uk.

Tyler Moore is the Tandy Associate Professor of Cyber Security at the University of Tulsa, Oklahoma. His research interests include security economics, cybercrime measurement, and cybersecurity policy. Moore received his Ph.D. from the University of Cambridge, United Kingdom, as a Marshall Scholar. Contact him at tyler-moore@utulsa.edu.



Toward a Data-Driven Society: A Technological Perspective on the Development of Cybersecurity and Data-Protection Policies

José L. Hernández-Ramos, Dimitris Geneiatakis, Ioannis Kounelis, Gary Steri,
and Igor Nai Fovino | European Commission

A data-driven society requires a common regulatory umbrella to provide a harmonized vision of cybersecurity. We describe cybersecurity policies and joint initiatives in the European Union and give insights about the need to align ongoing technological advances with such regulatory efforts.

The future digital landscape is being driven by an unprecedented technological convergence, which has led to the establishment of worldwide initiatives and alliances to encourage a harmonized development environment. Through this trend, currently the data generated by physical devices in a certain environment can be shared and consumed around the world to explain or predict phenomena, such as climate change or financial crisis. The responsible and sustainable use of these data can help improve everyday services, such as transport systems, health care, or energy efficiency, which represent core scenarios of a data-driven society, for the benefit of society.

This unique technological evolution also corresponds to new cybersecurity and data-protection risks and challenges, which could ultimately impact citizens' safety. Indeed, recent examples, such as the well-known Mirai attack in 2016¹ or the detection of hackable cardiac

devices in the United States,² highlight the strong need to regulate such an evolution to properly address cybersecurity and data-protection issues that are currently underestimated. These aspects were already mentioned in 2013 by Massachusetts Institute of Technology Prof. Alex Pentland, who initially coined the term *data-driven society*³ by discussing the need to define a New Deal on data to protect citizens through an adequate use of their data. In fact, we believe that current technological convergence must be supported through a legal framework to drive the responsible use of such technologies to guarantee fundamental rights of citizens.

The European Commission (EC) has recognized data-driven innovation as a “key driver of growth and jobs that can significantly boost European competitiveness in the global market” in “Towards a Common European Data Space.”¹⁶ However, the EC has also identified the need to develop a legal environment for data handling to address problems, such as free flow, access, and portability of personal data and interoperability in “Building a

Digital Object Identifier 10.1109/MSEC.2019.2939728
Date of current version: 25 September 2019

European Data Economy.”¹⁷ Addressing these aspects, the General Data Protection Regulation (GDPR), which came into force on 25 May 2018, is one of the main initiatives to regulate data processing not only in European territory but also globally. Together with the GDPR, other significant European efforts built on the 2013 European Union (EU) cybersecurity strategy, such as the Directive on Security of Network and Information Systems (NIS Directive),¹⁸ represent the strong conviction of considering cybersecurity and data protection as fundamental aspects to increase the confidence of citizens in a data-driven society. Apart from legislation efforts, different funding schemes for cybersecurity public-private partnership (cPPP) have been considered, as our digital society highly relies on the private domain’s products. One of the main cybersecurity initiatives is constituted by the European Cyber Security Organisation (ECSO), which aims to foster the harmonization between industry, academy, and governments for a more aligned cybersecurity strategy in the EU. ECSO represents the contractual counterpart to the EC for the implementation of the cPPP.

The scope of this article is to provide a technological perspective on the definition of regulatory efforts related to cybersecurity and data protection in the EU. We describe the existing related regulations that are in force and give examples of how trending technological drivers influence new regulatory attempts. Toward this end, we consider the framework depicted in Figure 1, which shows the relationship between such regulatory efforts and a data-driven society. This trend is realized through different data-driven services, which, in turn, are supported by a set of technological drivers. In particular, we base our analysis on three main technological drivers: the IoT, blockchain, and AI, which are fostered by different partnerships and alliances to ensure a harmonized development to avoid market fragmentation. Both technologies and alliances are promoting the realization of different data-driven services (e.g., smart energy or e-health) that are intended to improve the citizens’ quality of life. These services make up the data-driven society, which is governed in the EU through

different cybersecurity and data-protection regulatory efforts. Overall, we present a comprehensive overview of current legislation and regulatory work in Europe concerning a data-driven society.

Technological Drivers for a Data-Driven Society

To understand the impact of a data-driven society and the need for regulatory efforts, it is necessary to identify the set of technologies that are leading this trend. This section describes the technologies and the European initiatives promoting their development, as well as the challenges that could potentially imply the development of cybersecurity and data-protection policies.

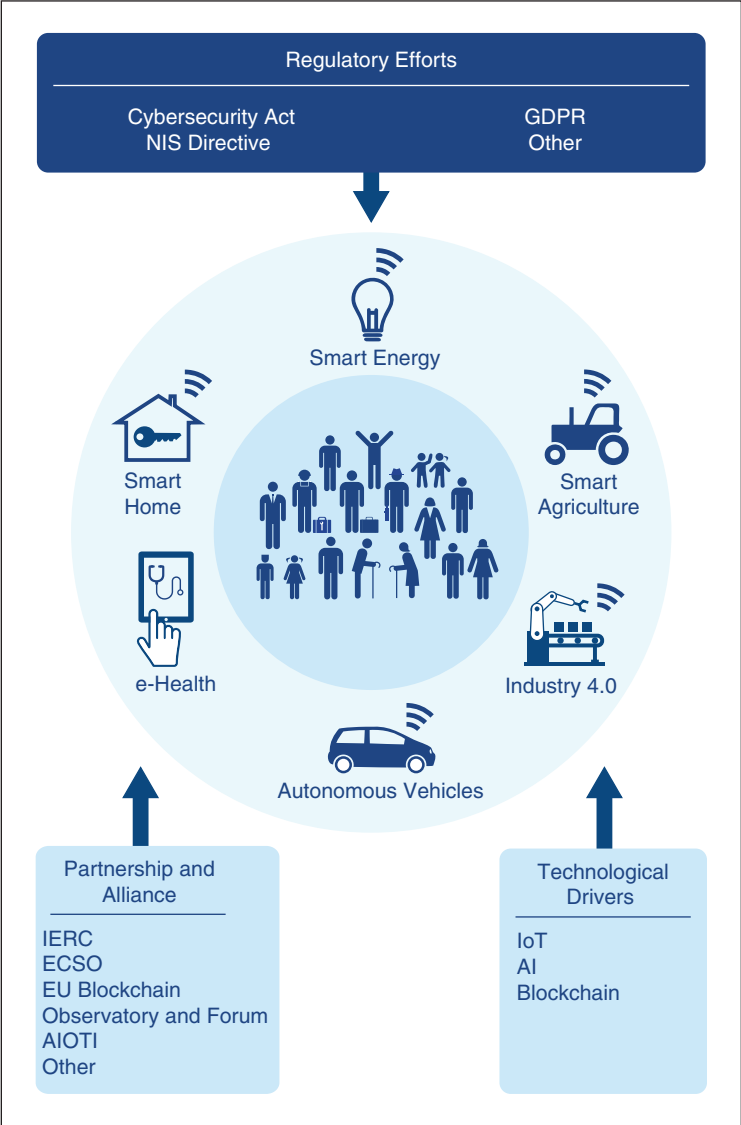


Figure 1. Fostering a regulated data-driven society. IERC: European Research Cluster on the Internet of Things; AIOTI: Alliance for Internet of Things Innovation; IoT: Internet of Things; AI: artificial intelligence.

Producing Data Through the IoT

The IoT⁴ promotes the trend toward a hyperconnected world encompassing different technologies to enable the integration of physical devices into the Internet. Therefore, the IoT is essential for realizing a data-driven society by allowing the data produced by these devices to be used for the development of innovative data-centric services. Indeed, in a hyperconnected world, data collected by different sensors in a certain local environment can be used to predict or explain global-scale processes more accurately (e.g., regarding energy efficiency). Today, the growth of the IoT is being driven by a plethora of technologies in the field of wireless communications and the advances in the development of embedded devices. One of the most important trends is represented by the development of 5G technology, which represents the natural evolution of the current 4G deployments. In the EU, the 5G Observatory is a joint initiative to monitor the development of this technology involving industry stakeholders and member states along with major international developments that could impact the European market.

Although the IoT concept was coined by Kevin Ashton in 1999, the landscape of solutions, technologies, and protocols making up the IoT is still fragmented and disharmonized. This fact can be a risk for the adoption of large-scale IoT deployments. In this sense, different pan-European initiatives have been established to promote an aligned vision of the IoT developments. In particular, the AIOTI was established in 2015 by the EC for the creation of a competitive European IoT market through interaction with industry and academia. Its activities are organized around different working groups, such as the WG4 IoT policy, which identifies potential issues and provides recommendations for the development of cybersecurity and data-protection policies in the IoT. Moreover, the IERC embraces different IoT research projects financed by the EU with the purpose of defining an aligned vision for the development of IoT technologies by considering the results obtained through such projects. As a main outcome, every year the IERC launches the Strategic Research and Innovation Agenda based on the discussion among the stakeholders involved in its activities.

Previous initiatives consider cybersecurity and data protection as key elements to be addressed for the sustainable development of the IoT. In fact, these concerns need to be addressed through joint efforts by the stakeholders involved. On the one hand, manufacturers of IoT devices must be aware of the principles of security by design to increase the confidence of citizens in the IoT deployments. Furthermore, these concerns must be addressed throughout the whole lifecycle of an IoT device to identify and react against potential attacks or vulnerabilities. On the other hand, the integration of everyday devices on the Internet means that citizens will be more exposed to

security and privacy risks. In fact, many of these devices will often operate on behalf of users sharing data without their explicit consent. Additionally, many IoT devices (e.g., small sensors or actuators) lack a user interface, which means that users could not be provided with the means to express their security and privacy preferences. Additionally, today's society suffers from a lack of training in and awareness of cybersecurity. As it has been demonstrated in recent attacks (e.g., Mirai), this can cause devices to be put on the market with default security configurations that are never changed during their lifecycle.

Sharing Data: The Emergence of Blockchain

Distributed ledger technologies and blockchains⁵ have been in the spotlight in recent years. The intrinsic nature of blockchains presents some interesting advantages. In fact, blockchains are based on the principle that there is no central entity that controls the system and that transactions between users can succeed without the need of having a trusted third party for verification. As a result, the transactions and the data found in the blockchain are in the control of the users' community. Furthermore, the transactions are tamperproof, immutable, and transparent. A ledger with all of the performed transactions is saved on all participating nodes and is thus distributed across the whole network; that is why it is called a *distributed ledger*. In each node, the ledger is stored in a special data structure composed of linked blocks, called *blockchain*.

Despite the advantages in terms of decentralization and immutability, blockchain systems present a number of challenges from cybersecurity and data-protection perspectives. The decentralized access model to public blockchains offers a certain level of anonymity to users, which has quickly turned into a feature exploited for illegal activities, especially with cryptocurrencies. Full decentralization is also a main concern regarding the governance of this type of system. The lack of embedded governance rules is a weakness that makes the decision process problematic when it comes to make decisions affecting all users. In this regard, the risk is that the choice is left to the developers or a restricted group of people, thus undermining all of the benefits coming from decentralization. The same issue can be highlighted looking at the consensus mechanisms of the current blockchain implementations. In proof-of-work systems, the consensus is performed by a small number of powerful miners, which could potentially impact the transaction verification process. The same could happen for proof-of-stake mechanisms, where there is no mechanism to guarantee the distribution of the process among all of the participants. In the case of private or permissioned blockchain systems instead, there is a third party or consortium that runs the system and controls the access. Therefore, the concept of decentralization here is relative.

In light of the aforementioned considerations, the main challenges are to guarantee the right balance between users' privacy and potential anonymity as well as between decentralization and the absence of rules and governance. In fact, if the transparency offered by blockchain is a guarantee for its auditability and verification of the transactions, it also represents a privacy threat, whereas transactions could be linked to each other and then lead to a real identity. At the same time, there is the risk of an excess of privacy, which could lead to online anonymity and then open the doors to illegal activities. Similarly, a total absence of trusted parties could lead to a system where the enforcement of rules or the protection of user rights become impracticable.

In Europe, the growing interest in blockchains has motivated the establishment of different initiatives and alliances. The EC launched the EU Blockchain Observatory and Forum in February 2018 to monitor the development of this technology, analyze trends, and address potential deployment issues. Its activities are arranged into two working groups. The Use Cases and Transition Scenarios Working Group focuses on the analysis and development of promising use cases, such as public sector and health applications. The Blockchain Policy and Framework Conditions Working Group is intended to analyze potential problems that motivate the development of regulatory efforts to encourage a large-scale deployment of blockchain. Additionally, the European Blockchain Partnership represents a joint effort between different member states for the establishment of a European Blockchain Services Infrastructure. This platform is intended to support the development of cross-border digital public services with a strong emphasis on cybersecurity and privacy aspects. In parallel with these initiatives, several EU countries have already developed attempts to integrate blockchain technology into their services. One of the main examples is Estonia, which founded the Estonian E-Health Foundation in 2016 to safeguard patients' health records using blockchain.

From Data to Information: The Explosion of AI

In recent years, AI⁶ has become a phenomenon that promises to redefine the way we live. The strong development of this technology is based on three fundamental pillars. First of all, the increase of computing power has enabled the use of existing AI techniques that could not be employed before. Furthermore, there is a significant increase in data availability, mostly due to the use of IoT technologies. As a result, AI algorithms can use huge amounts of data to provide more reliable and accurate results. Finally, the evolution of AI algorithms through the development of machine- and deep-learning techniques is strongly supported by academia and industry.

The development of AI is essential to transform such data into information that can be used to explain and predict global events, such as climate change, or to autonomously react against cybersecurity threats. Indeed, the development of AI techniques will foster the development of more autonomous systems, which add an additional level of complexity for the compliance with current regulatory efforts. Currently, AI techniques are already used in different areas of our daily lives, such as virtual personal assistants, or in scenarios, such as transport systems, health, or energy efficiency. Therefore, AI should be considered a key player for economic and social growth to foster a data-driven society.

Because of the expected impact, different European initiatives have emerged recently to join forces in the development of the AI technology. In particular, on 10 April 2018, 25 European countries signed a declaration of cooperation on AI to work jointly on social, economic, legal, and ethical aspects related to the research and deployment of AI. In December 2018, the EC launched "Coordinated Plan on Artificial Intelligence"¹⁹ to foster efficient cooperation in the development of AI in Europe through four key elements: investments, cross-border data availability, trustworthy and secure AI developments, and learning and training programs to make European citizens aware of the AI. In parallel with the development of this proposal, the High-Level Expert Group on AI (AI HLEG) was established with representatives from academia and industry to support the implementation of the European strategy on AI. The main purpose of AI HLEG is to advise the EC on the next steps for the development of AI, including recommendations for the development of policies on social, legal, and ethical issues related to AI. Another relevant initiative is represented by the AI4EU project that is intended to pave the way for an AI-on-demand platform for Europe. The project started in January 2019 with 79 partners in 21 countries.

The development of these initiatives highlights the broad dimension and impact related to the development of AI technologies. In an increasingly hyperconnected world, our devices (for example, smartphones or virtual personal assistants) often share our data without our explicit consent to provide more personalized services based on the analysis of such data. Although a piece of information may not represent a risk to a certain user, the application of AI techniques could help to infer more significant information that may compromise users' privacy. However, beyond security and privacy concerns, the deployment of AI approaches raises social, legal, and ethical issues. The development of AI techniques promises a more autonomous environment, which could entail a transformation of the job market. Furthermore, this trend also involves a challenge to determine the degree of responsibility of the actions caused by autonomous systems. For example,

in the case of transport systems, the unexpected or erroneous behavior of a vehicle could have an impact on the safety of citizens. Therefore, the current regulatory efforts are aimed at regulating not only the development of the technology itself but also the impact that technology can have on the economic and social sphere of future societies.

Cybersecurity and Data-Protection Regulatory Efforts in the EU

The challenges derived from previous technological drivers need to be addressed through the definition of a common legal umbrella to regulate a future data-driven society. In this section, we describe the main EU legal instruments in the cybersecurity and data-protection fields.

EU Laws

When talking about EU legal instruments, there is a need to refer to Article 288 of the Treaty on the Functioning of the EU, which defines their application and effects. The instruments described in this article are the following:

- *Regulation*: A regulation addresses all member states as well as natural and legal persons, and it is binding in its entirety and directly applicable.
- *Directive*: Directives are addressed to all or specific member states. They are binding with respect to the intended result. Member states have to transpose them into national law, and they can choose the form and methods.
- *Decision*: Directed to specific addressees (member states or natural and legal persons), a decision is binding in its entirety and directly applicable. In some cases, it does not specify an addressee, which can be established only from the content of the decision itself (e.g., decisions for amending treaty provisions⁷).
- *Recommendation and opinion*: Recommendations and opinions are nonbinding instruments that can be addressed to specific member states, EU bodies, or individuals. They allow EU institutions to express a view on a particular subject without placing the addressees under a legal obligation. For example, a recommendation can suggest a line of action, while an opinion can give an assessment of a certain situation and prepare the way for subsequent legally binding acts.

In addition to the aforementioned instruments, there are also resolutions, declarations, and action programs that are other forms of action to shape the EU legal framework. For example, a resolution helps to define the future work and a political direction, while an action program puts legislative programs and general objectives into practice. Finally, there are also different preparatory documents, such as white papers or communications from the EC, that set the views on a specific topic but have no

legal effect. However, they are very useful and helpful to identify the orientation and thinking on a given subject. The EC can also adopt delegated acts (i.e., nonlegislative acts of general and binding application that supplement or amend certain nonessential elements of a legislative act⁷).

Main Cybersecurity and Data-Protection Regulatory Frameworks

The definition of new regulatory cybersecurity and data-protection efforts must deal with the incessant technological evolution. The following EU laws represent the main regulatory European initiatives addressing such concerns.

NIS Directive

The NIS Directive is the main EU legislation on cybersecurity. In particular, it aims to foster a strategic cooperation among the member states to propose joint actions against potential cybersecurity incidents or risks in areas, such as transport, banking, or health care. The NIS Directive was initially proposed in 2013 to ensure a high level of network and information security at the EU level. It came into effect in August 2016 and set a period of 21 months so that the member states can transpose the directive into their national laws.

GDPR

The GDPR 2016/679 regulation²⁰ establishes the rules related to the access and processing of personal data to ensure a common data-protection framework in the EU. The GDPR defines a set of principles regarding the processing of personal data (Article 5), including lawfulness, fairness and transparency, purpose limitation, data minimization, accuracy, storage limitation, integrity and confidentiality, and accountability. Furthermore, it defines a set of rights for data subjects (the person associated to certain personal data), such as access, rectification, and erasure of their personal data, as well as different obligations and restrictions for data processing. The GDPR was adopted in 2016 and has been applicable since May 2018.

EU Cybersecurity Act

The EU Cybersecurity Act represents a set of measures to support a strong cybersecurity in the EU that was initially proposed in 2017. The proposal is based on two main aspects. First, it strengthens the European Network and Information Security Agency (ENISA) by granting a permanent mandate and reinforcing its financial human resources. Second, it aims to establish the first EU-wide cybersecurity certification framework for information and communications technology (ICT) products and services. The EU Cybersecurity Act was adopted on 12 March 2019 by the European Parliament.

Furthermore, “Regulation (EU) 910/2014 on Electronic Identification and Trust Services for Electronic Transactions in the Internal Market and Repealing Directive 1999/93/EC” (eIDAS Regulation)²¹ aims at regulating the electronic interactions among businesses, citizens, and public authorities. It is intended to ensure valid electronic identification and authentication ecosystems across all of the member states. In addition, the recent “Proposal for a Regulation Concerning the Respect for Private Life and the Protection of Personal Data in Electronic Communications and Repealing Directive 2002/58/EC (Regulation on Privacy and Electronic Communications)”²² is an ongoing effort to adapt the current ePrivacy Directive²³ to the recent advances in ICT by defining stronger rules for the protection of electronic communications.

Regulating Technological Drivers: Landscape and Challenges

In addition to the main legislative initiatives already described, new regulatory efforts have been proposed in recent years addressing specific aspects on the evolving technological landscape. In the context of the IoT, one of the first regulatory efforts was “Opinion 8/2014 on the Recent Developments on the Internet of Things,”²⁴ which was proposed by the Article 29 Data Protection Working Party. This proposal identified a set of challenges and risks on data protection in the IoT, including lack of control, quality of the user’s control, repurposing of original processing, or disclosure of behavioral patterns that could harm users’ privacy. It also includes a set of recommendations for the stakeholders involved, such as device manufacturers, social platforms, or third-party application developers. These guidelines embrace the need for privacy impact assessment, increasing users empowerment and the application of privacy-by-design and privacy-by-default principles. Furthermore, the “Advancing the Internet of Things in Europe”²⁵ document highlighted three main requirements to develop IoT in Europe: a single market for the IoT in the EU, a thriving IoT ecosystem for innovation, and a human-centric IoT, in which users are provided with the means to protect their personal data. In addition, “Directive 2014/53/EU on the Harmonisation of the Laws of the Member States Relating to the Making Available on the Market of Radio Equipment and Repealing Directive 1999/5/EC”²⁶ establishes a framework for making service radio equipment available on the market and putting it into the EU. Due to the nature of devices based on wireless communication technologies, this regulation must be strongly considered in IoT deployments.

Beyond these regulatory initiatives, the possibility of obtaining huge amounts of data from our surrounding environment represents a significant challenge to realize IoT developments compliant with the current legislation on cybersecurity and data protection. The GDPR

defines *personal data* as any information relating to an identified, or identifiable, natural person (data subject). Furthermore, it defines the roles of *data controller*, which determines the purposes and means of the processing of personal data, and *data processor*, which processes personal data on behalf of the controller. With the integration of physical devices into the Internet, many of these appliances (for example, wearables) are intended to manage and share personal data,⁸ such as health information.

The application of AI techniques could transform nonsensitive information (a priori) into personal data, especially through the use of machine-learning techniques. This could provoke a change in the original purpose of the personal data processing without explicit consent of the user. Indeed, the increasing development of autonomous systems (e.g., in the context of transport systems) is driven mainly by these techniques to build reliable data-driven decision-making processes with an increasing degree of automation. Furthermore, due to the dynamism and distributed nature of the IoT, the identification of the controller and processor roles could be challenging in some scenarios in which devices are acting on behalf of their owners.

Another challenge is related to the need to enforce lawfulness, transparency, and fairness. Toward this objective, the GDPR states the following:^{20,26}

Any processing of personal data should be lawful and fair. It should be transparent to natural persons.... The principle of transparency requires that any information and communication relating to the processing of those personal data be easily accessible and easy to understand, and that clear and plain language be used.

Due to the complex and opaque nature of some AI techniques, the realization of this principle could be challenging. Indeed, the lack of transparency and explainability is considered a major issue in the development of new algorithms.⁹ These aspects could have severe implications on users’ privacy.¹⁰

Related to the requirements and challenges with the GDPR compliance, in 2018 the EU Blockchain Observatory and Forum published the report “Blockchain and the GDPR,”¹¹ which describes some of the main obstacles to align blockchain developments with the main data-protection regulation in the EU. With the distributed nature of blockchain, the relationship between data processors and data controllers is more difficult to define. This is especially challenging in the case of public and permissionless blockchains (e.g., Bitcoin) where all participants can access and add blocks to the ledger. On the other hand, as mentioned in the section “Technological Drivers for a Data-Driven Society,” the transactions of a blockchain system are added to an immutable ledger that

cannot be modified. This could be a conflicting aspect with GDPR's Articles 16 and 17, especially if personal data are stored directly in the ledger. To mitigate this problem, the main option discussed today is the need for off-chain storage of personal data so that the blockchain is used to store cryptographic hashes to reference the data. Even in this case, the integration with encryption algorithms or privacy mechanisms (e.g., zero-knowledge proofs) is essential for the protection of personal data. Although this is easier to be accomplished in private and permissioned blockchains, new challenges may arise due to the need to interconnect different types of blockchains (e.g., to share information among the member states).

It should be noted that blockchain technology is being considered in new regulatory efforts, such as "Fin-Tech Action Plan: For a More Competitive and Innovative European Financial Sector,"²⁷ which was proposed in 2018. Beyond the use of blockchain in the financial sector, the increasing interest in this technology will foster the emergence of new initiatives to reinforce or complement the already mentioned EU Blockchain Observatory and Forum. Additionally, one of the main objectives of the already mentioned EU Cybersecurity Act is to create a framework of European cybersecurity certificates for products, processes, and services across the EU. This framework is intended to serve as a cornerstone of a more trustworthy Digital Single Market, in which the cybersecurity and data-protection level of ICT products could be assessed and compared by end consumers. To a certain extent, this effort could be considered analogous to the specification of the EU energy label ("Directive 2010/30/EU of the European Parliament and of the Council of 19 May 2010 on the Indication by Labeling and Standard Product Information of the Consumption of Energy and Other Resources by Energy-Related Products")²⁸ that is used currently in household appliances.

However, the development of this cybersecurity certification framework sets out significant challenges, including the heterogeneity, complexity, and cost of existing certification methodologies.¹² These problems can be aggravated in the case of IoT devices due to the inherent scale and dynamism of this technology. Indeed, IoT devices will typically be deployed in uncontrolled physical environments being more vulnerable to attacks and threats. Therefore, there is a need for certification approaches that keep the cybersecurity level of a certain device up-to-date throughout its lifecycle. This should also provide a visual representation of the cybersecurity level to be understandable by end users. These aspects are also considered by ECSO, which proposed the use of a metascheme¹³ to accommodate different methodologies under a common approach to overcome the heterogeneity of current schemes. However, the achievement of this framework will require multidisciplinary efforts from

different stakeholders, including device manufacturers and end users, as well as an increase in cybersecurity and data-protection awareness of our societies.

Cybersecurity and Data-Protection Policies in Data-Driven Services

As previously described, data-driven services represent the core of a data-driven society to improve the citizens' quality of life. This section describes some of the main regulatory efforts around three scenarios, which are being enriched through recent technological advancements.

Cooperative Intelligent Transport Systems

Current technological advances are fostering the evolution of typical transport systems into Cooperative Intelligent Transport Systems (C-ITS). On the basis of the Directive 2010/40/EU,²⁹ in March 2019, the EC adopted the delegated regulation C/2019/1789,³⁰ which contains new rules for the deployment of C-ITS on European roads. The goal of the regulation is to ensure a safe and interoperable deployment of ITS technology for both vehicles and road infrastructures in all member states by defining the technical requirements for the C-ITS stations and services. In particular, for the latter, it provides a list of C-ITS priority services that have to comply with the requirements of the corresponding C-ITS service profile (services are split into vehicle-to-vehicle and infrastructure-to-vehicle categories). It also defines the obligations of manufacturers, importers, and distributors.

One of the main concerns for C-ITS services is related to the amount of personal data that is handled and shared across the C-ITS platform. In this regard, the aforementioned regulation aims at limiting the amount of personal data sent to what is strictly necessary and avoids sending the identity of the driver or of the vehicle. To do this and guarantee the authenticity and integrity of the exchanged messages at the same time, the C-ITS platform has to be based on a public key infrastructure where pseudonym certificates (authorization tickets) frequently change. In addition to the certificate policy (whose authority is the EC at this moment), the regulation defines a security policy for the management of information security in the C-ITS platform. This policy requires the C-ITS station operators to operate their information security management system in accordance with the ISO/IEC27001 standard and a set of additional requirements (e.g., information classification and risk assessment).

e-Health

To cope with the current demographic changes and the aging of the population in Europe, the modernization of e-health and health-care services is essential. Indeed, the EU has proposed different initiatives in recent years to create a more secure and trustworthy digital ecosystem

for the storage and access of health data according to the current cybersecurity and data-protection legislation. Some of the challenges for a large-scale adoption of e-health systems were identified by “eHealth Action Plan 2012–2020: Innovative Healthcare for the 21st Century.”³¹ Despite the adoption of Directive 2011/24/EU³² on the application of patients’ rights in cross-border health care, the previous communication identified the need for interoperability and alignment with regulatory efforts in terms of data protection. These health-related data are intended to be shared and accessed through electronic health records (EHRs). Consequently, there is a need to define an interoperable approach to allow EHRs to be shared securely among member states. To accomplish this goal, the recent “Commission Recommendation 2019/243 of 6 February 2019 on a European Electronic Health Record Exchange Format”³³ was proposed based on the results derived from the Connecting Europe Facility program and the successful exchange of e-prescriptions between Estonia and Finland by using the eHealth Digital Service Infrastructure. This recommendation identifies the need to enable the secure access and sharing of EHR across borders, the compliance with GDPR regarding health data, and the use of secure electronic identification and authentication aligned with the eIDAS Regulation.

Energy

In recent years, the energy sector has also experienced a significant digital transformation in Europe. This transformation has been driven by the EU objectives for energy efficiency to combat climate change as well as the integration of technologies, such as the IoT, allowing a more flexible, dynamic, and user-centric energy market. In addition to the legislative efforts on energy efficiency, such as “Directive (EU) 2018/2002 on Energy Efficiency,”³⁴ cybersecurity has also been identified as a key component in this sector. In fact, “Commission Recommendation 2019/553 on Cybersecurity in the Energy Sector”³⁵ offers some guidelines to address such challenges, taking into account the real-time requirements, the risk of cascading effects, and the combination of legacy systems with new technologies. This recommendation is also based on the legislative results derived from the Clean Energy for All Europeans package, such as “Proposal for a Regulation on Risk-Preparedness in the Electricity Sector and Repealing Directive 2005/89/EC,”³⁶ which mandates member states to develop national risk-preparedness plans, including measures to address cyberattacks. Other related efforts are represented by “Proposal for a Regulation of the European Parliament and of the Council on the Internal Market for Electricity,”³⁷ which discusses the need for the development of new cybersecurity measures to protect the grid, or “Regulation (EU) 2017/1938

Concerning Measures to Safeguard the Security of Gas Supply,”³⁸ which requires risk assessment to be considered at regional and national levels.

Regulating a Data-Driven Europe: The Road Ahead

The EU maintains cybersecurity and data protection as some of its main priorities to be further developed in the coming years. Indeed, as described in “Proposal for a Regulation Establishing the Digital Europe Program for the Period 2021–2027,”³⁹ the EC will invest around €2 billion in cybersecurity for that period. The main goals are to increase cybersecurity equipment and infrastructure in the EU as well as to promote the development of skills and knowledge in cybersecurity. For that reason, the EC has recently proposed “Regulation Establishing the European Cybersecurity Industrial, Technology and Research Competence Center and the Network of National Coordination Centers.”⁴⁰ This initiative was announced to build a research and industrial ecosystem in the EU to manage the cybersecurity funds of the period 2021–2027. The objective is to encourage cooperation among stakeholders to take advantage of the knowledge of more than 660 cybersecurity expertise centers in all member states. Furthermore, the EC has invested more than €60 million to fund four pilot projects to establish and operate a pilot for such a network as well as to develop a common European cybersecurity research and innovation road map.

Toward the realization of a data-driven society, the evolving technologies will need to be aligned with the development of new cybersecurity and data-protection regulatory frameworks. In addition to overcoming obstacles in accordance with current legislation, the main technological drivers need to be adapted to the new regulatory efforts. For instance, new measures are foreseen to cover machine-to-machine communications that are considered an essential component of the IoT paradigm. A major policy initiative, considering the current version of the proposal, is represented by the upcoming e-privacy regulation that is introduced by “Proposal for a Regulation Concerning the Respect for Private Life and the Protection of Personal Data in Electronic Communications.”⁴¹ This directive deals with the confidentiality of communications and the protection of personal data in electronic communications by particularizing and complementing the GDPR. Therefore, the development of technologies and security protocols in the IoT should consider the application of suitable cryptographic techniques to be embedded in end devices, which is especially relevant and challenging in the case of resource-constrained devices and low-power wireless communication networks. To this end, the EC has recently proposed “Recommendation Cybersecurity of 5G networks,”⁴² which highlights the need for cooperation to develop secure 5G systems due

to the cross-border impact of risks and threats. This initial regulatory effort might evolve in the coming years according to the development of 5G scenarios to cover the corresponding cybersecurity and data-protection concerns. Toward this objective, one of the main initiatives is represented by the need for defining a 5G certification scheme according to the aforementioned EU Cybersecurity Act.

Furthermore, according to the analysis in the section “Regulating Technological Drivers: Landscape and Challenges,” the alignment of emerging technologies with regulatory efforts sets out significant challenges to be considered. As already mentioned, the intrinsic nature of blockchain could represent conflicting aspects with existing regulations, such as the GDPR. This is especially relevant in the case of public blockchains, in which (potentially sensitive) data are publicly accessible. Although the use of permissioned blockchains could mitigate such issues, the establishment of EU blockchain initiatives has been promoted in recent years to better understand the impact of this technology on the preparation of new regulations. As also described, similar efforts have been considered in the context of the IoT and AI. Nevertheless, the development of disruptive technologies, such as quantum computing,¹⁴ might need to be analyzed in the coming years to address the potential implications on existing cybersecurity and data-protection policies.

To encourage the development of technologies aligned with new and existing regulations, standardization is an essential component.¹⁵ Indeed, most current alliances and initiatives promote the harmonized development of new technologies to avoid a fragmented market. The EC has identified a set of strategic priorities for European standardization in support of legislation and policies in “The Annual Union Work Program for European Standardization for 2019.”⁴³ Such fragmentation could also lead to a diverging development regarding the cybersecurity and data-protection EU legislation. For that reason, new alliances are emerging, such as the International Association for Trusted Blockchain Applications (INATBA), which was announced in November 2018 by the EC. The role of INATBA is to complement and join efforts with other initiatives (e.g., the EU Blockchain Observatory and Forum) by promoting a global governance model for blockchain to support an interoperable development of standards in sectors, such as agriculture, health, or public services.

In fact, blockchain is considered one of the main disruptive technologies that needs standardized approaches to foster secure and interoperable large-scale deployments. This has motivated the establishment of several standardization initiatives, such as the ISO/TC 307, the IEEE P2418, or ITU-T Focus Group on Application of Distributed Ledger Technology standards. However, the development of different standards in the same direction could also represent a threat to developing

technological solutions compliant with cybersecurity and data-protection regulation. To overcome these obstacles, there is a clear need for cooperation among the stakeholders of a data-driven society, including industry, standardization bodies, and end users. This way, future technological developments will leverage the common legal umbrella that is represented by current and future cybersecurity and data-protection policies.

The realization of the so-called data-driven society must consider cybersecurity and data protection as core aspects to increase end users’ trust. In recent years, the unprecedented technological evolution required the development of new regulatory efforts to adapt current legislation to such advances. This work described the EU landscape of policies on cybersecurity and data protection by considering specific technological enablers. As a major challenge, the development of technological solutions compliant with such policies requires the involvement of different stakeholders to increase users’ awareness on cybersecurity and data protection. In addition to the need for adapting technological approaches to existing regulations, the implications derived from the emergence of new paradigms (e.g., 5G or quantum technologies) must be properly analyzed to ensure a regulated development of such technologies. In most cases, the compliance with existing and future legislation will not be exclusively determined by the technologies themselves but by the way in which these technologies will be used for the benefits of our society. ■

References

1. C. Koliass, G. Kambourakis, A. Stavrou, and J. Voas, “DDoS in the IoT: Mirai and other botnets,” *Computer*, vol. 50, no. 7, pp. 80–84, 2017. doi: 10.1109/MC.2017.201.
2. U.S. Food and Drug Administration, “Cybersecurity vulnerabilities affecting Medtronic implantable cardiac devices, programmers, and home monitors: FDA safety communication,” Mar. 21, 2019. [Online]. Available: <https://www.fda.gov/MedicalDevices/Safety/AlertsandNotices/ucm633960.htm>
3. A. Pentland, “The data-driven society,” *Scientific Amer.*, vol. 309, no. 4, pp. 78–83, 2013. [Online]. Available: <https://www.scientificamerican.com/article/how-big-data-can-transform-society-for-the-better/>
4. A. Al-Fuqaha, M. Guizani, M. Mohammadi, M. Aledhari, and M. Ayyash, “Internet of Things: A survey on enabling technologies, protocols, and applications,” *IEEE Commun. Surveys Tut.*, vol. 17, no. 4, pp. 2347–2376, 2015. doi: 10.1109/COMST.2015.2444095.
5. G. Zyskind, O. Nathan, and A. S. Pentland, “Decentralizing privacy: Using blockchain to protect personal data,” in *Proc. 2015 IEEE Security and Privacy Workshops*, pp. 180–184.

6. S. Russell and P. Norvig, Eds., *Artificial intelligence: A Modern Approach*. Upper Saddle River, NJ: Pearson, 1995.
7. K.-D. Borchardt, "The ABC of EU law," Publications Office of the European Union, 2018. [Online]. Available: <https://publications.europa.eu/en/publication-detail/-/publication/5d4f8cde-de25-11e7-a506-01aa75ed71a1>
8. J. Singh, C. Millard, C. Reed, J. Cobbe, and J. Crowcroft, "Accountability in the IoT: Systems, law, and ways forward," *Computer*, vol. 51, no. 7, pp. 54–65, 2018. doi: 10.1109/MC.2018.3011052.
9. A. Adadi and M. Berrada, "Peeking inside the black-box: A survey on explainable artificial intelligence (XAI)," *IEEE Access*, vol. 6, pp. 52,138–52,160, Sept. 2018. doi: 10.1109/ACCESS.2018.2870052.
10. B. C. Stahl and D. Wright, "Ethics and privacy in AI and big data: Implementing responsible research and innovation," *IEEE Security Privacy*, vol. 16, no. 3, pp. 26–33, 2018. doi: 10.1109/MSP.2018.2701164.
11. T. Lyons, L. Courcelas, and K. Timsit, "Blockchain and the GDPR," The European Union Blockchain Observatory and Forum, 2018. [Online]. Available: https://www.eublockchainforum.eu/sites/default/files/reports/20181016_report_gdpr.pdf
12. S. N. Matheu, J. L. Hernández-Ramos, and A. F. Skarmeta, "Toward a cybersecurity certification framework for the Internet of Things," *IEEE Security Privacy*, vol. 17, no. 3, pp. 66–76, 2019. doi: 10.1109/MSEC.2019.2904475.
13. European Cyber Security Organisation, "European Cyber Security Certification: A meta-scheme approach v1.0," 2017. [Online]. Available: <http://www.ecs-org.eu/documents/uploads/european-cyber-security-certification-a-meta-scheme-approach.pdf>
14. M. Mosca, "Cybersecurity in an era with quantum computers: Will we be ready?" *IEEE Security Privacy*, vol. 16, no. 5, pp. 38–41, 2018. doi: 10.1109/MSP.2018.3761723.
15. European Commission, "2018 rolling plan for ICT standardization released," 2018. [Online]. Available: https://ec.europa.eu/growth/content/2018-rolling-plan-ict-standardisation-released_en
16. European Union, *Communication From the Commission to the European Parliament, the Council, the European Economic and Social Committee and the Committee of the Regions "Towards a Common European Data Space,"* COM/2018/232 final, June 18, 2018.
17. European Union, *Communication From the Commission to the European Parliament, the Council, the European Economic and Social Committee and the Committee of the Regions "Building a European Data Economy,"* COM/2017/09 final, May 22, 2019.
18. European Union, *Directive (EU) 2016/1148 of the European Parliament and of the Council of 6 July 2016 Concerning Measures for a High Common Level of Security of Network and Information Systems Across the Union*, OJ L 194, 19.7.2016, pp. 1–30.
19. European Union, *Communication From the Commission to the European Parliament, the European Council, the Council, the European Economic and Social Committee and the Committee of the Regions Artificial Intelligence for Europe*, COM/2018/795 final, Dec. 7, 2018.
20. European Union, *Regulation (EU) 2016/679 of the European Parliament and of the Council of 27 April 2016 on the Protection of Natural Persons With Regard to the Processing of Personal Data and on the Free Movement of Such Data, and Repealing Directive 95/46/EC (General Data Protection Regulation) (Text With EEA Relevance)*, OJ L 119, 4.5.2016, pp. 1–88.
21. European Union, *Regulation (EU) No 910/2014 of the European Parliament and of the Council of 23 July 2014 on Electronic Identification and Trust Services for Electronic Transactions in the Internal Market and Repealing Directive 1999/93/EC*, OJ L 257, 28.8.2014, pp. 73–114.
22. "Proposal for a Regulation of the European Parliament and of the Council concerning the respect for private life and the protection of personal data in electronic communications and repealing Directive 2002/58/EC (Regulation on Privacy and Electronic Communications)," COM/2017/010 final, 2017/03 (COD), Mar. 2017.
23. European Union, *Directive 2002/58/EC of the European Parliament and of the Council of 12 July 2002 Concerning the Processing of Personal Data and the Protection of Privacy in the Electronic Communications Sector (Directive on Privacy and Electronic Communications)*, OJ L 201, 31.7.2002, pp. 37–47.
24. Article 29 Working Party, "Opinion 8/2014 on the recent developments on the Internet of Things," 14/EN WP 223, Sept. 16, 2014.
25. European Commission, "Staff Working Document: Advancing the Internet of Things in Europe (accompanying the document 'Communication from the Commission to the European Parliament, the Council, the European Economic and Social Committee and the Committee of the Regions Digitising European Industry: Reaping the Full Benefits of a Digital Single Market COM(2016) 180,'" SWD/2016/0110 final, Dec. 5, 2016.
26. European Union, *Directive 2014/53/EU of the European Parliament and of the Council of 16 April 2014 on the Harmonisation of the Laws of the Member States Relating to the Making Available on the Market of Radio Equipment and Repealing Directive 1999/5/EC Text With EEA Relevance*, OJ L 153, 22.5.2014, pp. 62–106, Sept. 11, 2018.
27. European Union, *Communication From the Commission to the European Parliament, the Council, the European Central Bank, the European Economic and Social Committee and the Committee of the Regions FinTech Action Plan: For a More Competitive and Innovative European Financial Sector*, COM/2018/0109 final, Mar. 8, 2018.
28. European Union, *Directive 2010/30/EU of the European Parliament and of the Council of 19 May 2010 on the Indication by Labelling and Standard Product Information of the*

- Consumption of Energy and Other Resources by Energy-Related Products (Text With EEA Relevance)*, OJ L 153, 18.6.2010, pp. 1–12, May 19, 2010.
29. European Union, *Directive 2010/40/EU of the European Parliament and of the Council of 7 July 2010 on the Framework for the Deployment of Intelligent Transport Systems in the Field of Road Transport and for Interfaces With Other Modes of Transport (Text With EEA Relevance)*, OJ L 207, 6.8.2010, pp. 1–13, Jul 7, 2010.
 30. European Union, *Commission Delegated Regulation (EU) .../... Supplementing Directive 2010/40/EU of the European Parliament and of the Council With Regard to the Deployment and Operational Use of Cooperative Intelligent Transport Systems*, C/2019/1789 final.
 31. European Union, *Communication From the Commission to the European Parliament, the Council, the European Economic and Social Committee and the Committee of the Regions eHealth Action Plan 2012–2020—Innovative Healthcare for the 21st Century*, COM/2012/0736 final*, Dec. 7, 2018.
 32. European Union, *Directive 2011/24/EU of the European Parliament and of the Council of 9 March 2011 on the Application of Patients' Rights in Cross-Border Healthcare*, OJ L 88, 4.4.2011, pp. 45–65, March 9, 2011.
 33. European Union, *Commission Recommendation (EU) 2019/243 of 6 February 2019 on a European Electronic Health Record Exchange Format (Text With EEA Relevance)*, C/2019/800 OJ L 39, 11.2.2019, pp. 18–27, Feb. 6, 2019.
 34. European Union, *Directive (EU) 2018/2002 of the European Parliament and of the Council of 11 December 2018 Amending Directive 2012/27/EU on Energy Efficiency (Text With EEA Relevance)*, PE/54/2018/REV/1, OJ L 328, 21.12.2018, pp. 210–230, Dec. 11, 2018.
 35. European Union, *Commission Recommendation (EU) 2019/553 of 3 April 2019 on Cybersecurity in the Energy Sector (Notified Under Document C(2019) 2400)*, C/2019/2400, OJ L 96, 5.4.2019, pp. 50–54, Apr. 3, 2019.
 36. European Union, *Proposal for a Regulation of the European Parliament and of the Council on Risk-Preparedness in the Electricity Sector and Repealing Directive 2005/89/EC*, COM(2016) 862 final 2016/0377 (COD), 2016.
 37. European Union, *Proposal for a Regulation of the European Parliament and of the Council on the Internal Market for Electricity*, COM (2016) 861 final, 2016/0379 (COD), 2016.
 38. European Union, *Regulation (EU) 2017/1938 of the European Parliament and of the Council of 25 October 2017 Concerning Measures to Safeguard the Security of Gas Supply and Repealing Regulation (EU) No 994/2010 (Text With EEA Relevance)*, OJ L 280, 28.10.2017, pp. 1–56, Oct. 25, 2017.
 39. European Union, *Proposal for a Regulation of the European Parliament and of the Council Establishing the Digital Europe Programme for the Period 2021–2027*, COM/2018/434 final, 2018/0227 (COD), 2018.
 40. European Union, *Proposal for a Regulation of the European Parliament and of the Council Establishing the European Cybersecurity Industrial, Technology and Research Competence Centre and the Network of National Coordination Centres*, COM(2018) 630 final, 2018/0328 (COD), 2018.
 41. European Union, *Proposal for a Regulation of the European Parliament and of the Council Concerning the Respect for Private Life and the Protection of Personal Data in Electronic Communications and Repealing Directive 2002/58/EC (Regulation on Privacy and Electronic Communications)*, COM/2017/010 final, 2017/03 (COD), Mar. 2017.
 42. European Union, *Commission Recommendation (EU) 2019/534 of 26 March 2019 Cybersecurity of 5G Networks*, C/2019/2335, OJ L 88, 29.3.2019, pp. 42–47.
 43. European Union, *Communication From the Commission to the European Parliament, the Council, the European Economic and Social Committee and the Committee of the Regions, the Annual Union Work Programme for European Standardisation for 2019*, COM/2018/686 final, Oct. 11, 2018.
-
- José L. Hernández-Ramos** is a scientific project officer at the Joint Research Centre of the European Commission. His research interests include the application of security and privacy mechanisms in the Internet of Things and transport systems scenarios. Hernández-Ramos received a Ph.D. in computer science from the University of Murcia, Spain. He has served as a technical program committee and chair member for different international conferences. Contact him at jose-luis.hernandez-ramos@ec.europa.eu.
-
- Dimitris Geneiatakis** is a scientific project officer at the Joint Research Centre of the European Commission. Geneiatakis received a Ph.D. in information and communication systems security from the University of the Aegean, Greece. Contact him at dimitrios.geneiatakis@ec.europa.eu.
-
- Ioannis Kounelis** is a scientific officer at the Joint Research Centre of the European Commission. His research interests include mobile security, blockchain technologies, and secure system design. Kounelis received a Ph.D. in computer security from the KTH Royal Institute of Technology, Sweden. Contact him at ioannis.kounelis@ec.europa.eu.
-
- Gary Steri** is a researcher at the Joint Research Centre of the European Commission. Steri received his Ph.D. in computer science from the University of Cagliari, Sardinia, Italy, in 2011. Contact him at gary.steri@ec.europa.eu.
-
- Igor Nai Fovino** is a scientific project manager at the Joint Research Centre of the European Commission. Fovino received his Ph.D. in computer security from the Università degli Studi di Milano, Italy. Contact him at igor.nai-fovino@ec.europa.eu.



Understanding the Information Environment to Win the Next Conflict Without Firing a Shot

Michael Klipstein, Austin Minter, and Jeremiah Pittman | Army Cyber Institute

Information and communication technology has become a powerful influencing tool to sow discord, sway sentiment, and purport cause for actions. We examine the holistic information space 10 years out to better understand how the information environment will interact with society.

In today's world, smartphones are replacing desktops, laptops, and tablets as the default entry point to the Internet. These devices promote growing access to and viewership of nontraditional online news sources that tailor to the bias of the individual viewer; a rush to move and manipulate data online in the cloud; and a proliferation of connected devices in our lives. As society has digitized, what used to be distinct domains of warfare—cyberwarfare, electronic warfare, and information operations—have converged. Information is delivered via electronic means to digital devices, which are vulnerable to cyberattacks. This reality has changed the way people receive data, perceive the world, and make decisions.

Powered by the megatrends just described, key indications have emerged: First, adversary narratives will negatively portray the United States to diminish its prestige and influence on the global stage. Second, the Internet of Things (IoT) will continue to proliferate and will be heavily influenced by China's advancement of standards for these platforms. Third, cultural division will increase as news and information sources become tailored for

the viewer. Finally, countries will seek to move combat "upstream" in the information space in an attempt to avoid kinetic conflict.

Catching a Glimpse of the Future Now

Here we examine the aforementioned predictions: that the U.S. image and influence will be marginalized globally, China will take on a leadership role and have a substantial impact on the development of the IoT, curated information sources will increase sectarianism and cultural division, and adversaries will place an increased emphasis on combat in the information space to avoid kinetic conflict. These predictions are built upon the current operational environment but are considered here in the extreme, if the current trajectory continues. We agree that some of the items discussed are beginning to occur but not in their full capacity. Although the four items are distinct, these actions are mutually supportive of one another, and their danger magnifies in combination. Information is vulnerable to cyberoperations where it may be denied or manipulated, to information operations that manipulate or distort data and context, and to electronic warfare where information may be denied, manipulated, or combined to purposely inject information to a user or group.

U.S. Global Influence Is Marginalized As Adversaries Illuminate Its Lack of Resolve to Maintain Superiority

The United States will continue to leave itself vulnerable in the information space if it lacks a cohesive prescriptive global strategy and operational narrative to guide and communicate the nation's efforts and engagements, particularly with its allies and partners. Reactive strategy lends itself to changing national objectives and, therefore, partner forces losing priority as administrations change. Previous U.S. administrations have ignored answering the questions in the Powell Doctrine, compounding the problem by entering into foreign conflicts without outlining strategy and defining success in the operation.

Adversaries currently weave a tapestry of narratives to diminish U.S. prestige and to attempt to widen schisms with Western allies and partners using multiple tools. Russia (and the Soviet Union) has long used propaganda and other irregular warfare activities as an instrument of national power.¹ For years now, Russia has been setting the stage for conflict with the United States, using its control and influence over the Russian media and other news outlets to propagate the ideas that the United States is the aggressor and that Russia is only protecting its citizens and those of its allies.¹⁻³ In the economic space, China's "One Belt, One Road" initiative has played on the perception that Africa has been exploited by the Western financial system. This narrative has increased China's influence in Africa, helping to displace U.S. and Western dominance. China's "infrastructure first" strategy sends economic narratives that showcase how Huawei-constructed networks cost as much as 30% less than non-Chinese infrastructures due to China's subsidies.⁴ These economic actions and messages have allowed China to seize an advantage in Africa and developing nations seeking infrastructure support. We see China attempting to influence South American nations with the allure of inexpensive infrastructure.

Adversaries can and will take advantage of the United States if it turns its back on allies and friends. Even though Georgia had been in talks with the West for admittance to NATO, the international community largely stood by during the Russia-Georgia war in 2008. Scholars have pointed toward U.S. inaction with regard to Georgia as a leading contributor to Russia's invasion of Ukraine and annexation of Crimea six years later in 2014.^{5,6}

Currently, public discourse over the U.S. withdrawal of forces from Syria in the fight with ISIS is ongoing. Compounding this problem is the presence of Russian military forces in Syria acting on the behest of the Assad government since 1971, while the United States has backed rebel forces. Leaving Syria and allowing the Turks to crush the Kurdish partner forces would enable Russia, Iran, and Hezbollah to fill the power vacuum⁷ and would send a powerful message to potential strategic partners.

If the United States continues without a cohesive prescriptive global strategy and associated narrative, nations and nonstate actors with centralized decision-making authority will continue to use audacity and national will to outpace the decision making of the United States and to depict military restraint as weakness. The restraint shown by U.S. political decision makers could be portrayed as an unwillingness to project force.

Economically, the U.S. economy will be damaged as its prestige falters and competitors seek to promote themselves on the global stage and build relations with developing and established nations. We see this already with China expanding its influence through the String of Pearls theory along with the IoT and 5G initiatives discussed later in this article. As U.S. prestige and influence wane on the global stage, competitors filling the power void will seek economic advantages and nonadvantageous partnership. Economic impacts will lead to social changes across the international community. Adversarial or competitor cultures and influence will rise in locations that once would have sought to emulate the United States.

Information and narratives about the United States will be slanted to marginalize and promote an image of weakness and unwillingness to commit to defending allies, partner nations, or free people. Additionally, statements and messaging from the United States will be manipulated to provide "evidence" that the U.S. narrative is false. As other nations promote their presence on the global stage through political actions, economic development, and military action, a committed information campaign will ensue to promote the idea of U.S. weakness and lack of resolve.

Niche nonstate actor groups such as ISIS will continue to microtarget audiences within the United States to sow discontent and urge violence in the name of religious causes. We observe some of this now with ISIS creating recruitment videos in more than 20 languages with tailored messages for targeted demographics.²² Increased use of social media and microtargeting will allow future nonstate actors to capitalize on the virality of messages within targeted population segments to splinter a population and, possibly, to incite domestic violence.

The IoT Will Continue to Proliferate and Be Led by China's Advancement of Standards for These Platforms

China employs a top-down, coordinated effort to lead the world in IoT technology. China has about 500 smart city pilot projects: "Beijing, Shanghai, Guangzhou, Hangzhou, and other large cities have established an extensive database and sensor networks to collect, store, and analyze information related to transportation, electricity, public safety, and environmental factors."⁸ However, China's dominance as a production center has more wide-ranging ramifications as we look at IoT and

computing peripherals used in conjunction with cloud storage and manipulation of data.

With smartphones becoming more popular for Internet access than desktops in 2016 and laptops in 2018, mobile phones will continue to be the dominant Internet access platform. Similarly, with smartphones increasing in size and computational power, these devices will continue to become interconnected with other IoT devices and peripherals in our lives, in the home, car, and work. As smartphones become a more significant presence in computing because of size, computational power, and convenience, combined with the proclivity for storing and manipulating data in cloud environments,⁹ China will become the de facto leader in data and increasingly in computation. This will be a result of the combination of phones and the growing Chinese population. The sheer impact of China's manufacturing and purchasing power will skew all technological norms in favor of China.¹⁰

Political and military organizations and structures are intertwined in China. Due to the interconnectedness of China's civil-military relations, the intelligence and cyber units of the Chinese People's Liberation Army could have access to all of its IoT devices worldwide. The close ties between the government and private companies will also allow China to discover new IoT vulnerabilities that can be leveraged to quickly secure IoT devices against competing intelligence agencies. Many research laboratories are known to directly benefit Chinese military intelligence and cyberoperations units. For example, Beijing Key Laboratory of IoT Information Security Technology works directly with the Chinese military. With the proliferation of Chinese-made IoT devices, consumers are collecting, sharing, storing, and transmitting troves of data that could be susceptible for use by China's government. China's national security laws currently set a precedent for leveraging information and communications technology for national security uses. The language of these laws, though vague in how or when they will be used, explicitly allows Chinese authorities to inspect IT systems and data at will.⁸

Additionally, the Chinese National Intelligence Law compels Chinese and foreign citizens, businesses, and organizations to support, inform, and cooperate with intelligence efforts. This legal requirement sets conditions for Chinese national intelligence collection globally. This collection can be sourced from IoT devices, Chinese-made cellular phones or telecommunication networks and devices, and consumer products that may connect to the Internet such as home cameras. This long-term effort will create a sensor network of devices across homes, businesses, and governmental locations facilitating information collection and, potentially, injection of ideas into target minds.

Economically, China seeks to influence the world to adopt pro-China standards for IoT and 5G technology through both international standards and regional

influence initiatives. The U.S. IoT market is expected to reach a market value of US\$421 billion by 2021, while the Chinese IoT market is expected to reach US\$264 billion by 2020 with year-over-year growth expected to continue at rates of 20–30%. The United States and allied nations currently lead overall international market share in IoT technology, but China is quickly gaining and bringing the advantages of its "market size, production capacity, and government support."⁸ Many foreign competitors want to compete in the Chinese market but are blocked or face technology transfer if they enter China due to Chinese business law. China's government-led, predatory market actions and support for its IoT companies threaten the freedom and opportunities in IoT markets. China is one the most prolific attendees to international technology standards organizations, sending nearly the highest number of delegates to all meetings. Regionally, China is leveraging its Belt and Road Initiative to influence project partner nations to adopt Chinese standards and use Chinese Internet communication technology.⁸ Since China has the largest potential market for IoT technology, they bring considerable leverage to any standards discussion. This already substantial leverage is magnified when partnered with China's top-down coordination with Chinese companies to undersell foreign competitors in this space.⁸

Socially, China will enjoy a monopoly on information and the perception of reality within its borders with a broader control of data and perception of reality abroad. Citizens and visitors alike will be monitored through closed-circuit television (CCTV) networks monitoring streets and other public areas. CCTV is already connected to artificial intelligence (AI) and machine learning, allowing for the description of a person through estimated height, weight, age, and clothing worn, allowing for correlation against databases to identify the individual in question.¹¹ These domestic infrastructures will be exported globally and will be discussed with information.

In terms of infrastructure, by 2025, experts expect 13.8 billion industrial IoT devices, with China accounting for 4.1 billion of those. Due to industrial products leading all industries in IoT adoption at 45%, China is perched to dominate the optimization of industrial processes worldwide. China, and in particular Huawei, is leading the world in 5G design and production, using AI and data analytics to optimize the industrial sector.¹² China already has "ten times the 5G sites per person as in the United States."⁸ This telecommunications backbone sets the stage for IoT devices to be useful. Specifically tailored to IoT devices, Chinese telecom companies have installed more than 710,000 specific narrow-band IoT base stations.⁸ Compounding China's advantage is the creation of a fiber infrastructure spanning Asia that will allow only Huawei 5G device connections.¹³ This infrastructure project will bring economic advantage for nations wishing to connect to the overland fiber to

mitigate fears of the United States tapping undersea fiber cables. Additionally, this project's requirement for Huawei devices creates a growing company hegemony that will service almost 70 countries and can service 40% of the world's economic output.¹³ With the Belt and Road initiative bringing high-speed fiber connections to more than 800 million homes in China alone, the country stands to be the leader in data access and manipulation online.

With its already robust industrial and manufacturing economy, it only makes sense that China would pursue optimization through the IoT to cut costs and improve efficiency. The Chinese 5G infrastructure can dynamically create virtual private networks of varying speeds and capacity. When all these data are combined with China's ballooning AI capabilities, China will have the potential to produce the most efficient processes because they will have collected and analyzed the most data. China has already demonstrated predatory market practices in dominating the IoT space; one real danger could be that when foreign nations adopt Chinese industrial IoT, those systems could be purposefully manipulated to ensure China's economic preeminence.

China's dominance of this space has been synchronized over many years, though their crafting of enduring and long-range strategies within their National Congress, championing adoption of international standards, and sheer percentage of global market consumers. These conditions allow China to enjoy a dominant position in the global economy and infrastructure environment. Although China's top-down model of IoT technology promotion incurs significant excess costs, China is committed to leading in the IoT industry because they see this effort as critical to securing both long-term economic benefits and the national security benefits their intelligence community can leverage if they dominate international IoT markets.⁸

In the information space, China will continue to control the flow and narrative presented, both internally and externally. Using IoT devices, information collection, analysis, and collation will occur at unprecedented levels when coupled with AI and machine learning. China currently employs large-scale facial recognition for purposes as diverse as pedestrian law enforcement and purchasing fast food and consumer goods.¹¹ This always-monitoring capability overlaid with IoT data collection and analysis along with the social credit score¹⁴ provides China the ability to track a person in the physical or online world. As China continues to advance IoT standards, a global information collection network becomes a possibility.

Cultural Division Will Increase as News and Information Sources Become Tailored for the Viewer

The rapid pace of technological change has reduced the time required to mobilize people, coordinate efforts, and

impact an environment. Communication infrastructure, mass media, and society's dependence on technology make it difficult to deny people access to real-time communications, imagery, and video. This technological change has created a virtual world in which the physical world becomes aware and sentient of everything going on at one instant in time. In this virtual world, geography and transportation no longer limit the space and awareness of things. This enables the warp-speed mobilization of humanity and ends with societies becoming divided, mobilizing transnationally to influence whenever stimulated or led.

The core of this technological development revolves around near-omnipresent access to the Internet. The advent of increasingly inexpensive devices in one's pocket capable of storage and Internet use has allowed access to become ubiquitous and has facilitated greater online dependence, resulting in one in five Americans getting their news more from social media than print media.¹⁵

Online news sources have created a phenomenon in which nontraditional sources have grown in acceptance and viewership due to integration and promotion through social media platforms. In this phenomenon, the race to become the first or most sensational to report has quickened the news cycle for verification, particularly among nontraditional news providers. An example is the reporting of then-President Obama being injured from explosions at the White House,¹⁶ resulting in a flash crash of the Dow. With the degradation of journalistic standards, nontraditional news providers are free to publish with impunity. Furthermore, fractured news sources facilitate curated venues for resonating with consumers' values and grievances, playing on emotions and stoking discontent with the current situation or issue.

Unencumbered Internet access will enable groups of people with weak local reference to find others with common values and shared grievances to coalesce around a narrative or perspective that can easily translate to action. The world realized this potential application during the Arab Spring and the mobilization of transnational terror threats such as ISIS. Reinforced by confirmation bias, Internet news consumers thus seek the perspective that more aligns to their personal "truth."

Politically, online viewership is diluting mainstream media reporting and, combined with confirmation bias, will lead to viewers continuing to select news and information outlets that speak to their biases and prejudices, causing further societal schisms. As botnets and trolls continue to disseminate narratives supporting or demonizing groups, internal strife will be magnified, and infighting will commence. Outside entities, such as nation-states, will continue to capitalize on this dividing force to weaken national identity, allowing for envelopment of lands, peoples, and natural resources.¹⁷ Social media platforms, and therefore, nontraditional news and information outlets, will continue

to flourish as governments and organizations use social media to connect with and inform their constituents.

Militarily, narratives will promulgate before operations through social media platforms and will then be amplified by nontraditional news and information outlets on social media. This phenomenon is exemplified by ISIS promoting its “overwhelming” victories over the Iraqi government using the hashtag #AllEyesOnISIS.¹⁸ This narrative preceding ISIS forces carried more force than actual ISIS elements, causing Iraqi forces to flee.

Socially, further friction and division will occur between societal groups based on the prejudice du jour. Just as genocide in Rwanda in 1990–1994 was based on conflict between the Hutu and Tutsi, where both groups used irrelevant and often untrue facts or events to further stoke conspiracy and hatred, information will become more skewed based on viewership desires and beliefs. Botnets promoting and reinforcing agendas and supporting narratives will continue across social media with even the most isolated locales having access to the Internet and, subsequently, “truth.” In this information domain, nation-states will work to fight and win conflicts without firing shots, winning through ideas instead of kinetic force.

Combat With Adversaries Will Occur Farther Upstream in the Information Space to Avoid Kinetic Conflict

Information has long been used to disrupt adversaries, usually individual leaders, through pamphlets, leaflets, or transmitted media such as radio or television. The mass populace may have witnessed the message, but the intended recipient was a leader. The ability of one person or group to influence people was proportionate to the resources they could apply. The more resources, the more influence they could have. Currently, one person or one group can influence as many people as they want, because technical know-how has all but eliminated proportionate scaling costs. Examining the previous three predictions leads to this last claim becoming the emerging norm, the output of the previous three predictions singularly or in combination.

With the ever-more-interconnected world of devices and people, all people will be a target. The targets of information messaging will be not leaders but populations. We see this now with Russian interference in voting for Brexit and the 2016 U.S. presidential election.¹⁸ Projecting forward Gerasimov’s ideas for both military and nonmilitary applications of information in conflict,^{19,20} this trend will escalate. Countering and proliferating ideas as a precursor to friction or kinetic conflict will increase, as the attribution of these actions is difficult. Maintaining deniability as a nation-state while fermenting division in a group will be used to legitimize invasions, reduce internal political risk of a coup, and prevent adversaries from gathering national will for political or military action. As this capability becomes more

nuanced and understood, campaign plans spanning years will emerge to set conditions to attain national objectives. As the Institute for the Future states in their 2018 report, “Worst of all, since these platforms appear so interactive and democratic, we experience this degradation of our social processes as a form of personal empowerment.”²¹

Politically, information warfare can achieve strategic objectives without the expenses and consequences of projection of real military power. Using information warfare and avoiding physical conflict reduces the risk to political careers by avoiding the consequences and attribution of casualties. Political leaders have multiple concepts to diffuse any connection to information warfare campaigns. These operations offer deniability, as information warfare tends to use real interest groups and leverages seeds of truth or biases in most campaigns. Leaders can deny involvement in such a campaign, instead blaming information on real interest groups.

The current landscape of weaponized social media platforms to execute information warfare campaigns is extremely complex. Automated social media bots and AI make it increasingly difficult for the public to understand and follow the technical nuances used in larger information warfare campaigns. Targeted messaging to multiple groups has become easier. ISIS has demonstrated how to tailor messages to groups, including using sign language.²² Technological advancements will continue to make messaging easier, faster, more secure, and nonattributable. Adversaries will choose contentious topics regarding race, gender, national origin, religion, liberal versus conservative ideology, abortion, sexual preference, ethnicity, or immigration. Any topic that has caused division and foments strong emotional responses for society is a potential candidate for a new information warfare campaign or a chance to falsely promote and magnify a small story.

Militarily, widespread or targeted information warfare campaigns will occur against critical military units or military leaders. An adversary will cause tremendous personal discomfort to many leaders by exposing the contents of their personal email, whether real or fabricated. Specific leaders could be “character assassinated” by adversaries planting child pornography on their personal computers, followed by a fraudulent report to authorities or a release to the masses. Would there be enough trust in the mainstream media for the public to exonerate a leader falsely accused of these types of charges? Tailored information could be sent directly to troops to erode morale, undermine their cause, or strip away their trust in leadership. This has already been displayed in recent fighting in Ukraine. Tailored and divisive messages were sent directly to frontline Ukrainian troops and their families by Russian-backed separatists. While this was conducted during actual armed conflict, it is not unreasonable to conclude that this would be equally effective prior to open warfare. With the proliferation of

technology, this new employment of information warfare will be displayed in all phases of future conflict.

Economically, information warfare allows an adversary to achieve a strategic objective with limited investment. With governments utilizing domestic information warfare campaigns, will corporations and private citizens follow suit?¹⁹

Nonmilitary forms and means of struggle have received unprecedented development and have acquired a dangerous, sometimes violent nature. The practical use of nonmilitary methods and means can cause a collapse in the energy, banking, economic, information, and other spheres of a state's daily activities.

The United States spends billions in military investments focused on people; air, land, sea, and under-ocean warfare platforms; and infrastructure. But all these military advantages can be superseded by several thousand dollars in computer parts combined with basic technical knowledge and a focused information warfare campaign. This drastically reduces the economic bar to entry into this space. Additionally, with governments utilizing domestic information warfare campaigning, corporations, private citizens, or groups might also follow suit.

Socially, the ubiquity of mobile phones has created a targeted delivery mechanism for nearly every person on earth. If someone does not own a smartphone, his or her network is not worth influencing. Adversaries can easily inject themselves into a social media network and then use sock puppets and botnets to artificially distribute information within that social media group. Original group members, real people assumed to support their group's ideology, following principles of social proof, will begin to accept and spread the new artificial information seeded by adversaries. Inoculating the public to these information campaigns presents unique challenges, and the national education environment must foster critical reading and thinking to reduce susceptibility. The Institute for the Future 2018 report illuminated how disinformation follows contagion propagation models: "Social media manipulates us individually, one private screen at a time."²¹

This article argues that four emerging trends will change the information environment by 2029: the diminishment of America's image and trust on the global stage, the increase of China's influence in the IoT and its becoming the dominant computing nation, the continued fracturing of societies through cultural schisms brought forth by tailored nontraditional news, and finally, the shift to combatting adversaries in the information space as a method of avoiding kinetic conflict.

Some researchers point to these phenomena appearing in contemporary events. Debate still occurs over how much

influence foreign actors held over the 2016 U.S. election and Brexit voting,^{12,15,19} but agreement exists that Russian organizations waged online operations to divide populations across multiple social issues. Although we agree with that assessment, we believe that this is only a leading indication and not a capability used to its full potential. We believe that further distortions of reality will manipulate perceptions and decisions on a large scale in more than isolated incidents such as elections and that this distortion will apply to the day-to-day fabric of life. This comprehensive approach allows for more incremental shifts in perception and affect. These incremental shifts become background noise, and long-term adversarial planning will capitalize on these programmed glacial changes to set conditions to meet their aims in an unobservable way. We use the term "unobservable" as no one incident draws the attention or scrutiny of the target. However, in total, the impact on the target will be greater than the sum of the incremental actions.

Looking forward, the future is not set in stone. Grass-root efforts currently exist to determine and assess the provenance of pictures and information online. Fact-checking sites exist and use algorithms to assess the truth of what is presented. Technology alone, however, will not save the day. To avoid this paradigm and change the future, the United States must draw upon all its resources to ask key questions to understand and successfully navigate this space to create a winning strategy. Such questions include the following: What is the number one geopolitical strength and vulnerability of the information environment? What is the value threshold of real or perceived loss for the administration? What are the strategic cultural context and priorities of the culture the United States looks to influence? This requires the U.S. government to take an introspective look to determine whether it can ask better questions of itself, industry, and academia to understand the information environment and the ramifications of actions.

National leaders must create a prescriptive strategy detailing the conditions in the information domain the United States will find favorable in the future along with the means and ways to attain them. Additionally, the U.S. government must engage with industry to prioritize and lead efforts in emerging technologies while investing in domestic production of these technologies. Socially, the United States must have a whole-society effort to adopt and implement these emerging technologies to modernize communications infrastructure with the goal of placing higher than seventh in the world in the World Bank rankings,²³ surpassing The Netherlands, Sweden, and Austria. Lastly, the United States must propagate its own messaging of what its goals are and what actions the government will take on the world stage in addition to completing actions when public statements are made to maintain the credibility of the nation and not allow for adversaries to spread a false narrative. ■

Acknowledgment

This article was written as part of a U.S. Department of Defense Joint Staff Strategic Multilayer Assessment of the future of warfare.

References

1. S. Jones, *Going on the Offensive: A U.S. Strategy to Combat Russian Information Warfare*. Washington, DC: Center for Strategic and International Studies, 2018.
2. P. Cobaugh, "A five-point strategy to oppose Russian narrative warfare," Medium, Apr. 25, 2018. Accessed on: Feb. 26, 2019. [Online]. Available: <https://medium.com/@paulcobaugh/a-five-point-strategy-to-oppose-russian-narrative-warfare-56e0006aab2a>
3. The Moscow Times, "Russia's biggest enemy is U.S.—Poll," Jan. 10, 2018. Accessed on: Feb. 26, 2019. [Online]. Available: <https://www.themoscowtimes.com/2018/01/10/russias-biggest-enemy-is-us-poll-a60146>
4. J. Lewis, *How 5G Will Shape Innovation and Security*. Washington, DC: Center for Strategic and International Studies, 2018.
5. S. Pruitt, "How a five-day war with Georgia allowed Russia to reassert its military might," History Channel, Aug. 8, 2018. Accessed on: Feb. 2, 2019. [Online]. Available: <https://www.history.com/news/russia-georgia-war-military-nato>
6. J. J. Mearsheimer, "Why the Ukraine crisis is the West's fault: The liberal delusions that provoked Putin," *Foreign Affairs*, vol. 93, no. 5, pp. 77–89, 2014.
7. M. Kaban, "What would the US withdrawal from Syria mean for the region?" *Al Jazeera*, Dec. 23, 2018. Accessed on: Feb. 23, 2019. [Online]. Available: <https://www.aljazeera.com/indepth/opinion/withdrawal-syria-region-181223131305616.html>
8. J. Chen et al., "China's Internet of Things," SOS International, Oct. 2018. [Online]. Available: <https://www.uscc.gov/Research/chinas-internet-things>
9. B. Marr, "9 technology mega trends that will change the world in 2018," *Forbes*, Dec. 4, 2017. [Online]. Available: <https://www.forbes.com/sites/bernardmarr/2017/12/04/9-technology-mega-trends-that-will-change-the-world-in-2018/#24e81e9e5eed>
10. New Jersey Institute of Technology, "Will mobile devices replace computers?" 2019. [Online]. Available: <https://graduatedegrees.online.njit.edu/resources/mba/mba-infographics/will-mobile-devices-replace-computers/>
11. E. Reeve, correspondent. "A face in the crowd," *VICE on HBO*. Season 6, show 2. Aired Apr. 13, 2018.
12. N. Ismail, "Will China dominate the global industrial Internet of Things market?" *Information Age*, June 27, 2018. [Online]. Available: <https://www.information-age.com/china-dominate-industrial-iiot-123473101/>
13. S. Crawford, "China will likely corner the 5G market—and the US has no plan," Feb. 20, 2019. Accessed on: Feb. 22, 2019. [Online]. Available: <https://www.wired.com/story/china-will-likely-corner-5g-market-us-no-plan/>
14. A. Ma, "China has started ranking citizens with a creepy 'social credit' system—here's what you can do wrong, and the embarrassing, demeaning ways they can punish you," *Business Insider*, Oct. 29, 2018. [Online]. Available: <https://www.businessinsider.com/china-social-credit-system-punishments-and-rewards-explained-2018-4>
15. E. Shearer, "Social media outpaces print newspapers in the U.S. as a news source," Pew Research Center, Dec. 10, 2018. [Online]. Available: <https://pewrsr.ch/2rsoHtb>
16. P. Domm, "False rumor of explosion at White House causes stocks to briefly plunge; AP confirms its Twitter feed was hacked," *CNBC*, Apr. 23, 2013. [Online]. Available: <https://www.cnn.com/id/100646197>
17. N. A. Mancheri, B. Sprecher, G. Bailey, J. Ge, and A. Tukera, "Effect of Chinese policies on rare earth supply chain resilience," *Resources, Conservation Recycling*, vol. 142, pp. 101–112, Mar. 2019. doi: 10.1016/j.resconrec.2018.11.017.
18. P. Singer and E. Brookings, *Like Wars*. Boston: Houghton Mifflin, 2018.
19. V. Gerasimov, "Contemporary warfare and current issues for the defense of the country," *Army Univ. Press*, Nov. 2017. [Online]. Available: <https://www.armyupress.army.mil/Portals/7/military-review/Archives/English/Contemporary-Warfare-and-Current-Issues-for-the-Defense-of-the-Country.pdf>
20. V. Gerasimov, "The value of science is in the foresight: New challenges demand rethinking the forms and methods of carrying out combat operations," *Military-Ind. Kurier*, Feb. 27, 2013.
21. D. Rushkoff, D. Pescovitz, and J. Duagan, "The biology of disinformation: Memes, media viruses, and culture inoculation," *The Institute for the Future*, 2018. [Online]. Available: http://www.iftf.org/fileadmin/user_upload/images/DigIntel/SR-2002_IETF_Biology_of_disinformation_tk_042618.pdf
22. TED Radio Hour, "Unintended consequences," *National Public Radio*, Nov. 2, 2018. [Online]. Available: <https://www.npr.org/programs/ted-radio-hour/662611757/unintended-consequences>
23. The World Bank, "International LPI," 2018. Accessed on: Feb. 23, 2019. [Online]. Available: <https://lpi.worldbank.org/international/global?sort=asc&order=LPI%20Rank#datatable>

Michael Klipstein is a senior researcher and chief of strategic partnerships at the Army Cyber Institute at West Point, New York. Contact him at michael.klipstein@westpoint.edu.

Austin Minter is a researcher at the Army Cyber Institute at West Point, New York. Contact him at austin.minter@westpoint.edu.

Jeremiah Pittman is an electronic warfare researcher at the Army Cyber Institute at West Point, New York. Contact him at jeremiah.pittman@westpoint.edu.

Governance Challenges for European Cybersecurity Policies: Stakeholder Views

Pierantonio Sterlini and Fabio Massacci | University of Trento

Natalia Kadenko, Tobias Fiebig, and Michel van Eeten | Delft University of Technology

We outline possible approaches to cybersecurity governance and compare them against the proposed European Union network of competence centers. We survey stakeholders for their opinions about the centers and analyze the results.

Security issues affect the private data of millions of citizens. Organizations that influence elections and state actors that attack critical infrastructures have made cybersecurity a focus of policy makers. Cybersecurity governance and conformity are now part of trade negotiations alongside traditional issues, such as tariffs on cars, between the European Union (EU) and the United States.¹

Yet, when trying to create governance frameworks for cybersecurity, policy makers often lack “user requirements.” Proposing more (or less) centralized regulation can always be done, but it may not be the most effective option.² The diverse, distributed, evolving, and global nature of cyberthreats often requires responses that stem from coordinated partnerships. Therefore, when deciding whether to prioritize research or skills development, policy makers need a ground truth about the needs of existing stakeholders to avoid impractical frameworks that may hinder existing collaborations.

For example, an Atlantic Council report³ recommends a “state-centric cybersecurity expert center” in

the United States as part of a new governance model. It also mentions “organizing around like-minded countries”; that is, intensifying international cooperation and conducting joint campaigns in response to cyberthreats. Similarly, the European Commission has proposed a cybersecurity competence center and network of national centers that would oversee cybersecurity R&D financing in the EU. The legislative process has broadened its scope; for example, to include professional education. The cybersecurity competence center is an interesting case study for cybersecurity governance, given the wide diversity of the stakeholders, from government officials to hackers. We are interested in understanding how those groups see their role and what they think the final goal of the cybersecurity competence center should be.

The core of our contribution is the analysis and empirical validation of different models of cybersecurity governance for the cybersecurity competence center to inform the European Commission and European Parliament decision-making process. We seek to examine three research questions (RQs) drawn from theory, legislative proposals, and the direct opinions of European stakeholders to see whether they are aligned:

- *RQ 1 (narrow or broad focus)*: Do stakeholders envision a focus on R&D or broader goals (for example, professional skills and transfers to market)?
- *RQ 2: (decision making)*: What governance framework structure do the stakeholders think will achieve their target cybersecurity capabilities?
- *RQ 3 (key players)*: Which organizations do the stakeholders want to leverage and rely on for an EU-wide cybersecurity competence network?

To answer those questions, we first discuss several models of governance and how the EU cybersecurity competence center initiative fits them. We then conduct a quantitative and qualitative study of EU stakeholders (chief information security officers from Fortune 50 companies, senior officers from EU agencies and data-protection authorities, industry managers, hacktivists, and academics) to collect their opinions. Our findings shed light on the key issues that policy makers should address when designing a governance model for cybersecurity.

Governing Cybersecurity?

There is no one-size-fits-all model for governance. In his classic work, Powell⁴ discusses three governance models: market, hierarchy, and network. When it comes to cybersecurity, the invisible hand of the market shows itself openly, including its failures around the world.⁵ The economic exchange largely preserves the autonomy of actors whose costs and benefits are self-assessed (for example, software costs versus the expense of possible data loss), and no long-term feeling of trust and obligation emerges. When there

is an insufficient governing approach at the national level, market mechanisms address immediate needs. We can expect market-based stakeholders to ask the cybersecurity competence center for R&D solutions, since cyberthreats have the potential to undermine their profits (the narrow focus in RQ 1). Stakeholders that favor the market model would likely prefer a decision-making process that granted limited powers to the EU body (RQ 2). Industry players would probably be named as key stakeholders (RQ 3).

With its rigid, vertical, and clear task distribution and bureaucratic rules, the hierarchical model is suited to high-speed mass production, replacing the uncertainty of market mechanisms with stability and predictability,

according to Powell.⁴ The downside of stability is a lack of flexibility to anticipate and react to changes. The desire for predictability may nudge actors toward compliance and “box ticking” instead of proper risk analysis.² Unfortunately, flexibility may be crucial to quickly reacting to the rapidly shifting cybersecurity environment. Hierarchical organizations also require a backup joint resource pool to safeguard against inevitable insufficient responses.

Yet, requests for additional resources from cybersecurity “defenders” are always vulnerable to threat inflations by what U.S. President Dwight Eisenhower called the military-industrial complex and for which robust evidence exists in the cyber domain.⁶ This model’s most difficult challenge is that it requires the commitment of a large group of actors, including not just industries and consumers but representatives of national and supranational political bodies as well as civil-society groups, to abide by the hierarchical organization. The model includes space for broader goals that could be reflected by stakeholders expressing their desire for a wider focus (RQ 1). The European Commission would likely be named the primary decision-making power (RQ 2). Stakeholders may also require the involvement of multiple parties rather than allowing industry to settle the rules of the game (RQ 3).

**Organizations that influence elections
and state actors that attack critical
infrastructures have made cybersecurity
a focus of policy makers.**

An alternative to realizing a “cyber-moonshot” is to consider the cooperative framework of what started out as an institutional moonshot of sorts; namely, the EU. A model of international cybersecurity cooperation may answer the challenges of cybersecurity policy making, similar to

the way that the EU prototypes were the answer to the challenges of peace building in postwar Europe. A common European goal may be best realized in the network governance model, which includes, as described by Powell, “interdebtedness and reliance over the long haul.”³ A successful network model facilitates the exchange of data and knowledge, for which an environment of trust and the feeling of being united is essential. Pupillo⁷ also states that “trust-based relationships are essential to cybersecurity and resilience policy” and elaborates on the inherent contradictory market incentives (private costs versus shared benefits). In other words, leaving cybersecurity to market-based relationships will likely fail to create the conditions necessary

for efficient global responses, while hierarchical structures with the clear boundaries of specialization and authority may be inadequate for the challenges of a dynamic environment.

Stakeholder answers that indicated a preference for the network model would include the need to tackle broad, ambitious cybersecurity goals (RQ 1) by opting for a decision-making process based on consensus and involving multiple parties (RQs 2 and 3). The network model is not immune to challenges, such as a perceived loss of independence, unclear responsibilities, and encapsulation. Like many domains that require intense and timely cooperation, it must avoid falling into a state of disequilibrium as a result of producing short-term solutions and sacrificing long-term stability for immediate political gains.⁸ Collaborative governance, that is, “attempts to bring all relevant stakeholders together for face-to-face discussions during which policies are developed,”⁹ will help to tackle additional challenges, such as attracting talent, incorporating relevant input from diverse stakeholders, and ensuring sustainable development.

EU Cybersecurity Policy

How has the real-life cybersecurity competence center legislative process responded to the governance challenges? Policy makers often find it challenging to write about EU rules without mentioning a “patchwork approach”¹⁴ and “half-hearted progress.”¹⁵ With the growing body of policy documents and legislative acts covering cybersecurity, several challenges have become apparent. The EU-wide issue of maintaining a balance between national freedoms and supranational regulations remains problematic because for cyberthreats the distinction between those areas is unclear. From identifying attackers to developing the most efficient responses, cybersecurity increasingly requires intra- and international cooperation as well as cross-domain policy responses (for example, justice, international security, and the harmonization of education). Additionally, international market forces are an important player in the field.

The Legislative Evolution

The history of the European cybersecurity network begins with the adoption of the Budapest Convention on Cybercrime in 2001, the Common Framework on Electronic Communications Networks and Services in 2002, and the establishment of the European Union Agency for Cybersecurity (ENISA) in 2004. The main tasks for ENISA were “developing a culture of network and information security for the benefit of citizens, consumers, businesses, and public sector organizations in the European Union, thus contributing to the smooth functioning of the internal market.”¹⁰ The model was based on the market, with information exchange as a principle of successful governance.

Changes in international conditions led to the evolution of EU cybersecurity legislation (Figure 1). The EU Cybersecurity Strategy from 2013 (updated in 2017) stressed the need for cooperation between member states, the private sector, and EU agencies (ENISA, the European Crime Center/Europol, and the European Defense Agency) to promote awareness of threats, encourage investment, and share best practices.¹¹ The 2015 European Agenda on Security focused on combatting cybercrime through a “coordinated response at the European level,” including implementing policies and adjusting existing legislation.¹² The 2015 Digital Single Market Strategy pointed to the vital role of investments in novel technologies and support to small- and medium-sized enterprises (SMEs). After several pieces of legislation targeting specific cybercrime issues (for example, payment fraud), the Directive on the Security of network and information systems (NISs) was issued in 2016 and provided an example of an EU-wide initiative. It established an NIS group to coordinate strategic cooperation among member states, provide guidelines for national capabilities, and promote the exchange of information.

The EU Cyberdefense Policy Framework, adopted in 2014, was updated in 2018 to better correspond to new challenges.¹³ Attention was paid to conflict prevention and cooperation in cyberspace as well as the

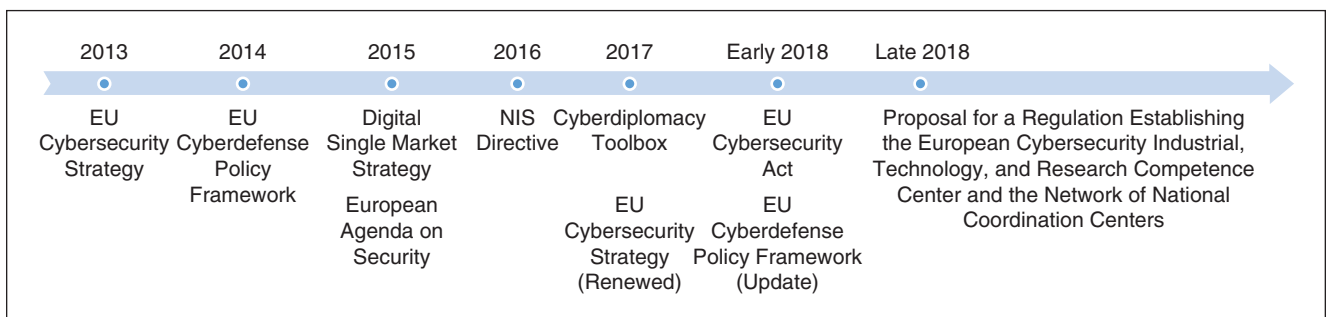


Figure 1. The evolution of the European cybersecurity policy initiatives.

availability of information. The updated priorities list included the development of cyberdefense capabilities, training, and exercises; research and technology; and civil-military and international cooperation. The “cyberdiplomacy toolbox” from 2017 provided a framework for joint foreign-policy responses to cyberattacks against the EU to “influence the behavior of potential aggressors in the long term.”

In December 2018, the European Parliament, European Council, and European Commission reached an agreement on the Cybersecurity Act, which established an EU framework for cybersecurity certification and granted ENISA additional resources, thus reaffirming the agency’s role of supporting member states in cyberattack management and prevention as well as in cybersecurity policy making. Whether ENISA was actually successful in fulfilling that function is debated, as we shall see in the stakeholders’ interviews.

The evolution showed that Europe’s goals were broadening (RQ 1) from narrow and market based to an accommodation of intense cooperation at different levels (RQ 2) with diverse stakeholders involved (RQ 3) in the network model. The political debate also raised the need for stronger cybersecurity governance at the EU level and better coordination at the operational scale, including the mitigation of organizational fragmentation and better resource utilization.

The Network of Competence Centers

Against that background, it became apparent that EU cybersecurity funding needed to be better coordinated, as identified by the last steps in Figure 1. On 13 September 2017, the European Commission issued a communication, “Resilience, Deterrence, and Defense: Building Strong Cybersecurity for the EU,” which proposed establishing the cybersecurity competence center with a network of national coordination hubs. The European Commission’s initial intent was that the cybersecurity competence center would coordinate research funding (RQ 1). In December 2018, a rapporteur from the European Parliament presented a draft report that stressed the coordinating role of ENISA in the cybersecurity competence center’s activities and called for an advisory role for experts and large and small companies (the hierarchical model, RQ 2). The report endorsed a multistakeholder

approach and the vision of cybersecurity as a dynamic field that required a more creative approach than a series of products.¹⁶

At the time of writing, the “Proposal for a Regulation Establishing the European Cybersecurity Industrial, Technology, and Research Competence Center and the Network of National Coordination Centers” passed the European Parliament. One proposed amendment¹⁷ fit

the idea of collaborative governance (the network model, RQ 2) by explicitly defining stakeholders as “industry, public entities, and other entities which deal with operational and technical matters in the area of cybersecurity as well as to civil society, interalia trade unions, consumer associations,

the free and open source software community, and the academic and research communities.”

Another amendment addressed capacity (RQ 1), saying that it “should deliver cybersecurity-related financial support from the Horizon Europe and Digital Europe programs as well as from the European Defense Fund ... the European Regional Development Fund, and other programs where appropriate. This approach should contribute to creating synergies and coordinating financial support related to Union initiatives in the field of cybersecurity research and development, innovation, technology, and industrial development and avoiding duplication.” Amendment 16 was added to address ethical aspects of security and privacy, while Amendment 18 stressed that “the Union needs to be able to adapt fast and continuously to new developments in the field. Hence, the [cybersecurity competence center] and the cybersecurity competence community should be flexible enough to ensure the required reactivity.”

The emerging mixture of hierarchy and network models that is being developed by the EU, while correctly identifying the existing challenges and aiming for transparency, accountability, development potential, and resource allocation, may suffer from inefficiency, overlapping competencies, and conflicts of independence. The governance process is further complicated by the nature of the interinstitutional cooperation between EU bodies. Four pilot projects were launched in 2019 to “assist the EU in defining, testing, and establishing the governance model” of the cybersecurity competence center. Our research was performed in one of them, CyberSec4Europe.



Policy makers need a ground truth about the needs of existing stakeholders to avoid impractical frameworks that may hinder existing collaborations.



Table 1. The demographics of the survey participants.

Work sector			
Academy	Industry	Regulator, agency	Trade association
26	25	Three	Three

The participants came from 16 member states of the EU. Five were from outside the EU, and two did not specify their nationality.

Table 2. The vertical domains of the industry participants.

Health	Finance	Incident reporting	Supply chain	Smart cities	Identity management
Five	Three	Four	Six	Six	Nine

Multiple answers were permitted. Eight participants did not identify a domain. The vertical domains closely mirror those of the European Cybersecurity Organization.

Table 3. The stakeholders' professions.

Number	Role	Organization
1	Senior manager	European Union Agency for Cybersecurity
2	Board member	European Union Agency for Cybersecurity
3	Board member	European trade organization
4	Board member	EU data-protection supervisor
5	Senior manager	European consumer organization
6	Ethical hacker	Self-employed
7	Senior manager	Semiconductor multinational corporation
8	Vice president	Re-insurance multinational corporation
9	President	Critical-infrastructure association
10	Chief information security officer	Pharmaceuticals and energy multinational corporations
11	Professor	University
12	Policy advisor	Cybersecurity for industry and government
13	Government official	National government, IT security
14	Professor, entrepreneur	University, small security company
15	Ethical hacker	Security industry
16	Professor	University
17	Vice president	Software multinational corporation
18	Senior manager	Financial institution

Collecting Stakeholder Viewpoints

Various techniques exist for knowledge elicitation,¹⁸ but a variant of structured and semi-structured interviews is the most commonly used (see chapter 42 in Spector et al.¹⁹). To collect the opinions of stakeholders, we took a two-pronged approach, as previously done by De Gramatica et al.²⁰ and Halaweh,²¹ to stakeholder cybersecurity policy analysis. A structured survey was given to more than 50 stakeholders to collect suggestions and opinions about the governance model, and it was supplemented by 18 face-to-face discussions based on the notion of “grand tour interviews.”²²

The Survey

The survey included open and multiple-choice questions to provide a quantitative analysis of the results. The expected time to complete the 24 questions was 15–20 min. The demographics of the stakeholders who responded are summarized in Table 1. The survey was open from mid-March through the end of August 2019 and made available to the industrial and academic members of the cybersecurity competence center pilot programs (which yielded roughly 200 potential respondents). Fifty-seven completed surveys were collected. At the time of writing, the European Cybersecurity Organization agreed to circulate the survey to its members for a major consultation event to take place in November 2019.

The Interviews

Through a purposive sampling approach,²² we identified stakeholders (Table 2) to represent a variety of roles that were specifically involved in cybersecurity (from agency representatives to data-protection authorities and chief information security officers to representatives of customer organizations). For the 18 additional stakeholders (Table 3) who agreed to sit down with us, we conducted semistructured interviews that were recorded with the participants' permission and transcribed anonymously. All of the interviews were conducted between March and June. They enabled us to supplement and clarify the survey's findings.

The Questions

The survey and interviews featured questions that were designed to elicit answers in a terminology close to the stakeholders' own interests. For example, a stakeholder that did not participate in the cybersecurity competence center pilots was unlikely to be interested in generic questions on governance. However, that person would have opinions about the capabilities that Europe should develop and who should be in charge of achieving them (for example, using the hierarchy and market models).

Our questions began with the overall cybersecurity goals that Europe should achieve (such as the coordination of policies, technological independence, and protection of citizens and state actors from non-EU countries). For example, technological independence is a central EU policy priority given the current U.S. protectionist measures (such as its restrictions on Huawei). To achieve that goal, we also asked what should change. Then we asked, “In your area, what key capabilities are required by systems, people, institutions, and so forth to achieve that change?” Research and technological innovation were among the options, but professional knowledge and skills could also be selected.

With regard to the key players, the participants were asked to select at most eight stakeholder groups from a broad list (see “Identifying the Stakeholders”). We then focused on the decision-making aspects of the cybersecurity competence center. Another significant question was whether the network should push the national centers and the industries flocking around them toward specialization (that is, fund a research area in one member state only, as the “avoiding duplication” clause in the legislation is often interpreted to mean). This is an important question for the United States³ and other countries that opt for distributed network centers (for example, the United Kingdom).

In terms of mandates, we asked whether the center and its network should advocate compulsory security certification at the European level. In the initial

European Commission text, there was a provision for identifying areas that would be subject to mandatory security certification. Industry lobbying efforts have weakened the wording, and at the time of writing, only voluntary certification schemes are considered in the legislative documents.

Analysis

In terms of what should change to improve the cybersecurity situation (for example, better resilience, transparency, trustworthiness, security metrics, and so forth), respondents considered the transparency of cybersecurity decisions, trustworthiness, and resilience to be challenges. Some interviewees (interviewees 4, 7, 9, and 17) highlighted the need for knowledge and education to be constantly updated to meet the dynamic changes in cybersecurity. There must be new generation of experts trained through an interdisciplinary approach to master system security and understand how cybersecurity affects business. Some participants raised the issue of making sure that EU taxpayer money to fund cybersecurity research does not benefit U.S. companies through their European subsidiaries (interviewees 1 and 3). In general, the goal was to achieve cybersovereignty, independence, and control (interviewees 1, 3, 11, and 14–16), with a clear preference for a broader focus (RQ1) and indications of support for the hierarchical and network models.

Our survey results indicated that activities should go beyond funding R&D and include training and

Identifying the Stakeholders

Participants were asked to select up to eight of the following stakeholder groups:

- European Commission
- European Network and Information Security Agency
- National cybersecurity agencies
- Other national government representatives
- Industry
- Academia
- Industry associations
- Consumer associations
- Data-protection authorities
- Computer emergency response teams
- Formal standards and/or certification organizations (e.g., the International Organization for Standardization and International Telecommunications Union)
- Community standards and/or certification organizations (e.g., the Internet Engineering Task Force)
- Community professional organizations (e.g., the North American Network Operators’ Group and bodies related to the Regional Internet Registries, such as the Réseaux IP Européens Network Coordination Centre)
- Open source software communities (e.g., the Linux Foundation and the Free and Open Source Software Developers’ European Meeting)
- Hacker communities (e.g., the German Chaos Computer Club European Hackerspaces)
- Other.

innovation. Only 32% of the participants considered the development of better security technologies to be essential, while 35% believed that it was of major importance. Less than half (42%) considered new and improved technical standards to be essential. In contrast, 46% of the respondents replied that new professional and academic skills were critical to achieve cybersecurity capabilities. Slightly more than half (51%) believed that policy interventions held major significance.

The interviewees agreed that R&D funding was an important objective (interviewees 1–3, 7, and 10), but they widely diverged on whether it was the only one (as advocated by an EU actor, stakeholder number 2). For example, three very diverse stakeholders (interviewees 3, 6, and 10) raised the critical need to support SMEs to bring research to the market, a view shared by the European Parliament. Others (interviewees 1, 4, 8, 9, and 17) focused on professional skills and education. Since all three models are consistent with those opinions, we must look to other answers to see how the goals should be met. The certification of infrastructures, services, and products were also shown to be aspects that should change (it was of major importance to one third of the respondents). In that respect, half of the participants agreed that the cybersecurity competence center should support mandatory security certification. Such answers lean toward hierarchical models.

The quest to specialize research in each national center was not supported by the stakeholders. Less than one third of the respondents (28%) supported the option, one quarter considered it to be possible only in special cases, and the remainder expressed a negative opinion. Concerns about potential duplication were held mostly by stakeholders who had a Europe-wide responsibility (for example, interviewees 2 and 3, who explicitly mentioned wasted resources). Other stakeholders who believed that the scheme might backfire did not share the view. For example, interviewees 4, 6, 10, and 17 believed that the policy would be effective only during the short term, since it is not possible to predict where new innovations will take place. Others (interviewees 4, 10–13, and 16) stated that specialization will occur naturally and should be capitalized rather than enforced. Those answers strongly support the network and market models over the hierarchy model.

A majority of the participants (60%) considered the European Commission and ENISA (61%) to be important players. However, nearly one fifth (18%) indicated only the European Commission. Vice versa, a similar number of respondents (19%) pointed to ENISA without mentioning the European Commission. That can be interpreted as a preference for clear task distribution through a designated structure, which corresponds to the hierarchical model. Still, many stakeholders were

not familiar with ENISA. Of those respondents who expressed an opinion, most assigned ENISA to an orchestration role, underlining the need for harmonization between organizations (as stated by number 17). Some interviewees (interviewees 3 and 10) noted that ENISA has done nothing effective and probably will not, due to a lack of resources.

Most of the interviewees argued that decisions should be left to the member states and that a balance between different stakeholders was desirable. As interviewees 3–5 observed, different member states would have varying sensibilities and agencies in charge of national security (for example, the Federal Office for Information Security in Germany, National Cybersecurity Agency of France, and Department of Information Security in Italy). Cybersecurity will always have a critical role in national security that cannot be eliminated by market issues (as stated by interviewees 3, 4, and 9). Such answers, again, strongly support the network model.

What emerged as a surprise was the role of the cybersecurity competence center as a first point of contact to support society (from SMEs to individual citizens) when it needs cybersecurity advice. A majority of the participants (68%) assigned academia a fundamental cybersecurity role, which is expected for centers that receive research funding. Nearly half of them said the computer emergency response teams (CERTs) should have an advisory role. Several interviewees (interviewees 1, 4, 8, and 9) believed the cybersecurity competence center could promote mechanisms for sharing attack data that protected victims' identities and enabled other actors to shield themselves. Others (interviewees 1, 4, 5, and 9) believed that citizens and ethical hackers could report security issues to the cybersecurity competence center to pass on to the appropriate regulator, since the companies that were involved would have a conflict of interest. In addition, 58% of the respondents attributed an important role to the data-protection authorities, which was comparable to the number of participants who selected the European Commission, thus demonstrating the importance that privacy protection has for European citizens.

Ambiguous views of the cybersecurity competence center emerged from the survey. The stakeholders projected their concerns, interests, and ambitions for European cybersecurity onto the agency. To some extent, that simply reflects the diversity of the parties operating in this area. Even the European institutions have saddled their policies with diverse objectives, hopes, and requirements, a situation that emerged from a network approach rather than a hierarchical one.

The complex governance network that surrounds the cybersecurity competence center means that coordination and collaboration will not emerge purely from a shared vision or hierarchically determined structure. In the end, competing incentives will shape what the cybersecurity competence center will become and deliver. Those motives are the key for policy makers. What will the cybersecurity competence center and its funding structures reward? International collaboration? Research and development with industry? Products and technologies? Training and education? All of the above?

Concerning first RQ, there is no agreement on the relative importance of R&D versus skill development. Given the diverging viewpoints of our participants, we recommend allocating resources evenly in both directions. RQ 2 clearly elicited a preference for an informed network model (academics) with some elements of hierarchy (the European Commission and ENISA). The presence of CERTs among the stakeholders in charge of advising funding and education shows the importance of incident management in a cybersecurity governance framework, which is relevant to determining where the funding and educational skills should go (which plays only a minor role in today's education charters).

Concerning our third RQ, there seems to be a general consensus that the flexible network model is the best way to cope with cybersecurity challenges and adapt to different economic and policy conditions. That flexibility implies that there should be no top-down decisions about the national centers' form and specialization, which has broad consequences for the Atlantic Council's proposal for the United States. In terms of operational and decision-making rules, another broad consensus exists on sharing security-issue information and possibly creating unified cybersecurity technical standards.

Eventually, if research funding remains the core of the network that will finally be approved by EU institutions, the broader ambitions for the cybersecurity competence center could be accommodated through incentives that reward linking research to societal impacts. An incentive embedded in funding schemes would strengthen the need for researchers to work with CERTs, industry partners, nongovernmental organizations, and so forth to improve security in the EU. ■

Acknowledgments

We thank A. Ferreira for jointly organizing a survey about the technological road map and the governance of the network, S. Fisher-Hubner and P.H. Cros for testing the survey, and all of interview subjects for their time. This work was partly funded by CyberSec4Europe within the European Union's Horizon 2020 program, H2020-SU-ICT-03-2018, under grant 830929.

The opinions reported in this article are our own and not necessarily endorsed by the European Union or the survey respondents' organizations.

References

1. European Commission, "EU-U.S. trade talks: European Commission presents draft negotiating mandates," 2019. [Online]. Available: http://europa.eu/rapid/press-release_IP-19-502_en.htm
2. F. Massacci, R. Ruprai, M. Collinson, and J. Williams, "Economic impacts of rules-versus risk-based cybersecurity regulations for critical infrastructure providers," *IEEE Security Privacy*, vol. 14, no. 3, pp. 52–60, May–June 2016. doi: 10.1109/MSP.2016.48.
3. F. D. Kramer and R. J. Butler. (2019). Cybersecurity: Changing the Model. Atlantic Council. Washington, DC. [Online]. Available: <https://www.atlanticcouncil.org/in-depth-research-reports/report/cybersecurity-changing-the-model/>
4. W. W. Powell, "Neither market nor hierarchy: Network forms of organization," *Res. Organ. Behav.*, vol. 12, pp. 295–336, Jan. 1990.
5. N. Vratonjic, J. Freudiger, V. Bindschaedler, and J.-P. Hubaux, "The inconvenient truth about web certificates," in *Economics of Information Security and Privacy III*, B. Schneier, Ed. New York: Springer-Verlag, 2013, pp. 79–117.
6. J. Brito and T. Watkins, "Loving the cyber bomb? The dangers of threat inflation in cybersecurity policy," *Harvard Law School National Security J.*, vol. 3, Apr. 2011.
7. L. Pupillo. (2018). EU cybersecurity and the paradox of progress. CEPS. Brussels, Belgium. [Online]. Available: <https://www.ceps.eu/ceps-publications/eu-cybersecurity-and-paradox-progress/>
8. D. Hodson and U. Puetter, "The European Union in disequilibrium: New intergovernmentalism, postfunctionalism and integration theory in the post-Maastricht period," *J. European Public Policy*, vol. 26, pp. 1153–1171, Jan. 2019. doi: 10.1080/13501763.2019.1569712.
9. M. Bevir, *Governance: A Very Short Introduction*. London: Oxford Univ. Press, 2012.
10. European Union, "Regulation (EC) No. 460/2004 of the European Parliament and of the Council of 10 March 2004 establishing the European Network and Information Security Agency," 2004. [Online]. Available: <https://eur-lex.europa.eu/LexUriServ/LexUriServ.do?uri=CELEX:32004R0460:EN:HTML>
11. European Commission, "Cybersecurity strategy of the European Union: An open, safe and secure cyberspace," 2013. [Online]. Available: https://eeas.europa.eu/archives/docs/policies/eu-cyber-security/cybsec_comm_en.pdf
12. European Commission, "The European agenda on security," 2015. [Online]. Available: <http://www.europarl.europa.eu/cmsdata/125863/EU%20agenda%20on%20security.pdf>

13. Council of the European Union, "EU cyber defence policy framework," 2018. [Online]. Available: <http://data.consilium.europa.eu/doc/document/ST-14413-2018-INIT/en/pdf>
14. R. A. Bendiek, "Europe's patchwork approach to cyber defense needs a complete overhaul," Council on Foreign Relations, Aug. 30, 2017. [Online]. Available: <https://www.cfr.org/blog/europes-patchwork-approach-cyber-defense-needs-complete-overhaul>
15. A. Bendiek, R. Bossong, and M. Schulze, "The EU's revised cybersecurity strategy: Half-hearted progress on far-reaching challenges," German Institute for Security and International Affairs, Nov. 2017. [Online]. Available: <https://nbn-resolving.org/urn:nbn:de:0168-ssoar-55103-4>
16. Committee on Industry, Research, and Energy, "Draft report on the proposal for a regulation of the European Parliament and of the Council establishing the European Cybersecurity Industrial, Technology and Research Competence Centre and the Network of National Coordination Centres," European Parliament, Brussels, Belgium, Rep. 2018/0328(COD), 2018. [Online]. Available: <http://www.europarl.europa.eu/sides/getDoc.do?pubRef=-//EP//NONSGML+COMPARG+PE-631.940+01+DOC+PDF+V0//EN&language=EN>
17. European Parliament, "European Parliament legislative resolution of 17 April 2019 on the proposal for establishing the European Cybersecurity Industrial, Technology and Research Competence Centre and the Network of National Coordination Centres," 2019. [Online]. Available: http://www.europarl.europa.eu/doceo/document/TA-8-2019-0419_EN.pdf
18. R. Hoffman, N. Shadbolt, M. Burton, and G. Klein, "Eliciting knowledge from experts: A methodological analysis," *Organ. Behav. Hum. Decis. Process.*, vol. 62, no. 2, pp. 129–158, May 1995. doi: 10.1006/obhd.1995.1039.
19. M. J. Spector, D. M. Merrill, J. Elen, and M. J. Bishop, *Handbook of Research on Educational Communication and Technology*. New York: Springer-Verlag, 2014
20. M. De Gramatica, F. Massacci, W. Shim, A. Tedeschi, and J. Williams, "IT interdependence and the economic fairness of cybersecurity regulations for civil aviation," *IEEE Security Privacy*, vol. 13, no. 5, pp. 52–61, Sept.–Oct. 2015. doi: 10.1109/MSP.2015.98.
21. M. de Gramatica, F. Massacci, W. Shim, U. Turhan, and J. Williams, "Agency problems and airport security: Quantitative and qualitative evidence on the impact of security training," *Risk Anal.*, vol. 37, no. 2, pp. 372–395, Mar. 2016. doi: 10.1111/risa.12607.
22. M. Halaweh, "Using grounded theory as a method for system requirements analysis," *J. Inform. Syst. Technol. Manage.*, vol. 9, no. 1, pp. 23–38, Apr. 2012. doi: 10.4301/S1807-17752012000100002.

Pierantonio Sterlini (p.sterlini@unitn.it) is a research project manager at the University of Trento, Italy.

Sterlini received a B.S. in international studies from the University of Trento. She leads the education and capability work package of the Horizon 2020 CyberSecurity4Europe pilot. She is a past president of the Italian Fair Trade Commercial Cooperative Organization.

Fabio Massacci (fabio.massacci@unitn.it) is a professor at the University of Trento, Italy. Massacci received a Ph.D. in computer engineering from the Sapienza University of Rome, Italy. He published more than 250 peer-reviewed papers and received the Ten Year Most Influential Paper Award at the 2015 IEEE International Requirements Engineering Conference. He coordinated several European Union initiatives, including the Socio-Economics Meets Security project, and he participates with the Common Vulnerability Scoring System Special Interest Group. He is Member of the IEEE.

Natalia Kadenko (kadenko@tudelft.nl) is a postdoctoral student in cybersecurity governance at Delft University of Technology, The Netherlands. Kadenko received a Ph.D. in the political problems of international systems and global governance from the Taras Shevchenko National University of Kyiv, Ukraine. She has worked as an editor and political analyst and cooperated with a nongovernmental organization that specialized in peacekeeping research.

Tobias Fiebig (t.fiebig@tudelft.nl) is an associate professor at Delft University of Technology, The Netherlands. Fiebig received a Ph.D. in computer networks from the Berlin Institute of Technology. A former network engineer, he works with several national and international research programs, including the Horizon 2020 Safe-Data-Enabled Economic Development project, and he leads the governance work package for the Horizon 2020 CyberSecurity4Europe pilot.

Michel van Eeten (m.j.g.vaneeten@tudelft.nl) is a professor at Delft University of Technology, The Netherlands, and the director of the Technology, Policy, and Management Graduate School. His research focuses on the interplay between technological design and economic incentives in Internet security. Van Eeten received a Ph.D. from Delft University of Technology. He led research projects funded by the European Union, The Netherlands Organization for Scientific Research, and industry that concerned the economics of cybersecurity and cybercrime. He serves on the Program Committee of the Workshop on Economics of Information Security and is a member of the Dutch Cyber Security Council.

Cyberattack-Resilient Cyberphysical Systems

Barry M. Horowitz | University of Virginia

A great deal of attention is currently being placed on the development of advanced automation for physical systems, including a wide array of applications such as automobiles, unmanned air vehicles (UAVs), the Internet of Things, and 3D printers. These automation opportunities introduce cyberattack risks that can lead to loss of human life or serious injury. The cyberattack risks related to physical systems first received national attention in 2011 due to the Stuxnet cyberattack, which disrupted industrial Iranian centrifuges employed in nuclear reactors.¹

General recognition of the continuously growing cyberattack risk situations has led a University of Virginia (UVA) research team to conduct studies that address providing cyberattack-resilient designs for cyberphysical systems that can complement solutions that seek to provide defense against cyberattacks. Since 2011, the UVA team, under my direction, has been engaging in research efforts exploring 1) system architectures for achieving resilience, 2) system methodologies and analysis tools for prioritizing resilience solutions, and 3) the roles and procedures for engaging operators in the real-time management of system reconfigurations that provide resilience. The methods have been demonstrated to

be effective across a broad range of applications, including UAVs, automobiles, 3D printers, and others. This article describes this comprehensive approach to resilience in cyberphysical systems and research advances on the horizon.

Defining Resilience

System engineers have been designing resilient electronic systems for many years (e.g., air traffic control systems and military nuclear weapon command control systems), employing what is referred to as *diverse redundancy* to permit dynamic reconfigurations of an abnormally behaving system. Diverse redundancy is a system design methodology that employs alternate methods for reconfiguring and operating a system under circumstances where the normal modes of operation become inoperable. In 2009, Riegar et al.² defined *resiliency* as the capacity of a system to maintain state awareness and to proactively maintain a safe level of operational normalcy in response to anomalies, including threats of a malicious and unexpected nature.

To provide cyber resiliency, a system must be designed to include a monitoring process related to cyberattacks and alternate diverse sets of hardware and software that, when called upon, would permit continued operation of the system. For the research efforts reported on in this article, a system architecture that

includes the required anticipatory processes for monitoring and reconfiguration control is provided by a subsystem referred to as a *sentinel*, which, to be viable for its role, should be designed to be far more secure than the system being addressed for resiliency.³ While the sentinel-based cyberattack detection process is expected to be automated, the level of reconfiguration automation may vary across system functions:

- *Totally automated*: Sentinel determines what to do and informs appropriately trained system operators regarding automated execution.
- *Semiautomated*: System operators receive automated recommendation(s) from the sentinel and, accounting for both situation context and a broader set of information available to them, decide on what to do.
- *Manual*: Operators, or higher levels in the system control hierarchy, determine what to do.

In addition, resilience includes containing the immediate consequences of the detected attack and post-attack forensic support based upon the data collected for addressing anomalies. Figure 1 provides a representation of a sentinel-based system architecture for providing cyberattack resilience. The employed system architectural approach is referred to as *system-aware cybersecurity* because

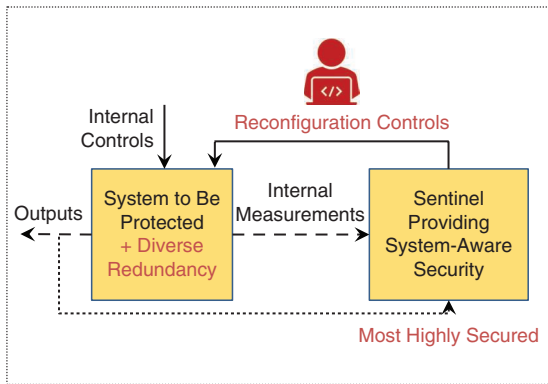


Figure 1. The architecture of sentinel-based cyberattack resilience.

attack detection methods are based upon discovery of system operational symptoms that would likely result from successful cyberattacks.

Figure 2 provides a more detailed representation of sentinel functions. As illustrated in the figure, the sentinel is connected to system interfaces from which it receives the data to support its monitoring function. The design of the communication interfaces depends upon a variety of factors, ranging from wired to wireless communications with a selection of protocols that depend upon the data to be sent and the formats and protocols of the functional subsystems to

be monitored. The sentinel must then condition the diverse sets of collected data so that they can be integrated and analyzed. This includes setting of appropriate data rates, data formats, and communication protocols for use within the sentinel.

Once the data to be analyzed for resilience purposes are ready for use, the sentinel performs the specific analyses required for detection of a cyberattack and determination of the location within the protected system that is under attack. When an attack is detected, the sentinel must prepare messages for the system users containing information regarding the detected attack and the steps required to reconfigure the system for continued operation. These messages must then be assembled for communication and computer control of the subsystems involved in the resilience-related reconfiguration solution.

In addition, the sentinel must prepare and disseminate its results for users engaged in more strategic roles (e.g., machine-learning purposes, forensics, etc.) related to managing resilience. There are a wide variety of possibilities for the hardware/software design of sentinels that are

dependent on the system being supported. For example, implementation can be through a single computing node or through a highly distributed set of nodes, and selection of the design should be highly dependent on the methods of security that can be applied for protection of the sentinel (see the “Cyberattack Protection of the Sentinel” section).

The anticipated value of employing this type of resilience solution is that it requires the cyberattacker both to understand how the system to be attacked is designed and to develop and employ multiple attacks on diversely redundant subsystems to sufficiently disrupt the targeted system. This, in turn, should impact the cost, time, technical complexity, and risk for creating the desired cyberattacks, with the objective of deterring attackers from going ahead with their desire to be disruptive. Of course, the resilience solution must be sufficiently low cost, timely, low risk, and effective to make it an attractive option.

Detecting Successful Cyberattacks

In this section, I describe mechanisms for cyberattack detection by

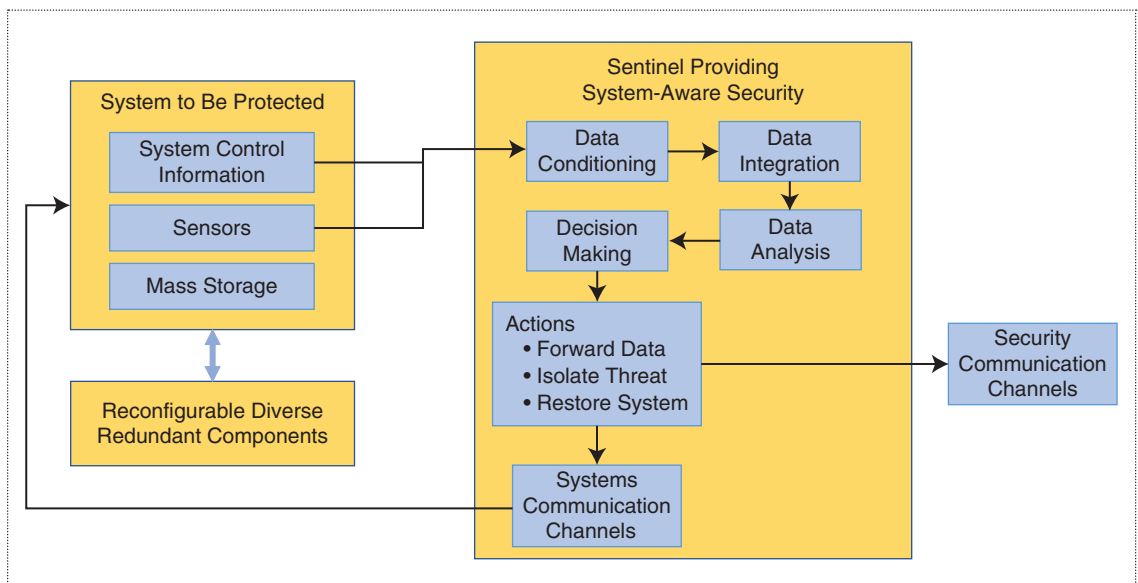


Figure 2. The sentinel data flow.

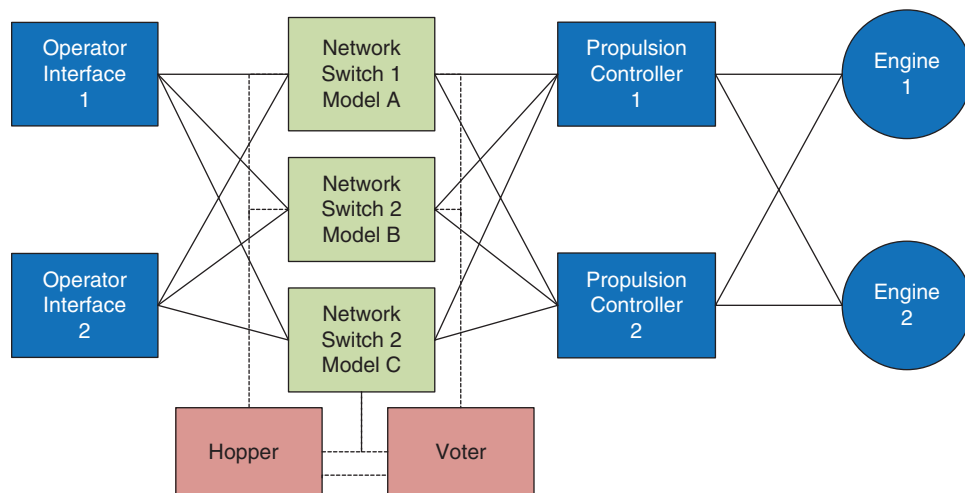


Figure 3. The technical configuration for hopping/voting resilience design pattern for ship propulsion control.

a sentinel subsystem. To provide quality and cost advantages, the suggested system-aware design approach includes reusable design patterns for detecting successful cyberattacks. Example attack detection design patterns include:

1. discovery of data inconsistencies within the system with no other explainable cause (e.g., operator system control inputs are different from the inputs received by the related controlled subsystems, diverse sensors provide inconsistent measurements)
2. detection of changes of system operational parameters without authorized and operationally correct procedures, resulting in significant performance consequences (e.g., changes to navigation waypoints in a UAV resulting in modification of a UAV's route, changes to the detection threshold values in a radar system resulting in modification of false alarm/missed detection rates for that radar system, changes in the selection of transmission power levels in a software-controlled radio system that cause communication range and radio interference problems)
3. recognizing significant unexplainable incompatibilities between internal system communication levels and the presentation of situation awareness information provided to system operators (e.g., air defense system operator provided with low levels of traffic information, but sensors are observed to be communicating information that should be presented at high rates).

While each of these examples applies to a wide variety of physical systems, the implementation of specific solutions will vary across different systems. The system-aware research efforts have included prototype designs that employed the example design patterns described previously as well as others for detecting cyberattacks on UAVs, police cars, 3D printers, and military systems. Note that the consequences of a cyberattack can vary significantly depending upon the actual system being attacked, so risk-based decisions are required in terms of which design patterns reduce the risks of attack most significantly. Furthermore, as noted

previously, resilient system efforts must be directed toward achieving designs that are highly secured.

System Reconfiguration Solutions

As illustrated earlier in discussing reusable design patterns for cyberattack detection, designs that exploit diverse redundancy for continuing operation also are reusable, but implementation and risk reduction value depend upon the actual system to be protected. In addition, diverse solutions typically do not perform as well as the normal mode of system operation, although they are potentially acceptable for continuing operation. Examples of diverse redundancy opportunities include the following:

- use of diverse sensors for providing situation awareness information (e.g., radar, infrared, audio, video, and many other technologies that can potentially be used as the basis for surveillance subsystems)
- use of diverse navigation subsystems (e.g., GPS, inertial navigation)
- use of relatively common subsystems, but designed and produced with different hardware and

software by different manufacturers (e.g., different operating systems, application software, microelectronics components, communications switches).

As a result, designers of resilient systems must evaluate the losses in performance that could result when the protected system is reconfigured and the operational acceptability of such losses.

Resilience can also be achieved through the integration of multiple approaches for achieving diversity that serve both detection of attacks and reconfiguration responses. For example, one of the design patterns derived from UVA's research efforts is referred to as *configuration hopping with voting*. An experimental application of this design pattern, utilizing multivariant programming⁴ via the use of three diversely manufactured communication switches and through comparison of message content going into and coming out of the switches, could determine if there was an inappropriately performing switch. If so, the improperly performing switch could be taken out of service while continuing system operation.

In addition, to make matters more complex for a cyberattacker intent on changing message content, the design pattern included the use of a moving target technique,⁵ dynamically changing which switch is to be operationally employed once every few seconds, with the use of randomly selected times for moving the potential targets. Since the diversely implemented switches were not closely synchronized in terms of order of messages and their timing, use of moving target defense brought with it the potential to create problems due to the timing of message processing within the diverse switches. To address this problem, message content comparisons were done in a batched manner at sufficiently spaced intervals (e.g., 20-s intervals) so as to reduce the percentage of deviating

messages due to timing. The sentinel detection algorithms were designed to permit missing messages as a normal situation when the deviations occurred close to the switching times, and the operational system depended on its existing communication protocols to assure that missing messages due to dynamic changing of the switch in operation were either resent in a timely manner or were acceptable for loss at low rates.⁶

Operational prototype-based experiments related to control of a ship's propulsion system were conducted to measure message loss rates. Results indicated that the number of lost messages due to a 20-hop/s resilience design was acceptably low (for a 250-Mb/s data rate involving 1-Kb User Datagram Protocol-formatted packets, results showed packet loss rates of fewer than two packets per 10,000 transmitted packets and that operators could dependably continue to carry out their propulsion control-related responsibilities with the reduced level of communication system performance).

Cyberattack Protection for the Sentinel

A significant design issue regarding achieving cyberattack resilience for the protected system is the security designed into the sentinel, which can consist of a combination of both cyberattack defense and resilience solutions. The UVA design concept for sentinels builds on the engineering principle that they should be far less complex than the subsystems they protect, so as to provide the opportunity for employment of advanced security techniques that are limited in the scale and complexity of their application, such as software verification technologies applied for development and testing of sentinel software and software execution-related security techniques employed at the microelectronics level. For example, Draper Laboratory is currently engaged

in research activities focused on achieving system security through hardware and firmware.¹¹

In addition, the cost for applying diverse redundancy-based resilience for the sentinel itself can then be addressed within more acceptable cost boundaries. The UVA research efforts included operational demonstrations of prototypes that employed multivariant programming and moving target defenses within a sentinel design. These techniques proved to be effectively employed because the sentinels were designed to consist of algorithms for detection that were each implementable with fewer than 1,000 lines of code. The research served to support the concept that simple designs can indeed provide effective system resilience solutions and the basis for greater trust of the sentinel than would otherwise be possible.

Risk-Based Prioritization of Alternative Resilience Solutions

A critical aspect of cyberattack-resilient system design is the prioritization and selection of alternative system solutions. Part of the UVA research effort has focused on the development of a risk-based methodology for prioritizing potential solutions. Referred to as *cybersecurity requirements methodology* (CSRM), the process for prioritizing potential system solutions involves collaboration among three small groups of participants (two to three members per group) and requires approximately two months of effort to develop the results. The three groups are

- the blue team, consisting of individuals with significant operational experience regarding systems in the domain of the specific system under consideration for resilience solutions
- the red team, consisting of individuals with combined experience in both cybersecurity defense and offense

- a system engineering (SE) team, with experience in development of system requirements related to resilience.

Cyberattack risk analysis involves identification of potential system problems that can result in significant consequences and the likelihood of these problems occurring. The CSRM approach looks to the blue team to identify and prioritize potential system problems related to the operation of system functions and the corresponding consequences related to these problems that are of greatest concern.

The identified problems can range from functions being implemented improperly, to deviations from the technical performance specifications, to loss of functions (note that the blue team is not asked to relate the problems of concern to cyberattacks, but to any functional issue associated with the system's hardware, software or operational procedures). UVA's CSRM research project included a case trial discussed next, for which the U.S. Army provided the blue team. The SE team is called upon to derive system-level descriptions of potential cyberattack-resilient solutions that would address the higher-consequence concerns expressed by the blue team. A critical aspect of the SE team's effort is to utilize rapid prototyping as a mechanism for addressing the operational issues regarding the role of the human operators in reconfiguration decision making and execution of switchovers. To arrive at viable operational solutions, the SE team is expected to coordinate and adjust its resilience solutions based upon suggestions from the blue team.

For the use case trial, members of UVA and Virginia Commonwealth University (VCU) served as the SE team. To assure sufficient specificity in the resulting SE system descriptions, SysML, a formal approach that

employs available support tools for describing systems, is used. The use of such tools is an important ingredient of assuring that high-priority solutions will be properly understood by the red team and, if selected for implementation, designed as intended. The red team is provided with the SE team's potential solution descriptions and is called upon to evaluate how each of them would potentially impact the decisions of cyberattackers, based upon the added complexity of attacks, extended time to implement and test attacks, cost of attacks, risk of discovery, and so forth.

The red team is also called upon to evaluate the potential effectiveness of the resilience solutions, compared to use of additional conventional cyber defense solutions, and to assess the potential for a cyberattack to disrupt the detection or reconfiguration functions of the potential resilience solutions.

An important aspect of CSRM is the use of existing historical data bases, openly available through the MITRE Corporation, related to cyberattacks and their causes and the use of a UVA/VCU set of analysis tools intended to support the red team's analysis efforts. The red team members combine their analyses to prioritize the SE team's suggested resilience solutions based upon the influence on attack likelihoods and the advantage offered compared to extended use of cyberattack defense solutions. The SE team uses the red team results to modify its proposed designs and to suggest a prioritization based upon the integrated assessments of the blue and red teams.

The three teams together finalize their integrated prioritization, and the SE team modifies its SysML system description of the recommended, highest-priority resilience solutions. This result, combined with cost assessments for each of the considered solutions, provides a basis for decision making regarding

implementation of cyberattack resilience design features.

Role of System Operators

An important aspect of designing cyberattack-resilient systems relates to the roles of the human system operators. An important aspect of the UVA research effort required the development of prototype resilient systems, including systems for UAVs and police cars. The prototype systems included the development of reconfiguration procedures for operators to follow in response to sentinel alerts.

Based upon use trials, it became apparent that uncertainties related to the reasons for the cyberattack can greatly influence the reconfiguration responses of operators. For example, consider a cyberattack that would change navigation waypoints for a UAV conducting a search and rescue mission. Possibilities related to the purpose of the attack can range from the attacker wishing to 1) disrupt that search and rescue mission, 2) disrupt the air traffic control system in the area surrounding the UAV, or 3) steal the UAV by directing it to a specific location.

The best response to the detected attack could be different depending upon the actual purpose of the attack, and the human operators may have a broader context of the risk posed by the detected attack than the sentinel that made the detection. UVA's experimental research included the involvement of Air Force pilots remotely controlling UAVs and ground-based vehicles in simulated situations. Results have shown that operators can significantly delay resilience-related responses due to their uncertainty about how best to respond, and, in general, they are not prepared to confidently select sentinel-recommended solutions.¹²

To date, the experiments have proven to be very useful in illuminating issues that need attention related to operator response to detected

cyberattacks, but the research has not yet matured to the point where specific human/machine team solution concepts are ready for recommendation. In addition to receiving continued research attention, over time, feedback from actual operational situations will need to be gathered to develop acceptable arrangements for operators to participate in system reconfiguration decision making related to cyberattacks.

Based upon the results gathered from the eight years of study conducted by UVA's cyberattack resilience research team, the opportunity to employ cyberattack resilience capabilities in cyberphysical systems appears to be a promising complement to cyber defense solutions. It has been shown that simpler sentinel-based solutions can be candidates for immediate trial implementations, and it is suggested that this would be a productive step for introducing cyberattack resilience solutions into practice. However, while the UVA research efforts have demonstrated how resilience solutions can provide important benefits, continued research is needed. Research needs to include:

1. continued identification of cost-effective reusable resilience design patterns
2. development of analysis tools that support risk-related selection of solutions for employment as well as test and evaluation methodologies for candidate solutions
3. experimental-based efforts related to addressing operator roles and performance in decisions related to system reconfiguration
4. broadening resilience solutions to address information systems as well as physical systems
5. defining and implementing field data collection and evaluation methodologies to support improvement of machine algorithms and operator processes. ■

Acknowledgments

This material is based, in part, upon work supported by the Stevens Institute of Technology through the Systems Engineering Research Center (SERC) under U.S. Department of Defense (DOD) Contract HQ0034-13-D-0004. SERC is a federally funded University Affiliated Research Center managed by Stevens Institute of Technology. Any opinions, findings, and conclusions or recommendations expressed in this material are those of the authors and do not necessarily reflect the views of the DOD.

References

1. N. Falliere, L. O. Murchu, and E. Chien, "W32.Stuxnet dossier," Symantec Corporation. Mountain View, CA, 2011. [Online]. Available: https://www.symantec.com/content/en/us/enterprise/media/security_response/whitepapers/w32_stuxnet_dossier.pdf
2. C. G. Rieger, Di Gertman, and M. A. McQueen, "Resilient control systems: Next generation design research," in *Proc. 2nd Conf. Human Systems Interactions*, 2009, pp. 632–636.
3. R. A. Jones and B. M. Horowitz, "System-aware cyber security architecture," in *Proc. IEEE 2011 Eighth Int. Conf. Information Technology: New Generations*, pp. 914–917.
4. M. Franz, "Making multivariate programming practical and inexpensive," *IEEE Security Privacy*, vol. 16, no. 3, pp. 90–94, May/June 2018.
5. M. Albanese and S. Jajodia, "Defending from stealthy botnets using moving target defenses," *IEEE Security Privacy*, vol. 16, no. 1, pp. 92–97, Jan./Feb. 2018.
6. G. L. Babineau, R. A. Jones, and B. M. Horowitz, "A system-aware cyber security method for ship-board control systems with a method described to evaluate cyber security solutions," *IEEE Int. Conf. Technologies for Homeland Security (HST)*, 2012. doi: 10.1109/THS.2012.6459832.

7. B. T. Carter, G. Bakirtzis, C. R. Elks, and C. H. Fleming, "A systems approach for eliciting mission-centric security requirements," *Annu. IEEE Int. Systems Conf. (SysCon)*, 2018, pp. 1–8.
8. B. M. Horowitz, "Cybersecurity for unmanned aerial vehicle missions," *AFCEA SIGNAL*, Apr. 2016, pp. 40–43.
9. K. J. Higgins, "State trooper vehicles hacked," *Dark Reading*, Sept. 2015. [Online]. Available: <https://www.darkreading.com/attacks-breaches/state-trooper-vehicles-hacked-/d/d-id/1322415?>
10. C. Gay, B. Horowitz, P. Bobko, J. Elshaw, and I. Kim, "Operator suspicion and decision responses to cyber-attacks on unmanned ground vehicle systems," *Proc. Hum. Factors Ergon. Soc. Annu. Meet.*, vol. 61, no. 1, pp. 226–230, Sept. 28, 2017. doi: 10.1177/1541931213601540.
11. Draper, "Inherently secure processor." Accessed on: Oct. 2019. [Online]. Available: <https://www.draper.com/explore-solutions/inherently-secure-processor>.
12. C. Gay, B. Horowitz, J. J. Elshaw, P. Bobko, and I. Kim, "Operator suspicion and human-machine team performance under mission scenarios of unmanned ground vehicle operation," *IEEE Access*, vol. 7, pp. 36,371–36,379, 2019. doi: 10.1109/ACCESS.2019.2901258.

Barry M. Horowitz is the Munster Professor of Systems Engineering at the University of Virginia, Charlottesville. His research interests include system architecture and design. Contact him at h8e@virginia.edu.



IEEE COMPUTER SOCIETY

DIGITAL LIBRARY

Access all your IEEE Computer Society subscriptions at
computer.org/mysubscriptions

Handling of Personal Information and Deidentified, Aggregated, and Pseudonymized Information Under the California Consumer Privacy Act

William Stallings | WilliamStallings.com

The California Consumer Privacy Act (CCPA) is perhaps the most influential state-level data privacy law in the United States. It is the first of its kind to provide significant privacy rights to consumers and is likely to be a model for other state privacy laws. It also gives consumers a great deal of control over their personal information (PI).

Defining PI and industry applicability under the CCPA goes beyond what is typically covered by U.S. privacy laws. The CCPA will have a considerable impact on any company that does business in California and collects or processes PI. If a business does not fully comply with the CCPA, it risks monetary penalties and regulatory enforcement actions. Moreover, individuals can initiate a lawsuit if they are the victims of data breaches caused by noncompliance.

The CCPA was passed in June 2018 followed by minor revisions passed in August 2018. A set of more-substantive amendments were signed into law in October 2019. The CCPA, including its revisions and amendments, went into effect 1 January 2020. It will be supplemented by regulations that aim to specify more detailed requirements for businesses to implement the law. These regulations are currently being

drafted, and a final version is expected in spring 2020, just in time for them to come into force on 1 July 2020.

Most of the existing commentary on the CCPA has, unsurprisingly, focused on consumer protection rights, that is, the right to access information about oneself or decline permission for information to be sold. However, this article discusses a facet of the law that has received less detailed attention: how the act deals with obfuscation algorithms that can protect privacy, including deidentification, aggregation, and pseudonymization. This article considers whether those technical protections are sufficiently well defined and whether they are likely to be effective in practice.

Before considering the technical protections in more detail, it is useful to first understand the scope of the act. The three aspects that are particularly important are who is a “consumer,” which businesses are covered, and what PI means.

Consumers

The law applies to individuals designated as consumers. A *consumer* is anyone who is a resident of California and can be identified in any way (including a unique identifier). The term *resident* includes 1) any individual who is in California for other than a temporary or transitory purpose and 2) any individual who is domiciled in California but who is outside



the state for a temporary or transitory purpose. All other individuals are considered nonresidents.

In practice, businesses' databases are likely to contain information about both residents and nonresidents, and it may not be practical to devise rules that distinguish between them. The law may therefore serve to provide broader protection than it appears to do on paper.

Businesses

The CCPA regulates the activities of businesses with respect to consumer privacy. An entity is a business if it meets all of the following conditions:

- a sole proprietorship, partnership, limited liability company, corporation, association, or other legal entity that is organized or operated for the profit or financial benefit of its shareholders or other owners
- either collects consumers' PI, or PI is collected on its behalf

- alone or jointly with others, determines the purposes and means of the processing of consumers' PI
 - does business in the State of California
 - satisfies one or more of the following thresholds:
 - 1) has annual gross revenues in excess of US\$25 million
 - 2) alone or in combination, annually buys, receives for the business' commercial purposes, sells, or shares for commercial purposes, alone or in combination, the PI of 50,000 or more consumers, households, or devices
 - 3) derives 50% or more of its annual revenues from selling consumers' PI.
- In general terms, the law therefore applies to businesses that deal with large numbers of consumers or that sell PI.

PI

The law defines *PI* as information that identifies, relates to, describes, or is reasonably capable of being associated with or could reasonably be linked, either directly or indirectly, with a particular consumer or household. It is much broader than existing legal definitions of personally identifiable information; it includes, but is not limited to, the following:

- identifiers such as a real name, alias, postal address, unique personal identifier, online identifier, Internet Protocol (IP) address, email address, account name, social security number, driver's license number, passport number, or other similar identifiers
- signature, physical characteristics or description, address, telephone number, state identification card number, insurance policy number, education, employment, employment history, bank account number, credit or debit card number, or any other financial information, medical information, or health insurance information

- characteristics of protected classifications under California or federal law, including race, religious creed, color, national origin, ancestry, physical or mental disability, medical condition, or marital status
- commercial information, including records of personal property; products or services purchased, obtained, or considered; or other purchasing or consuming histories or tendencies
- biometric information
- Internet or other electronic network activity information, including, but not limited to, browsing or search history, and information regarding a consumer's interaction with an Internet website, application, or advertisement
- geolocation data
- audio, electronic, visual, thermal, olfactory, or similar information
- professional or employment-related information
- education information.

Importantly, PI also includes inferences drawn from any of the items listed in this section to create a profile about a consumer, for example, their preferences, characteristics, psychological trends, predispositions, behaviors, attitudes, intelligence, abilities, and aptitudes. This expands the consumer protection available in the context of targeted products and services.

Many of the items on the preceding list are not automatically PI. Data items, such as IP addresses, purchasing histories, and geolocation data, become PI only if they can be associated with a specific consumer or household. PI does not include publicly available information that is lawfully made available from federal, state, or local government records. It also does not include protected health information. This definition of PI goes well beyond that which is found in previous California and federal laws. As a result, businesses will need to track all of the PI they have stored in in-house databases and cloud storage, as compared to the typical practice of

simply keeping track of directly identifiable attributes.

Finally, and most importantly for the purposes of this article, the law does not include deidentified or aggregate consumer information; however, what amounts to deidentified or aggregate information is not necessarily as straightforward as it appears.

Deidentification

The CCPA specifically defines *deidentified information* as information that cannot reasonably identify, relate to, describe, or be capable of being associated with or be linked, either directly or indirectly, to a particular consumer, provided that a business that uses deidentified information does the following:

- implements technical safeguards that prohibit reidentification of the consumer to whom the information may pertain
- implements business processes that specifically prohibit reidentification of the information
- implements business processes that prevent the inadvertent release of deidentified information
- makes no attempt to reidentify the information.

As defined in the CCPA, the context for deidentification is that of an organization which collects PI on a group of individuals and stores these as a file of records, one per individual, often referred to as a *microtable*. Typically, a microtable consists of individual records, each of which contains values of attributes for a single individual or other entity. Specifically, a microdata table with s respondents and t attributes is an $s \times t$ matrix, where X_{ij} is the value of attribute j for data subject i .

Deidentification therefore creates a new data set that is assumed not to contain identifying data. Depending on its context and mission, an organization may retain the original data set for some applications for which security and privacy controls are applied, or it may discard that data set. In the

latter case, the organization uses only the deidentified data set.

Businesses use deidentified data for a variety of applications, including the testing of applications that process PI, the statistical reporting on certain characteristics and events, the publishing of data for research purposes, and the performing of data analytics on behalf of another party.

The process of deidentification involves removing all direct identifiers. A *direct identifier* is a set of attributes in a data set that enables the unique identification of a data principal. Examples of direct identifiers include name, email address, home address, telephone number, health insurance number, and social security number. The process also involves the obfuscation of quasi-identifiers (QIs) in some fashion. QIs by themselves do not identify a specific individual but can be aggregated and linked with other information to identify data subjects. Examples of QIs include sex, marital status, postal code or other location information, a significant date (for example, birth, death, hospital admission, discharge, autopsy, specimen collection, or visit), diagnostic information, profession, ethnic origin, visible minority status, and income.

Examples of obfuscation include removing some QIs altogether, perturbing some QI values by a random amount, or replacing precise QI values with value ranges.¹ In any case, the resulting deidentified data are still in the form of a microtable, with one record for each deidentified individual.

Effective deidentification can substantially reduce privacy risk; however, even when a data set has been deidentified, there may remain the risk that an unauthorized party could reidentify that data set. The threat of reidentification of deidentified data is a serious one. The Electronic Privacy Information Center documents the following examples of the reidentification of deidentified data:²

- *Netflix study*: Netflix publicly released 100 million records regarding how its users had rated movies over a six-year period. Although Netflix attempted to deidentify the data, it was feasible, with only six movie ratings and the approximate date of the ratings, to identify individuals 99% of the time
- *America Online's (AOL's) release of user data*: In 2006, AOL publicly posted 20 million search queries for 650,000 AOL search engine users. These queries summed up three months of activity. Before the data were released, AOL deidentified them by removing identifying information such as user names and IP addresses; however, these identifiers were replaced with unique identification numbers so that researchers could still make use of the data. Even though the data were deidentified before their release, within a relatively short period of time, journalists were able to trace user queries to specific individuals.
- *Unique identification through zip code, birthdate, and sex*: According to a study of census data by Latanya Sweeney,³ 87% of the American population has a unique combination of zip code, birthdate, and sex. This means that the combination of these three pieces of information is sufficient to identify many individuals.

The CCPA explicitly states that the law shall not restrict a business's ability to collect, use, retain, sell, or disclose consumer information that is deidentified, and that deidentified data are not included in the definition of personal data.

In some of the literature, the term *deidentification* refers to a process that includes a reidentification code. The mapping between the code and the individual is stored separately and securely, such that the deidentified data cannot be reidentified without access to the code. When the term is used with this meaning, deidentification without the use of a code

is referred to as *anonymization*. The CCPA requires that there not be a reidentification code for the data to be deidentified.

Aggregation

There are often instances in which an organization wishes to use summary information about groups of individuals in applications that do not require the individuals to be identified and do not require the storage of even deidentified individual records in a microtable. Examples of this include actuarial or market research studies. In these cases, to preserve privacy, the organization providing the information aggregates the PI in a data set into summary information, which is useful for the application but does not enable the identification of individuals.

The aggregated data are in the form of a summary table, also called a *macrodata table*, which is typically 2D, with the rows and columns representing two different attributes. Thus, if the two attributes are *A* and *B*, the table can be expressed as $A \times B$. A summary table contains aggregated data about individuals derived from microdata sources. For example, a table that lists individuals by five-year age categories and their total annual income in increments of US\$10,000 is composed of statistical cells, such as the cell "35–39 years of age, US\$40,000 to US\$49,999 annual income."

The CCPA defines *aggregate consumer information* as that which relates to a group or category of consumers, from which individual consumer identities have been removed and is not linked or reasonably linkable to any consumer or household, including via a device.

The CCPA explicitly states that the law shall not restrict a business's ability to collect, use, retain, sell, or disclose consumer information that is considered aggregate consumer information. The CCPA also indicates that aggregated data are not included in the definition of personal data.

Pseudonymization

The CCPA defines *pseudonymization* as the processing of PI in a manner that renders the PI no longer attributable to a specific consumer without the use of additional information, provided that the additional information is kept separately and is subject to technical and organizational measures, which ensures that the PI is not attributable to an identified or identifiable consumer. In practice, pseudonymization is achieved by replacing the direct identifier(s) with a unique code(s) or pseudonym(s) for each record in a PI microtable. Other fields in the record, including QIs, are not altered.

Pseudonymized information enables an organization to make PI available to departments within the organization that use the PI for analysis but do not need to know the identities of the individuals represented in the microtable. It also allows for the linking of associated records from different data sets without revealing the identity of the data subjects.

Because pseudonymization does not alter any of the QI attributes, a pseudonymized data set is vulnerable to reidentification attacks. Accordingly, pseudonymized records are considered PI by the CCPA; as such, they must be protected and are subject to all the consumer rights of any other PI.

In some of the literature, the term *pseudonymization* involves not only replacing direct identifiers with a code but also applying deidentification techniques to the QI attributes. The CCPA refers to such processing as *pseudonymization and deidentification*.

Practical Approaches for Depersonalized Data

Depersonalized data are data derived from records containing PI but which are no longer linkable to individuals. All three forms discussed in this article (aggregation, deidentification, and pseudonymization) are useful for some business applications. Businesses subject to the CCPA must find ways

to continue to use these applications while complying with the CCPA.

The easiest case is aggregation. Although it is possible in some contexts to obtain PI from an aggregated data set, it is relatively easy to overcome this risk.¹ The CCPA excludes aggregated data from the definition of PI, so, for all practical purposes, the law does not impose a new burden on the use of such data.

The CCPA also excludes deidentified data from the definition of PI. However, as mentioned previously, recent research suggests that it is technically challenging to guarantee that the deidentification process used by a business renders reidentification impractical. As a result, organizations that seek to deidentify PI data sets must be mindful of the potential for reidentification, either from the transformed data set alone or in conjunction with other sources of data. Businesses could confirm the strength of their deidentification method either through statistical analysis or by removing many of the QIs from the data set. Both of these approaches are recommended, for example, in the Health Insurance Portability and Accountability Act of 1996.

In essence, there is a tradeoff between the utility of a deidentified data set and its resistance to reidentification. The more aggressive the use of techniques such as removing QIs or approximating QI values, the less useful the resulting microtable is for a variety of purposes. The challenge for businesses is to apply technical means that ensure the utility of the data but also to make certain that the purpose of the law (to protect consumers) is fulfilled, thus limiting the risk of being noncompliant.

Finally, the CCPA considers pseudonymized information to still be PI, so, businesses must make sure that pseudonymized information is adequately protected.

With its broad definition of PI, the CCPA will require California businesses to broaden their

data governance efforts to include the effective management of California residents' PI; this will require automated means of maintaining an inventory of the PI that resides within their organization. In addition, businesses must effectively manage consent requirements and monitor the processing of PI to ensure compliance with the CCPA.

At the same time, the CCPA clearly exempts deidentified data (so long as the data are effectively deidentified) and aggregate data. Hence, businesses may continue to conduct statistical, analytical, and research efforts on such data without regard to the new law and its accompanying regulations. ■

References

1. W. Stallings, *Information Privacy Engineering and Privacy by Design*. Upper Saddle River, NJ: Pearson, 2020.
2. Electronic Privacy Information Center, "Concerning the re-identification of consumer information," Washington, D. C., 2017. [Online]. Available: <https://epic.org/privacy/reidentification/>
3. L. Sweeney, "Simple demographics often identify people uniquely," Data Privacy Lab, School of Comput. Sci., Carnegie Mellon Univ., Pittsburgh, PA, Tech. Rep. LIDAP-WP4, 2000. [Online]. Available: <https://dataprivacylab.org/projects/identifiability/paper1.pdf>

William Stallings is the author of numerous textbooks on cybersecurity, cryptography, operating systems, and computer networking. His latest book is *Information Privacy and Privacy by Design* (Pearson, 2020). He created and maintains the Computer Science Student Resource site at ComputerScienceStudent.com, which provides documents and links on a variety of subjects of general interest to computer science students (and professionals). He is a member of the editorial board of *Cryptologia*, a scholarly journal devoted to all aspects of cryptology. Contact him at wllmst@me.com.

Blockchain Compliance With Federal Cryptographic Information-Processing Standards

James P. Howard II | Johns Hopkins Applied Physics Laboratory
Maria E. Vachino | Easy Dynamics Corp.

Under current Federal Information Security Management Act of 2002 (FISMA) requirements, all new federal IT programs and modernization efforts using blockchain must meet National Institute of Standards and Technology (NIST) cryptographic standards. This article evaluates four major blockchain technologies—Ethereum, Hyperledger Fabric, R3's Corda, and Multichain—to determine their level of NIST compliance.

Overview of Standard Compliance

Blockchain has taken the IT world by storm. Although it will not solve all of the problems for which it has been proposed, there are use cases for which blockchain is a viable data storage mechanism. These cases include IT projects in the federal government, whether developed publicly, privately, or as a public-private partnership.

Using an evaluation standard based on relevant NIST cryptographic standards [cryptographic hashing, digital signatures, and pseudorandom number generators (PRNGs)], we evaluate each of the aforementioned blockchain technologies to determine its level of NIST compliance. This analysis is vital to federal IT managers and contractors because NIST cryptographic standards are mandatory

under current FISMA requirements.¹ All new IT programs and modernization efforts using blockchain must meet these standards. Federal IT managers can use the information in this article to determine which blockchain platforms are suitable for their projects.

To evaluate compliance with NIST standards, we decomposed the analysis into two steps. First, we consider whether the cryptographic algorithms and key lengths used by each blockchain platform meet NIST requirements. Second, if the algorithm is acceptable, we determine whether the implementation has been validated by the NIST Cryptographic Module Validation Program. Both requirements are necessary to ensure compliance with NIST cryptographic standards.

Blockchain Platforms

Many blockchain-based technologies have emerged since the initial introduction of Bitcoin. Some of these are relatively trivial systems that cannot be used for general purposes. However, many are business-oriented applications that can be considered for federal projects. In the interest of simplifying this analysis, we established criteria to reduce the full breadth of available blockchain technologies to a handful of technologies meeting a primary set of characteristics. These characteristics demonstrate key properties required for any technology used in a federal project.



Selection Criteria

The federal government has been investigating potential applications of blockchain. Areas considered or under consideration include supply chain management² and financial systems.³ These application areas are necessarily as diverse as the services the federal government provides. As such, there are many requirement definitions that blockchain technology could be expected to fulfill.

However, blockchain is not a single unified technology. Some blockchain implementations provide rich interfaces to support complex distributed applications. Other implementations provide more limited functionality, with limited programmability. Different blockchain systems are better suited to solving different business problems. Accordingly, we considered blockchain implementations that fit the following parameters.

1. The device is supported by a single business or consortium responsible for developing standards and guiding future work.
2. The system allows independent, private chains without limiting the application to a single global network.
3. The technique is well supported by developer libraries that allow software developers easy access to data and protocols of the blockchain system.

These parameters are designed to provide the core services necessary for almost any federal IT project using blockchain technology.

Selection of Blockchains for Evaluation

Based on the criteria listed in the previous section, we selected four blockchain technologies. Where possible, we detail related products that should be considered equivalent to the selected blockchain technologies.

Hyperledger Fabric. The Hyperledger Project is a collection of independent blockchain frameworks and tools that provide a diverse set of capabilities. Hyperledger Fabric is a general-purpose blockchain system, originally developed by IBM,⁴ that focuses on flexibility for a range of deployment needs. Other Hyperledger framework projects include Iroha, which is tailored to mobile applications, and Hyperledger Indy, which targets identity-management applications.

The project is overseen by the Linux Foundation, based in the United States. Direct control of the Hyperledger ecosystem is provided by the Hyperledger Project's Governing Board.

Hyperledger Fabric is a private blockchain requiring confirmed identification to access the blockchain in a permissioned configuration. According to the Hyperledger Project, developers assume that business blockchain

networks will operate in an "environment of partial trust," with that partial trust enforced through the identification requirement.⁵

Hyperledger Fabric is adequately supported by developer libraries. There are software development kits available for JavaScript via Node.js for Java and all Java virtual machine (JVM)-based languages. The Hyperledger Project also provides Python, representational state transfer, and Go libraries. Hyperledger Fabric meets the selection criteria and will be evaluated against the NIST cryptographic standards.

Ethereum. Ethereum is an open source blockchain system designed to support distributed applications called *smart contracts*.⁶ The Ethereum Foundation, based in Switzerland, guides development and provides limited oversight.

Ethereum operates on its own global public blockchain network but can also be used to create private blockchains. These private blockchains do not require access to external resources and can run independently. Further, Ethereum documentation provides explicit instructions for creating private Ethereum networks.

Ethereum is also well supported with developer libraries. Ethereum libraries are available for Python, Java, and JavaScript, making integration with major IT products feasible. Third-party libraries are also available for Ruby, and Java libraries are accessible from JVM-based languages. Ethereum meets the selection criteria and will be evaluated against NIST cryptographic standards.

R3 Corda. The Corda system is an open source distributed ledger technology based on blockchain. However, unlike previously described blockchain architectures, Corda is not a single chain of blocks where all nodes have all blocks. Instead, transactions are only added to the chains owned by nodes that require access

to those transactions.⁷ The design of Corda allows users to ensure that only parties who need to know certain data on the ledger have access to that data. Although Corda does not strictly meet the requirements of a blockchain technology, it borrows substantially from blockchain and generally bills itself as a blockchain. For the purposes of this analysis, it has therefore been included.

Corda is managed by R3 LLC, a New York-based firm with members that include a number of international banks. R3 has released Corda as open source under the Apache licensing model but also provides a Corda Enterprise product that includes service level agreements (SLAs), support for enterprise applications, and technical support.

Corda does not provide a public blockchain option and is geared toward use as a private and permissioned blockchain. Corda manages permissions through identities, using X.509 certificates to provide identities to individuals, roles, and entities.⁸ This has the advantage of allowing developers to use an existing or compatible framework for identity management to govern access to their blockchain.

Because Corda is implemented on the JVM, it is relatively easy to access via Java and Java-based languages. However, we were unable to identify libraries for directly accessing Corda from outside the JVM. Despite this limitation, we can conclude that Corda marginally meets the selection criteria. We will evaluate it against the NIST cryptography standards.

Multichain. Multichain is a blockchain platform available in an open source version licensed according to the terms of the GNU General Public License (GPL) and a commercial version that does not include the GPL restrictions but does include an SLA. Multichain is provided by Coin Sciences Ltd., a United Kingdom-based company that conducts Multichain development and sells the commercial version.

Multichain provides private chains for application developers and does not include a public option. This platform uses a system of private permissions for accessing and adding data to the chain. The privacy system is secured by submitting transactions that contain metadata to document and providing credentials for access control changes.

Multichain has a clearly defined application programming interface exposed via JavaScript Object Notation (JSON)-Remote Procedure Call protocol. Accordingly, any JSON library will allow for Multichain connectivity. However, this does mean that interfaces are not exposed in native forms for developers. In addition, Multichain fully supports the Bitcoin protocol, and any Bitcoin-compatible library can be used with Multichain.⁹

We conclude that Multichain marginally meets the selection criteria. We will evaluate it against the NIST cryptography standards.

Other Blockchain Technologies

Several other blockchain technologies considered for evaluation in this analysis substantially failed to meet the selection criteria. For reference, we include them here along with the reason for failure.

Openchain is a platform developed by Coinprism to provide an asset tracking mechanism based on blockchain.¹⁰ Openchain is available in an open source model under the Apache license with support from Coinprism. However, Coinprism appears to have shut down in early 2018, although the open source edition is still available on GitHub. Given the lack of a central authority guiding Openchain development, we have excluded it from this analysis.

The Stellar blockchain by the Stellar Development Foundation is not a general-purpose blockchain but is instead intended for financial transactions.¹¹ Chain Core is another financial transaction blockchain. Because neither platform is

general purpose, they are excluded from this analysis.

Similarly, we have excluded many other single-purpose digital currencies. These are not general-purpose blockchains, cannot provide critical functionality, and are not suitable for federal deployment in most cases.

Analysis Criteria

NIST Federal Information Processing Standards

NIST is responsible for providing the Federal Information Processing Standards (FIPS) series of documents. These documents describe various methods for standardizing computer technology throughout the federal government. Because the federal government is a leading buyer of computational resources, FIPS has become the global de facto standard.

Several FIPS documents focus on cryptographic and security standards to ensure compatibility across vendors and agencies. We detail the cryptographic standards relevant to blockchain implementations as follows.

Hash Algorithms

Cryptographic hash functions are specialized hash algorithms that are computationally infeasible to revert.¹² This makes the hash algorithms suitable for use in cryptographic applications. Blockchains rely on this computational difficulty for multiple aspects of security.

NIST has provided approvals for a number of cryptographic hash algorithms for federal use. Approved standard hashes were developed in multiyear open contests sponsored by NIST with substantial public review. Because of the open process, these standards are relatively pervasive, and approved hash algorithms are commonly available in developer libraries and are used for applications across the software spectrum.

The first of these approvals is called *Secure Hash Algorithm (SHA)*-2.

SHA-2 is the second generation of the SHA series and provides six standard forms: SHA-224, SHA-256, SHA-384, SHA-512, SHA-512/224, and SHA-512/256. SHA-2 has two primary definitions, one for processing 512-b-wide input blocks and one for processing 1,024-b input blocks. In addition to the input size, these variants differ in internal state size and output hash size. They are summarized in Table 1.

The second current approval is the SHA-3 family, the third generation of the SHA series of hash algorithms. SHA-3 is based on the Keccak family of hash algorithms and was selected by NIST in 2015. Like SHA-2, the SHA-3 family provides six standard forms: SHA-3-224, SHA-3-256, SHA-3-384, SHA-3-512, SHAKE128(d), and SHAKE256(d). These also differ from each other in internal state size and output size. The SHAKE128(d) and SHAKE256(d) algorithms are also interesting because they provide arbitrary output sizes for the hash. However, despite coming from the same series, there is little relationship in the operation of SHA-2 and SHA-3. The SHA-3 family is summarized in Table 2.

Additional variants of the Keccak family are authorized by NIST. The cSHAKE128 and cSHAKE256 algorithms are 128- and 256-b hashes that are customizable with respect to use and intent. The TupleHash128 and TupleHash256 are 128- and 256-b implementations of a hash based on Keccak. Instead of operating on an input stream, the TupleHash functions are block hashes. That is, instead of accepting an arbitrary-length bit stream, the algorithms accept multiple arbitrary-length bit streams. Finally, the ParallelHash128 and ParallelHash256 algorithms are 128- and 256-b implementations of a hash algorithm designed to leverage multiple processors to speed computation.

Digital Signature Algorithms

Digital signatures provide a mechanism to ensure information's authenticity.¹³

Table 1. An overview of SHA-2 variants.

Variant	Internal state size (bits)	Output size (bits)	Input size (bits)
SHA-224	256	224	512
SHA-256	256	256	512
SHA-384	512	384	1024
SHA-512	512	512	1024
SHA-512/224	512	224	1024
SHA-512/256	512	256	1024

Table 2. An overview of SHA-3 variants.

Variant	Internal state size (bits)	Output size (bits)	Input size (bits)
SHA-3-224	1,600	224	1,152
SHA-3-256	1,600	256	1,088
SHA-3-384	1,600	384	832
SHA-3-512	1,600	512	576
SHAKE128(<i>d</i>)	1,600	<i>d</i>	1,344
SHAKE256(<i>d</i>)	1,600	<i>d</i>	1,088

Digital signatures are used extensively in blockchain implementations to identify the source of incoming data.

NIST provides three digital signature standards. The Digital Signature Algorithm (DSA) is defined by two parameters and is typically denoted as DSA- (L, N) , where the parameters L and N are the bit lengths of the key's components. NIST has approved DSA for three combinations of L and N : (2,048, 224), (2,048, 256), and (3,072, 256). Implementations of DSA may use any approved hash algorithm as provided in FIPS 180.

The Rivest–Shamir–Adleman (RSA) standard is defined by its key, where larger keys represent greater security. NIST has specified two permissible key sizes: 2,048 and 3,072 b. Unlike DSA, RSA key sizes are independent of the size of the

hash used. However, like DSA, any approved hash algorithm may be used with RSA.

The third option for digital signatures is the Elliptic Curve Digital Signature Algorithm (ECDSA). The elliptic curve cryptography (ECC) standard, rather than presenting a single algorithm, is a family of related algorithms defined by the curve used to process keys. NIST provides a list of recommended curves for federal use but does not mandate a single curve type or associate key length. Like the other digital signature algorithms, any hash used for a digital signature must be approved in FIPS 180.

PRNGs

In both security and nonsecurity applications, reliable and unpredictable random numbers are essential. The

random number generator (RNG) problem is a particularly difficult problem for conventional computers because they function deterministically. However, random numbers are essential in cryptography for creating keys. Blockchains using lottery systems for block sealing also require random numbers, regardless of the lottery scheme used. In block sealing, a block is committed to the distributed ledger with a hash of the block so that the next block may be based on it. This process is repeated for every block in a blockchain. Many developer libraries include RNGs (or PRNGs) of varying quality, and NIST has mandated that federal systems must use one of several high-quality RNGs.

NIST has specified two families of PRNGs, one based on block cipher algorithms and one based on hashing algorithms. Both require a source of entropy, or random noise, that can seed the process. The cipher-based algorithms are called *Counter-Deterministic Random Bit Generators* (CTR_DRBG) and can be used with any NIST-acceptable cipher algorithm. Accordingly, CTR_DRBG can be used with Advanced Encryption Standard (AES)-128, AES-192, and AES-256. The hash-based algorithms are Hash_DRBG and Keyed-Hash Message Authentication Code DRBG, and both also work with NIST-acceptable hash algorithms.

Evaluation of Blockchain Platforms

In this section, we apply the evaluation criteria laid out in the “Analysis Criteria” section to the four blockchain implementations listed in the “Blockchain Platforms” section. The results are summarized in Table 3.

Hyperledger Fabric

Hash Algorithms. Hyperledger Fabric uses SHA-256 for block sealing. SHA-256 is an acceptable hash algorithm according to NIST. However, Hyperledger Fabric is implemented

in the Go programming language and uses a Go SHA-256. This implementation has not been validated by NIST.

Digital signatures. For digital signatures and identity management, Hyperledger Fabric provides a built-in certificate authority (CA).¹⁴ Hyperledger Fabric and its CA only support ECDSA signatures using NIST-permitted P-256, P-384, and P-521 curves. These are paired with SHA-256, SHA-384, and SHA-512, respectively, for digital signature hash algorithms, which are all considered acceptable by NIST. However, Hyperledger Fabric uses a Go implementation of ECDSA, which has not been validated by NIST.

Ethereum

Hash algorithms. The Ethereum platform uses a proof-of-work system to produce consensus among nodes and is therefore energy intensive.¹⁵ However, the Ethereum Foundation is working on evolving the platform to rely on proof of stake. The proof-of-work system used by Ethereum is Ethash, which, like the SHA-3 family, is based on the Keccak hash algorithm. However, Ethash is incompatible with SHA-3 because SHA-3 requires a different input-padding scheme. Because of the pending change to proof of stake, the Ethereum platform can be considered a moving target for analysis and development. The analysis provided herein is current as of the publication date. Because Ethash does not meet NIST requirements, the implementation cannot be validated.

Digital signatures. Ethereum also fails to comply with the NIST requirements for digital signatures. Ethereum uses the secp256k1 elliptic curve,¹⁶ which is not one of the elliptic curves approved by NIST.

Because secp256k1 does not meet NIST requirements, the implementation cannot be validated.

R3 Corda

Hash algorithms. The Corda consensus mechanism assigns authorities called *notaries* for each data element.⁷ When a change of state occurs, the assigned notary attests to current data elements that have not been used for another state transition. This process ensures transactions are completed and consensus is achieved across the blockchain. Despite these differences from other consensus mechanisms, Corda uses SHA-256 for transaction sealing. SHA-256 is an acceptable hash algorithm according to NIST.

R3 Corda is implemented in the Kotlin and Java programming languages, and the SHA-256 implementation provided by the native Java environment is used for hashing. There are multiple implementations of the Java cryptographic library. Some Java cryptographic libraries have been validated by NIST and, if used, would be sufficient to ensure a validated hash algorithm is used.

Digital signatures. For digital signatures, Corda supports a wide range of digital signature algorithms. RSA is supported with SHA-256 as the hashing algorithm. For ECC, P-256 is also supported with SHA-256 as the hashing algorithm. Both combinations are acceptable according to NIST.

R3 Corda is implemented in the Kotlin and Java programming languages, and the digital signature

implementations are provided by the native Java environment. Similar to cryptographic hashing, use of a NIST-validated Java cryptographic library is sufficient to ensure a validated hash algorithm is used.

Multichain

Hash algorithms. Mining in Multichain is based on a round-robin process of authorized miners.¹⁷ That is, a miner must receive permission to participate in the mining network and can only mine blocks at some set frequency. Block sealing occurs similarly to other blockchains. The protocol for Multichain is based on Bitcoin, and the same design decisions apply.¹⁸ For block sealing, Multichain uses SHA-256, a NIST-approved hashing algorithm.

Digital signatures. For digital signatures, Multichain supports only one digital signature algorithm. Like Ethereum, this algorithm is secp256k1.¹⁹ This is not a NIST-approved digital signature algorithm, and no other digital signature algorithms are provided. Because secp256k1 does not meet NIST requirements, the implementation cannot be validated.

This article presented a high-level overview of four general-purpose blockchain systems and evaluated them against the relevant NIST cryptographic standard requirements. We found that one blockchain system, R3's Corda, can

Table 3. A summary of blockchain platform evaluation.

Blockchain	Hash	Digital signatures	PRNG	Validation
Hyperledger Fabric	SHA-256	ECDSA (P-256, P-385, P-521)	Go	No
Ethereum	Ethash	ECDSA (secp256k1)	Go	No
R3 Corda	SHA-256	RSA, ECDSA (P-256)	Java	Yes*
Multichain	SHA-256	ECDSA (secp256k1)	C	No

*If validated libraries are used.

meet the NIST requirements, provided the full system stack does not change the calculus. We believe this analysis is valuable because federal IT projects are mandated to meet the NIST requirements under FISMA guidelines. This analysis can also be used by private system integrators and developers. The NIST requirements are frequently used by nonfederal actors because of their rigor and ready availability. Blockchain offers an additional advantage to private users because they can invite other users to join the system after development is completed. Accordingly, private developers who foresee eventually inviting federal actors to participate in their blockchain can meet the NIST requirements now with the understanding that this will support future expansion into the federal arena. ■

Acknowledgment

Information in this article is based on research funded by the U.S. Department of Homeland Security Science and Technology Directorate (DHS S&T). Any opinions contained herein are those of the authors and do not necessarily reflect those of DHS S&T. For more information, please contact Anil John (anil.john@hq.dhs.gov).

References

1. E. Hulitt and R. B. Vaughn, "Information system security compliance to FISMA standard: A quantitative measure," *Telecommun. Syst.*, vol. 45, nos. 2–3, pp. 139–152, 2010.
2. H. M. Kim and M. Laskowski, "Toward an ontology-driven blockchain design for supply-chain provenance," *Intelligent Syst. Accounting, Finance Manage.*, vol. 25, no. 1, pp. 18–27, 2018.
3. Y. Guo and C. Liang, "Blockchain application and outlook in the banking industry," *Financial Innovation*, vol. 2, no. 1, pp. 24–36, 2016.
4. E. Androuraki, A. Barger, V. Bortnikov, C. Cachin, K. Christidis, A. De Caro et al., "Hyperledger Fabric: A distributed operating system for permissioned blockchains," in *Proc. 13th EuroSys Conf.*, 2018, p. 30–45.
5. Hyperledger Architecture Working Group, "Hyperledger architecture," Hyperledger, 2018. [Online]. Available: https://www.hyperledger.org/wp-content/uploads/2017/08/Hyperledger_Arch_WG_Paper_1_Consensus.pdf
6. S. Omohundro, "Cryptocurrencies, smart contracts, and artificial intelligence," *AI Matters*, vol. 1, no. 2, pp. 19–21, 2014.
7. T. Bocek and B. Stiller, "Smart contracts—blockchains in the wings," in *Digital Marketplaces Unleashed*. Berlin, Germany: Springer-Verlag, 2018, pp. 169–184.
8. M. Benji and M. Sindhu, "A study on the Corda and Ripple blockchain platforms," in *Advances in Big Data and Cloud Computing*. New York: Springer-Verlag, 2019, pp. 179–187.
9. O. Odiete, R. K. Lomotey, and R. Deters, "Using blockchain to support data and service management in IoV/IoT," in *Security with Intelligent Computing and Big-data Services*, S.-L. Peng, S.-J. Wang, V. E. Balas, and M. Zhao, Eds. New York: Springer-Verlag, 2018, pp. 344–362.
10. B. Iancu and C. Sandu, "A cryptographic approach for implementing semantic web's trust layer," in *Innovative Security Solutions for Information Technology and Communications*, I. Bica and R. Reyhanitabar, Eds. New York: Springer-Verlag, 2016, pp. 127–136.
11. M. Iansiti and K. R. Lakhani, "The truth about blockchain," *Harv. Bus. Rev.*, vol. 95, no. 1, pp. 118–127, 2017.
12. B. Preneel, "Cryptographic hash functions," *European Trans. Telecommun.*, vol. 5, no. 4, pp. 431–448, 1994.
13. S. Goldwasser, S. Micali, and R. L. Rivest, "A digital signature scheme secure against adaptive chosen-message attacks," *SIAM J. Comput.*, vol. 17, no. 2, pp. 281–308, 1988.
14. N. Zupan, K. Zhang, and H.-A. Jacobsen, "Hyperpubsub: A decentralized, permissioned, publish/subscribe service using blockchains," in *Proc. 18th ACM/IFIP/USENIX Middleware Conf.: Posters and Demos*, 2017, pp. 15–16.
15. M. Vukolić, "The quest for scalable blockchain fabric: Proof-of-work vs. BFT replication," in *International Workshop on Open Problems in Network Security*. New York: Springer-Verlag, 2015, pp. 112–125.
16. K. Iyer and C. Dannen, "Cryptoeconomics and game theory," in *Building Games with Ethereum Smart Contracts*. New York: Springer-Verlag, 2018, pp. 129–141.
17. K. Christidis and M. Devetsikiotis, "Blockchains and smart contracts for the Internet of Things," *IEEE Access*, vol. 4, pp. 2292–2303, May 2016.
18. C. Pahl, N. El Ioini, and S. Helmer, "A decision framework for blockchain platforms for IoT and edge computing," in *Proc. 3rd Int. Conf. Internet of Things, Big Data and Security*, 2018, pp. 105–113.
19. N. Courtois, G. Song, and R. Castellucci, "Speed optimizations in Bitcoin key recovery attacks," *Tatra Mountains Math. Publications*, vol. 67, no. 1, pp. 55–68, 2016.

James P. Howard II is a researcher at the Johns Hopkins Applied Physics Laboratory. Howard received a Ph.D. in public policy from the University of Maryland, Baltimore County. He is a Member of the IEEE, the Association for Computing Machinery, and the American Association for the Advancement of Science. Contact him at james.howard@jhu.edu.

Maria E. Vachino is a director at Easy Dynamics Corp. Vachino received an M.S. in cybersecurity from the Johns Hopkins Whiting School of Engineering, Baltimore, Maryland. Contact her at mvachino@easydynamics.com.

Last Word *continued from p. 72*

new product, and now think in terms of continuous deployment of new features. As I said previously, policy makers tend to think in terms of multiple years to get a law or regulation in place, and then more years as the case law builds up around it so everyone knows what it really means. It's like tortoises and hummingbirds.

Technology is inherently global. It is often developed with local sensibilities according to local laws, but it necessarily has global reach. Policy is always jurisdictional. This difference is causing all sorts of problems for the global cloud services we use every day. The providers are unable to operate their global systems in compliance with more than 200 different—and sometimes conflicting—national requirements. Policy makers are often unimpressed with claims of inability; laws are laws, they say, and if Facebook can translate its website into French for the French, it can also implement their national laws.

Technology and policy both use concepts of trust, but differently. Technologists tend to think of trust in terms of controls on behavior. We're getting better (at what?)—NIST's recent work on trust is a good example—but we have a long way to go. For example, Google's Trust and Safety Department does a lot of AI and ethics work largely focused on technological controls. Policy makers think of trust in more holistic societal terms: trust in institutions, trust as the ability not to worry about adverse outcomes, consumer confidence. This dichotomy explains how techies can claim bitcoin is trusted because of the strong cryptography, but policy makers can't imagine calling a system trustworthy when you lose all your money if you forget your encryption key.

Policy is how society mediates how individuals interact with society.

Technology has the potential to change how individuals interact with society. The conflict between these two causes considerable friction, as technologists want policy makers to get out of the way and not stifle innovation, and policy makers want technologists to stop moving fast and breaking so many things.

Finally, techies know that code is law—that the restrictions and limitations of a technology are more fundamental than any human-created

Technology and policy both use concepts of trust, but differently.

legal anything. Policy makers know that law is law, and tech is just tech. We can see this in the tension between applying existing law to new technologies and creating new law specifically for those new technologies.

Yes, these are all generalizations and there are exceptions. It's also not all either/or. Great technologists and policy makers can see the other perspectives. The best policy makers know that for all their work toward consensus, they won't make progress by redefining pi as three. Thoughtful technologists look beyond the immediate user demands to the ways attackers might abuse their systems, and design against those adversaries as well. These aren't two alien species engaging in first contact, but cohorts who can each learn and borrow tools from the other. Too often, though, neither party tries.

In October, I attended the first ACM Symposium on Computer Science and the Law. Google counsel Brian Carver talked about his experience with the few computer science grad students who would attend his Intellectual Property and Cyberlaw classes every year at UC Berkeley. One of the first things he

would do was give the students two different cases to read. The cases had nearly identical facts, and the judges who'd ruled on them came to exactly opposite conclusions. The law students took this in stride; it's the way the legal system works when it's wrestling with a new concept or idea. But it shook the computer science students. They were appalled that there wasn't a single correct answer.

But that's not how law works, and that's not how policy works. As the technologies we're creating become more central to society, and as we in technology continue to move into the public sphere and become

part of the increasingly important policy debates, it is essential that we learn these lessons. Gone are the days when we were creating purely technical systems and our work ended at the keyboard and screen. Now we're building complex socio-technical systems that are literally creating a new world. And while it's easy to dismiss policy makers as doing it wrong, it's important to understand that they're not (Qualify this somehow? From their point of view?). Policy making has been around a lot longer than the Internet or computers or any technology. And the essential challenges of this century will require both groups to work together. ■

Bruce Schneier is a lecturer and fellow at the Harvard Kennedy School and special advisor to IBM Security. His new book is *Click Here to Kill Everybody: Security and Survival in a Hyper-Connected World*. He organized a one-day track on public-interest technology at the RSA Conference in March 2019 in San Francisco. He maintains a resources page at www.public-interest-tech.com. Contact him via www.schneier.com.



Bruce Schneier
Harvard University

Technologists vs. Policy Makers

S ometime around 1993 or 1994, during the first Crypto Wars, I was part of a group of cryptography experts that went to Washington to advocate for strong encryption. Matt Blaze and Ron Rivest were with me; I don't remember who else. We met with then Massachusetts Representative Ed Markey. (He didn't become a senator until 2013.) Back then, he and Vermont Senator Patrick Leahy were the most knowledgeable on this issue and our biggest supporters against government backdoors. They still are.

Markey was against forcing encrypted phone providers to implement the NSA's Clipper Chip in their devices, but wanted us to reach a compromise with the FBI regardless. This completely startled us techies, who thought having the right answer was enough. It was at that moment that I learned an important difference between technologists and policy makers. Technologists want solutions; policy makers want consensus.

Since then, I have become more immersed in policy discussions. I have spent more time with legislators, advised advocacy organizations like EFF and EPIC, and worked with policy-minded think tanks in the United States and around the world. I teach cybersecurity policy and technology at the Harvard Kennedy School of Government. My most recent two books, *Data and Goliath*—about surveillance—and *Click Here to Kill Everybody*—about IoT security—are really about the policy implications of technology.

Over that time, I have observed many other differences between technologists and policy makers—differences that we in cybersecurity need to understand if we are to translate our technological solutions into viable policy outcomes.

Technologists don't try to consider all of the use cases of a given technology. We tend to build something for the uses we envision, and hope that others can figure out new and innovative ways to extend what we created. We

love it when there is a new use for a technology that we never considered and that changes the world. And while we might be good at security around the use cases we envision, we are regularly blindsided when it comes to new uses or edge cases. (Authentication risks surrounding someone's intimate partner is a good example.) Policy doesn't work that way; it's specifically focused on use. It focuses on people and what they do. Policy makers can't create policy around a piece of technology without understanding how it is used—how all of it's used.

Policy is often driven by exceptional events, like the FBI's desire to break the encryption on the San Bernardino shooter's iPhone. (The PATRIOT Act is the most egregious example I can think of.) Technologists tend to look at more general use cases, like the overall value of strong encryption to societal security. Policy tends to focus on the past, making existing systems work or correcting wrongs that have happened. It's hard to imagine policy makers creating laws around VR systems, because they don't yet exist in any meaningful way. Technology is inherently future focused. Technologists try to imagine better systems, or future flaws in present systems, and work to improve things.

As technologists, we iterate. It's how we write software. It's how we field products. We know we can't get it right the first time, so we have developed all sorts of agile systems to deal with that fact. Policy making is often the opposite. U.S. federal laws take months or years to negotiate and pass, and after that the issue doesn't get addressed again for a decade or more. It is much more critical to get it right the first time, because the effects of getting it wrong are long lasting. (See, for example, parts of the GDPR.) Sometimes regulatory agencies can be more agile. The courts can also iterate policy, but it's slower.

Along similar lines, the two groups work in very different time frames. Engineers, conditioned by Moore's law, have long thought of 18 months as the maximum time to roll out a



PURPOSE: The IEEE Computer Society is the world's largest association of computing professionals and is the leading provider of technical information in the field.

MEMBERSHIP: Members receive the monthly magazine *Computer*, discounts, and opportunities to serve (all activities are led by volunteer members). Membership is open to all IEEE members, affiliate society members, and others interested in the computer field.

COMPUTER SOCIETY WEBSITE: www.computer.org

OMBUDSMAN: Direct unresolved complaints to ombudsman@computer.org.

CHAPTERS: Regular and student chapters worldwide provide the opportunity to interact with colleagues, hear technical experts, and serve the local professional community.

AVAILABLE INFORMATION: To check membership status, report an address change, or obtain more information on any of the following, email Customer Service at help@computer.org or call +1 714 821 8380 (international) or our toll-free number, +1 800 272 6657 (US):

- Membership applications
- Publications catalog
- Draft standards and order forms
- Technical committee list
- Technical committee application
- Chapter start-up procedures
- Student scholarship information
- Volunteer leaders/staff directory
- IEEE senior member grade application (requires 10 years practice and significant performance in five of those 10)

PUBLICATIONS AND ACTIVITIES

Computer: The flagship publication of the IEEE Computer Society, *Computer* publishes peer-reviewed technical content that covers all aspects of computer science, computer engineering, technology, and applications.

Periodicals: The society publishes 12 magazines and 18 journals. Refer to membership application or request information as noted above.

Conference Proceedings & Books: Conference Publishing Services publishes more than 275 titles every year.

Standards Working Groups: More than 150 groups produce IEEE standards used throughout the world.

Technical Committees: TCs provide professional interaction in more than 30 technical areas and directly influence computer engineering conferences and publications.

Conferences/Education: The society holds about 200 conferences each year and sponsors many educational activities, including computing science accreditation.

Certifications: The society offers three software developer credentials. For more information, visit www.computer.org/certification.

BOARD OF GOVERNORS MEETING

28 – 29 May: McLean, Virginia

EXECUTIVE COMMITTEE

President: Leila De Floriani

President-Elect: Forrest Shull

Past President: Cecilia Metra

First VP: Riccardo Mariani; **Second VP:** Sy-Yen Kuo

Secretary: Dimitrios Serpanos; **Treasurer:** David Lomet

VP, Membership & Geographic Activities: Yervant Zorian

VP, Professional & Educational Activities: Sy-Yen Kuo

VP, Publications: Fabrizio Lombardi

VP, Standards Activities: Riccardo Mariani

VP, Technical & Conference Activities: William D. Gropp

2019–2020 IEEE Division VIII Director: Elizabeth L. Burd

2020–2021 IEEE Division V Director: Thomas M. Conte

2020 IEEE Division VIII Director-Elect: Christina M. Schober

BOARD OF GOVERNORS

Term Expiring 2020: Andy T. Chen, John D. Johnson, Sy-Yen Kuo, David Lomet, Dimitrios Serpanos, Hayato Yamana

Term Expiring 2021: M. Brian Blake, Fred Douglass, Carlos E. Jimenez-Gomez, Ramalatha Marimuthu, Erik Jan Marinissen, Kunio Uchiyama

Term Expiring 2022: Nils Aschenbruck, Ernesto Cuadros-Vargas, David S. Ebert, William Gropp, Grace Lewis, Stefano Zanero

EXECUTIVE STAFF

Executive Director: Melissa A. Russell

Director, Governance & Associate Executive Director: Anne Marie Kelly

Director, Finance & Accounting: Sunny Hwang

Director, Information Technology & Services: Sumit Kacker

Director, Marketing & Sales: Michelle Tubb

Director, Membership Development: Eric Berkowitz

COMPUTER SOCIETY OFFICES

Washington, D.C.: 2001 L St., Ste. 700, Washington, D.C. 20036-4928; **Phone:** +1 202 371 0101; **Fax:** +1 202 728 9614;

Email: help@computer.org

Los Alamitos: 10662 Los Vaqueros Cir., Los Alamitos, CA 90720;

Phone: +1 714 821 8380; **Email:** help@computer.org

MEMBERSHIP & PUBLICATION ORDERS

Phone: +1 800 678 4333; **Fax:** +1 714 821 4641;

Email: help@computer.org

IEEE BOARD OF DIRECTORS

President: Toshio Fukuda

President-Elect: Susan K. "Kathy" Land

Past President: José M.F. Moura

Secretary: Kathleen A. Kramer

Treasurer: Joseph V. Lillie

Director & President, IEEE-USA: Jim Conrad

Director & President, Standards Association: Robert S. Fish

Director & VP, Educational Activities: Stephen Phillips

Director & VP, Membership & Geographic Activities:

Kukjin Chun

Director & VP, Publication Services & Products: Tapan Sarkar

Director & VP, Technical Activities: Kazuhiro Kosuge

Keep Your Career Options Open

Upload Your Resume Today!

Whether you enjoy your current position or you are ready for change, the **IEEE Computer Society Jobs Board** is a valuable resource tool.

Take advantage of these special resources for job seekers:



JOB ALERTS



TEMPLATES



CAREER
ADVICE



RESUMES VIEWED
BY TOP EMPLOYERS



WEBINARS

No matter your career level, the IEEE Computer Society Jobs Board keeps you connected to workplace trends and exciting new career prospects.

www.computer.org/jobs



IEEE
COMPUTER
SOCIETY